Center for Internet Security®

CIS Benchmarks™

CIS Microsoft Windows 11 STIG Benchmark

v1.0.0 - 08-12-2025

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is ***NEVER*** acceptable to host a CIS Benchmark in ***ANY*** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use *1*
Table of Contents *2*
Overview *8*
Target Technology Details 8
Intended Audience 8
Recommendation Definitions *9*
Title 9
Assessment Status 9
Automated 9
Manual 9
Profile 9
A collection of recommendations (or rules) for securing a technology or a supporting platform. STIG Benchmark profiles are used to identify which Vulnerability Severity Category Code (CAT) each rule is associated with. 9
Description 9
Rationale Statement 9
Audit Procedure 10
Remediation Procedure 10
Additional Information 10
Profile Definitions 11
Acknowledgements 12
Recommendations *13*
1 STIG RULES 13
1.1 WN11-00-000005 (Manual) 14
1.2 WN11-00-000010 (Manual) 15
1.3 WN11-00-000015 (Manual) 17
1.4 WN11-00-000020 (Manual) 18
1.5 WN11-00-000025 (Manual) 19
1.6 WN11-00-000030 (Manual) 21
1.7 WN11-00-000031 (Manual) 23
1.8 WN11-00-000032 (Manual) 26
1.9 WN11-00-000035 (Manual) 28
1.10 WN11-00-000040 (Manual) 30
1.11 WN11-00-000045 (Manual) 31
1.12 WN11-00-000050 (Manual) 33
1.13 WN11-00-000055 (Manual) 34
1.14 WN11-00-000060 (Manual) 35
1.15 WN11-00-000065 (Manual) 37
1.16 WN11-00-000070 (Manual) 39
1.17 WN11-00-000075 (Manual) 41

1.18 WN11-00-000080 (Manual) 42
1.19 WN11-00-000085 (Manual) 44
1.20 WN11-00-000090 (Manual) 46
1.21 WN11-00-000095 (Manual) 47
1.22 WN11-00-000100 (Manual) 51
1.23 WN11-00-000105 (Manual) 52
1.24 WN11-00-000110 (Manual) 53
1.25 WN11-00-000115 (Manual) 54
1.26 WN11-00-000120 (Manual) 55
1.27 WN11-00-000125 (Manual) 56
1.28 WN11-00-000130 (Manual) 57
1.29 WN11-00-000135 (Manual) 58
1.30 WN11-00-000140 (Manual) 59
1.31 WN11-00-000145 (Manual) 61
1.32 WN11-00-000150 (Manual) 63
1.33 WN11-00-000155 (Manual) 65
1.34 WN11-00-000160 (Manual) 67
1.35 WN11-00-000165 (Manual) 69
1.36 WN11-00-000170 (Manual) 71
1.37 WN11-00-000175 (Manual) 73
1.38 WN11-00-000190 (Manual) 74
1.39 WN11-00-000210 (Manual) 76
1.40 WN11-00-000220 (Manual) 77
1.41 WN11-00-000230 (Manual) 78
1.42 WN11-00-000240 (Manual) 79
1.43 WN11-00-000250 (Manual) 81
1.44 WN11-00-000260 (Manual) 82
1.45 WN11-00-000395 (Manual) 84
1.46 WN11-AC-000005 (Manual) 85
1.47 WN11-AC-000010 (Manual) 87
1.48 WN11-AC-000015 (Manual) 88
1.49 WN11-AC-000020 (Manual) 89
1.50 WN11-AC-000025 (Manual) 90
1.51 WN11-AC-000030 (Manual) 92
1.52 WN11-AC-000035 (Manual) 93
1.53 WN11-AC-000040 (Manual) 95
1.54 WN11-AC-000045 (Manual) 97
1.55 WN11-AU-000005 (Manual) 99
1.56 WN11-AU-000010 (Manual) 101
1.57 WN11-AU-000030 (Manual) 103
1.58 WN11-AU-000035 (Manual) 105
1.59 WN11-AU-000040 (Manual) 107
1.60 WN11-AU-000045 (Manual) 109
1.61 WN11-AU-000050 (Manual) 111
1.62 WN11-AU-000054 (Manual) 113
1.63 WN11-AU-000060 (Manual) 115
1.64 WN11-AU-000065 (Manual) 117
1.65 WN11-AU-000070 (Manual) 119
1.66 WN11-AU-000080 (Manual) 121
1.67 WN11-AU-000075 (Manual) 123
1.68 WN11-AU-000081 (Manual) 125
1.69 WN11-AU-000082 (Manual) 127
1.70 WN11-AU-000083 (Manual) 129
1.71 WN11-AU-000084 (Manual) 131
1.72 WN11-AU-000085 (Manual) 133
1.73 WN11-AU-000090 (Manual) 135

1.74 WN11-AU-000100 (Manual) 137
1.75 WN11-AU-000105 (Manual) 139
1.76 WN11-AU-000107 (Manual) 141
1.77 WN11-AU-000110 (Manual) 143
1.78 WN11-AU-000115 (Manual) 145
1.79 WN11-AU-000120 (Manual) 147
1.80 WN11-AU-000130 (Manual) 149
1.81 WN11-AU-000135 (Manual) 151
1.82 WN11-AU-000140 (Manual) 153
1.83 WN11-AU-000150 (Manual) 155
1.84 WN11-AU-000155 (Manual) 157
1.85 WN11-AU-000160 (Manual) 159
1.86 WN11-AU-000500 (Manual) 161
1.87 WN11-AU-000505 (Manual) 162
1.88 WN11-AU-000510 (Manual) 163
1.89 WN11-AU-000515 (Manual) 164
1.90 WN11-AU-000520 (Manual) 166
1.91 WN11-AU-000525 (Manual) 168
1.92 WN11-AU-000550 (Manual) 170
1.93 WN11-AU-000555 (Manual) 172
1.94 WN11-AU-000560 (Manual) 174
1.95 WN11-AU-000565 (Manual) 176
1.96 WN11-AU-000570 (Manual) 178
1.97 WN11-AU-000575 (Manual) 180
1.98 WN11-AU-000580 (Manual) 182
1.99 WN11-AU-000585 (Manual) 184
1.100 WN11-CC-000005 (Manual) 185
1.101 WN11-CC-000007 (Manual) 186
1.102 WN11-CC-000010 (Manual) 188
1.103 WN11-CC-000020 (Manual) 189
1.104 WN11-CC-000025 (Manual) 190
1.105 WN11-CC-000030 (Manual) 191
1.106 WN11-CC-000035 (Manual) 193
1.107 WN11-CC-000037 (Manual) 195
1.108 WN11-CC-000038 (Manual) 197
1.109 WN11-CC-000039 (Manual) 199
1.110 WN11-CC-000040 (Manual) 201
1.111 WN11-CC-000044 (Manual) 202
1.112 WN11-CC-000050 (Manual) 203
1.113 WN11-CC-000052 (Manual) 205
1.114 WN11-CC-000055 (Manual) 207
1.115 WN11-CC-000060 (Manual) 209
1.116 WN11-CC-000063 (Manual) 210
1.117 WN11-CC-000065 (Manual) 211
1.118 WN11-CC-000066 (Manual) 212
1.119 WN11-CC-000068 (Manual) 214
1.120 WN11-CC-000070 (Manual) 215
1.121 WN11-CC-000075 (Manual) 218
1.122 WN11-CC-000080 (Manual) 220
1.123 WN11-CC-000085 (Manual) 222
1.124 WN11-CC-000090 (Manual) 224
1.125 WN11-CC-000100 (Manual) 225
1.126 WN11-CC-000105 (Manual) 226
1.127 WN11-CC-000110 (Manual) 228
1.128 WN11-CC-000115 (Manual) 230
1.129 WN11-CC-000120 (Manual) 232

1.130 WN11-CC-000130 (Manual) 233
1.131 WN11-CC-000145 (Manual) 235
1.132 WN11-CC-000150 (Manual) 237
1.133 WN11-CC-000155 (Manual) 239
1.134 WN11-CC-000165 (Manual) 240
1.135 WN11-CC-000170 (Manual) 241
1.136 WN11-CC-000175 (Manual) 242
1.137 WN11-CC-000180 (Manual) 244
1.138 WN11-CC-000185 (Manual) 245
1.139 WN11-CC-000190 (Manual) 246
1.140 WN11-CC-000195 (Manual) 248
1.141 WN11-CC-000197 (Manual) 249
1.142 WN11-CC-000200 (Manual) 250
1.143 WN11-CC-000204 (Manual) 251
1.144 WN11-CC-000205 (Manual) 253
1.145 WN11-CC-000206 (Manual) 255
1.146 WN11-CC-000210 (Manual) 258
1.147 WN11-CC-000215 (Manual) 260
1.148 WN11-CC-000220 (Manual) 261
1.149 WN11-CC-000225 (Manual) 262
1.150 WN11-CC-000252 (Manual) 263
1.151 WN11-CC-000255 (Manual) 265
1.152 WN11-CC-000260 (Manual) 267
1.153 WN11-CC-000270 (Manual) 268
1.154 WN11-CC-000275 (Manual) 269
1.155 WN11-CC-000280 (Manual) 270
1.156 WN11-CC-000285 (Manual) 271
1.157 WN11-CC-000290 (Manual) 272
1.158 WN11-CC-000295 (Manual) 273
1.159 WN11-CC-000300 (Manual) 274
1.160 WN11-CC-000305 (Manual) 276
1.161 WN11-CC-000310 (Manual) 277
1.162 WN11-CC-000315 (Manual) 278
1.163 WN11-CC-000320 (Manual) 279
1.164 WN11-CC-000325 (Manual) 281
1.165 WN11-CC-000326 (Manual) 282
1.166 WN11-CC-000327 (Manual) 284
1.167 WN11-CC-000330 (Manual) 286
1.168 WN11-CC-000335 (Manual) 287
1.169 WN11-CC-000345 (Manual) 288
1.170 WN11-CC-000350 (Manual) 290
1.171 WN11-CC-000355 (Manual) 291
1.172 WN11-CC-000360 (Manual) 292
1.173 WN11-CC-000365 (Manual) 293
1.174 WN11-CC-000370 (Manual) 296
1.175 WN11-CC-000385 (Manual) 297
1.176 WN11-CC-000390 (Manual) 298
1.177 WN11-CC-000391 (Manual) 299
1.178 WN11-EP-000310 (Manual) 300
1.179 WN11-PK-000005 (Manual) 301
1.180 WN11-PK-000010 (Manual) 304
1.181 WN11-PK-000015 (Manual) 306
1.182 WN11-PK-000020 (Manual) 308
1.183 WN11-RG-000005 (Manual) 311
1.184 WN11-SO-000005 (Manual) 314
1.185 WN11-SO-000010 (Manual) 315

1.186 WN11-SO-000015 (Manual) 316
1.187 WN11-SO-000020 (Manual) 317
1.188 WN11-SO-000025 (Manual) 318
1.189 WN11-SO-000030 (Manual) 319
1.190 WN11-SO-000035 (Manual) 321
1.191 WN11-SO-000040 (Manual) 323
1.192 WN11-SO-000045 (Manual) 325
1.193 WN11-SO-000050 (Manual) 327
1.194 WN11-SO-000055 (Manual) 328
1.195 WN11-SO-000060 (Manual) 330
1.196 WN11-SO-000070 (Manual) 331
1.197 WN11-SO-000075 (Manual) 333
1.198 WN11-SO-000080 (Manual) 336
1.199 WN11-SO-000085 (Manual) 339
1.200 WN11-SO-000095 (Manual) 341
1.201 WN11-SO-000100 (Manual) 343
1.202 WN11-SO-000110 (Manual) 344
1.203 WN11-SO-000120 (Manual) 346
1.204 WN11-SO-000140 (Manual) 347
1.205 WN11-SO-000145 (Manual) 348
1.206 WN11-SO-000150 (Manual) 349
1.207 WN11-SO-000160 (Manual) 350
1.208 WN11-SO-000165 (Manual) 351
1.209 WN11-SO-000167 (Manual) 352
1.210 WN11-SO-000180 (Manual) 354
1.211 WN11-SO-000185 (Manual) 355
1.212 WN11-SO-000190 (Manual) 356
1.213 WN11-SO-000195 (Manual) 358
1.214 WN11-SO-000205 (Manual) 360
1.215 WN11-SO-000210 (Manual) 361
1.216 WN11-SO-000215 (Manual) 362
1.217 WN11-SO-000220 (Manual) 363
1.218 WN11-SO-000230 (Manual) 364
1.219 WN11-SO-000240 (Manual) 366
1.220 WN11-SO-000245 (Manual) 367
1.221 WN11-SO-000250 (Manual) 368
1.222 WN11-SO-000251 (Manual) 369
1.223 WN11-SO-000255 (Manual) 371
1.224 WN11-SO-000260 (Manual) 372
1.225 WN11-SO-000265 (Manual) 373
1.226 WN11-SO-000270 (Manual) 374
1.227 WN11-SO-000275 (Manual) 375
1.228 WN11-SO-000280 (Manual) 376
1.229 WN11-UC-000015 (Manual) 378
1.230 WN11-UR-000005 (Manual) 379
1.231 WN11-UC-000020 (Manual) 380
1.232 WN11-UR-000010 (Manual) 381
1.233 WN11-UR-000015 (Manual) 383
1.234 WN11-UR-000025 (Manual) 384
1.235 WN11-UR-000030 (Manual) 386
1.236 WN11-UR-000035 (Manual) 388
1.237 WN11-UR-000040 (Manual) 390
1.238 WN11-UR-000045 (Manual) 391
1.239 WN11-UR-000050 (Manual) 392
1.240 WN11-UR-000055 (Manual) 394
1.241 WN11-UR-000060 (Manual) 395

1.242 WN11-UR-000065 (Manual) 397
1.243 WN11-UR-000070 (Manual) 399
1.244 WN11-UR-000075 (Manual) 402
1.245 WN11-UR-000080 (Manual) 404
1.246 WN11-UR-000085 (Manual) 406
1.247 WN11-UR-000090 (Manual) 409
1.248 WN11-UR-000095 (Manual) 412
1.249 WN11-UR-000100 (Manual) 413
1.250 WN11-UR-000110 (Manual) 415
1.251 WN11-UR-000120 (Manual) 417
1.252 WN11-UR-000125 (Manual) 419
1.253 WN11-UR-000130 (Manual) 420
1.254 WN11-UR-000140 (Manual) 422
1.255 WN11-UR-000145 (Manual) 424
1.256 WN11-UR-000150 (Manual) 426
1.257 WN11-UR-000160 (Manual) 428
1.258 WN11-UR-000165 (Manual) 430

Appendix: Summary Table 432

Appendix: Change History 444

Overview

Target Technology Details

Microsoft Windows 11 Secure Technical Implementation Guide (STIG)

Version: 2 Release: 3 Benchmark

Date: 02 Apr 2025

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft Windows 11 and are looking to comply with the STIG guidance

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations (or rules) for securing a technology or a supporting platform. STIG Benchmark profiles are used to identify which Vulnerability Severity Category Code (CAT) each rule is associated with.

Description

The Rule Title from the STIG.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Additional Information

References from the STIG Rule if applicable.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **SEVERITY: CAT I**

  Items in this profile exhibit one or more of the following characteristics:

  - are considered to be high severity
  - are intended for environments or use cases where following STIG based security guidance is paramount.
  - acts as defense in depth measure.
  - may negatively inhibit the utility or performance of the technology.

  This profile is intended for servers and workstations.

- **SEVERITY: CAT II**

  Items in this profile exhibit one or more of the following characteristics:

  - are considered to be medium severity
  - are intended for environments or use cases where following STIG based security guidance is paramount.
  - acts as defense in depth measure.
  - may negatively inhibit the utility or performance of the technology.

  This profile is intended for servers and workstations.

- **SEVERITY: CAT III**

  Items in this profile exhibit one or more of the following characteristics:

  - are considered to be low severity
  - are intended for environments or use cases where following STIG based security guidance is paramount.
  - acts as defense in depth measure.
  - may negatively inhibit the utility or performance of the technology.

  This profile is intended for servers and workstations.

Acknowledgements

The Recommendations in this Benchmark are a representation of the Rules in the unclassified DISA STIG for Microsoft Windows 11

Recommendations

1 STIG RULES

Microsoft Windows 11

Microsoft Windows 11 Secure Technical Implementation Guide (STIG)

Version: 2 Release: 3 Benchmark

Date: 02 Apr 2025

CLASSIFICATION unclassified

1.1 WN11-00-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Domain-joined systems must use Windows 11 Enterprise Edition 64-bit version.

```
GROUP ID: V-253254
RULE ID: SV-253254r991589
```

Rationale:

Features such as Credential Guard use virtualization-based security to protect information that could be used in credential theft attacks if compromised. There are a number of system requirements that must be met in order for Credential Guard to be configured and enabled properly. Virtualization-based security and Credential Guard are only available with Windows 11 Enterprise 64-bit version.

Audit:

Verify domain-joined systems are using Windows 11 Enterprise Edition 64-bit version.

For standalone systems, this is NA.

Open "Settings".

Select "System", then "About".

If "Edition" is not "Windows 11 Enterprise", this is a finding.

If "System type" is not "64-bit operating system...", this is a finding.

Remediation:

Use Windows 11 Enterprise 64-bit version for domain-joined systems.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.2 WN11-00-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 domain-joined systems must have a Trusted Platform Module (TPM) enabled.

```
GROUP ID: V-253255
RULE ID: SV-253255r971547
```

Rationale:

Credential Guard uses virtualization-based security to protect information that could be used in credential theft attacks if compromised. There are a number of system requirements that must be met in order for Credential Guard to be configured and enabled properly. Without a TPM enabled and ready for use, Credential Guard keys are stored in a less secure method using software.

Audit:

Verify domain-joined systems have a TPM enabled and ready for use.

For standalone systems, this is NA.

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Verify the system has a TPM and is ready for use.

Run "tpm.msc".

Review the sections in the center pane.

"Status" must indicate it has been configured with a message such as "The TPM is ready for use" or "The TPM is on and ownership has been taken".

TPM Manufacturer Information - Specific Version = 2.0

If a TPM is not found or is not ready for use, this is a finding.

Remediation:

For standalone systems, this is NA.

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Ensure domain-joined systems must have a TPM that is configured for use. (Versions 2.0 support Credential Guard.)

The TPM must be enabled in the firmware.

Run "tpm.msc" for configuration options in Windows.

Additional Information:

CCI-002421 Implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission.

- NIST SP 800-53 Revision 4::SC-8 (1)
- NIST SP 800-53 Revision 5::SC-8 (1)

1.3 WN11-00-000015 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 systems must have Unified Extensible Firmware Interface (UEFI) firmware and be configured to run in UEFI mode, not Legacy BIOS.

```
GROUP ID: V-253256
RULE ID: SV-253256r971547
```

Rationale:

UEFI provides additional security features in comparison to legacy BIOS firmware, including Secure Boot. UEFI is required to support additional security features in Windows 11, including virtualization-based Security and Credential Guard. Systems with UEFI that are operating in Legacy BIOS mode will not support these security features.

Audit:

For virtual desktop implementations (VDIs) where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Verify the system firmware is configured to run in UEFI mode, not Legacy BIOS.

Run "System Information".

Under "System Summary", if "BIOS Mode" does not display "UEFI", this is a finding.

Remediation:

Configure UEFI firmware to run in UEFI mode, not Legacy BIOS mode.

Additional Information:

CCI-002421 Implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission.

- NIST SP 800-53 Revision 4::SC-8 (1)
- NIST SP 800-53 Revision 5::SC-8 (1)

1.4 WN11-00-000020 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Secure Boot must be enabled on Windows 11 systems.

```
GROUP ID: V-253257
RULE ID: SV-253257r971547
```

Rationale:

Secure Boot is a standard that ensures systems boot only to a trusted operating system. Secure Boot is required to support additional security features in Windows 11, including virtualization-based Security and Credential Guard. If Secure Boot is turned off, these security features will not function.

Audit:

Verify the system firmware is configured for Secure Boot.

For virtual desktop implementations (VDIs) where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Run "System Information".

Under "System Summary", if "Secure Boot State" does not display "On", this is a finding.

Remediation:

Enable Secure Boot in the system firmware.

Additional Information:

CCI-002421 Implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission.

- NIST SP 800-53 Revision 4::SC-8 (1)
- NIST SP 800-53 Revision 5::SC-8 (1)

1.5 WN11-00-000025 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must employ automated mechanisms to determine the state of system components with regard to flaw remediation using the following frequency: Continuously, where ESS is used; 30 days, for any additional internal network scans not covered by ESS; and annually, for external scans by Computer Network Defense Service Provider (CNDSP).

```
GROUP ID: V-253258
RULE ID: SV-253258r1000099
```

Rationale:

An approved tool for continuous network scanning must be installed and configured to run.

Without the use of automated mechanisms to scan for security flaws on a continuous and/or periodic basis, the operating system or other system components may remain vulnerable to the exploits presented by undetected software flaws.

To support this requirement, the operating system may have an integrated solution incorporating continuous scanning using ESS and periodic scanning using other tools, as specified in the requirement.

Audit:

Verify DOD-approved ESS software is installed and properly operating. Ask the site information system security manager (ISSM) for documentation of the ESS software installation and configuration.

If the ISSM is not able to provide a documented configuration for an installed ESS or if the ESS software is not properly maintained or used, this is a finding.

Note: Example of documentation can be a copy of the site's CCB approved Software Baseline with version of software noted or a memo from the ISSM stating current ESS software and version.

Remediation:

Install DOD-approved ESS software and ensure it is operating continuously.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.6 WN11-00-000030 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Windows 11 information systems must use BitLocker to encrypt all disks to protect the confidentiality and integrity of all information at rest.

```
GROUP ID: V-253259
RULE ID: SV-253259r958870
```

Rationale:

If data at rest is unencrypted, it is vulnerable to disclosure. Even if the operating system enforces permissions on data access, an adversary can remove non-volatile memory and read it directly, thereby circumventing operating system controls. Encrypting the data ensures that confidentiality is protected even when the operating system is not running.

Audit:

Verify all Windows 11 information systems (including SIPRNet) employ BitLocker for full disk encryption.

For virtual desktop implementations (VDIs) in which the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

For AVD implementations with no data at rest, this is NA.

If full disk encryption using BitLocker is not implemented, this is a finding.

Verify BitLocker is turned on for the operating system drive and any fixed data drives.

Open "BitLocker Drive Encryption" from the Control Panel.

If the operating system drive or any fixed data drives have "Turn on BitLocker", this is a finding.

Note: An alternate encryption application may be used in lieu of BitLocker providing it is configured for full disk encryption and satisfies the pre-boot authentication requirements (WN11-00-000031 and WN11-00-000032).

Remediation:

Enable full disk encryption on all information systems (including SIPRNet) using BitLocker.

BitLocker, included in Windows, can be enabled in the Control Panel under "BitLocker Drive Encryption" as well as other management tools.

Note: An alternate encryption application may be used in lieu of BitLocker providing it is configured for full disk encryption and satisfies the pre-boot authentication requirements (WN11-00-000031 and WN11-00-000032).

Additional Information:

CCI-002475 Implement cryptographic mechanisms to prevent unauthorized modification of organization-defined information when at rest on organization-defined system components.

- NIST SP 800-53 Revision 4::SC-28 (1)
- NIST SP 800-53 Revision 5::SC-28 (1)

1.7 WN11-00-000031 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Windows 11 systems must use a BitLocker PIN for pre-boot authentication.

```
GROUP ID: V-253260
RULE ID: SV-253260r958872
```

Rationale:

If data at rest is unencrypted, it is vulnerable to disclosure. Even if the operating system enforces permissions on data access, an adversary can remove non-volatile memory and read it directly, thereby circumventing operating system controls. Encrypting the data ensures that confidentiality is protected even when the operating system is not running. Pre-boot authentication prevents unauthorized users from accessing encrypted drives.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

For virtual desktop implementations (VDIs) in which the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

For AVD implementations with no data at rest, this is NA.

```
Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\FVE\

Value Name: UseAdvancedStartup

Type: REG_DWORD

Value: 0x00000001 (1)

If one of the following registry values does not exist or is not configured
as specified, this is a finding.
```

Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\FVE\

Value Name: UseTPMPIN

Type: REG_DWORD

Value: 0x00000001 (1)

Value Name: UseTPMKeyPIN

Type: REG_DWORD

Value: 0x00000001 (1)

When BitLocker network unlock is used:

Value Name: UseTPMPIN

Type: REG_DWORD

Value: 0x00000002 (2)

Value Name: UseTPMKeyPIN

Type: REG_DWORD

Value: 0x00000002 (2)

BitLocker network unlock may be used in conjunction with a BitLocker PIN. See the article below regarding information about network unlock.

https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-how-to-enable-network-unlock

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
BitLocker Drive Encryption >> Operating System Drives "Require additional
authentication at startup"
```

to "Enabled" with "Configure TPM Startup PIN:" set to "Require startup PIN with TPM" or with "Configure TPM startup key and PIN:" set to "Require startup key and PIN with TPM".

Additional Information:

CCI-002476 Implement cryptographic mechanisms to prevent unauthorized disclosure of organization-defined information at rest on organization-defined system components.

- NIST SP 800-53 Revision 4::SC-28 (1)
- NIST SP 800-53 Revision 5::SC-28 (1)

1.8 WN11-00-000032 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 systems must use a BitLocker PIN with a minimum length of six digits for pre-boot authentication.

```
GROUP ID: V-253261
RULE ID: SV-253261r958504
```

Rationale:

If data at rest is unencrypted, it is vulnerable to disclosure. Even if the operating system enforces permissions on data access, an adversary can remove non-volatile memory and read it directly, thereby circumventing operating system controls. Encrypting the data ensures that confidentiality is protected even when the operating system is not running. Pre-boot authentication prevents unauthorized users from accessing encrypted drives. Increasing the pin length requires a greater number of guesses for an attacker.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

For virtual desktop implementations (VDIs) in which the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

For AVD implementations with no data at rest, this is NA.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\FVE\

Value Name: MinimumPIN
Type: REG_DWORD
Value: 0x00000006 (6) or greater
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
BitLocker Drive Encryption >> Operating System Drives "Configure minimum PIN
length for startup"
```

to "Enabled" with "Minimum characters:" set to "6" or greater.

Additional Information:

CCI-000804 Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users.

- NIST SP 800-53::IA-8
- NIST SP 800-53 Revision 4::IA-8
- NIST SP 800-53 Revision 5::IA-8
- NIST SP 800-53A::IA-8.1

1.9 WN11-00-000035 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The operating system must employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs.

```
GROUP ID: V-253262
RULE ID: SV-253262r958808
```

Rationale:

Utilizing an allowlist provides a configuration management method for allowing the execution of only authorized software. Using only authorized software decreases risk by limiting the number of potential vulnerabilities.

The organization must identify authorized software programs and only permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as allowlisting.

Audit:

Verify the operating system employs a deny-all, permit-by-exception policy to allow the execution of authorized software programs. This must include packaged apps such as the universal apps installed by default on systems.

If an application allowlisting program is not in use on the system, this is a finding.

Configuration of allowlisting applications will vary by the program.

AppLocker is an allowlisting application built into Windows 11 Enterprise. A deny-by-default implementation is initiated by enabling any AppLocker rules within a category, only allowing what is specified by defined rules.

If AppLocker is used, perform the following to view the configuration of AppLocker:

Run "PowerShell".

Execute the following command, substituting [c:\temp\file.xml] with a location and file name appropriate for the system:

Get-AppLockerPolicy -Effective -XML > c:\temp\file.xml

This will produce an xml file with the effective settings that can be viewed in a browser or opened in a program such as Excel for review.

Implementation guidance for AppLocker is available at the following link:

https://docs.microsoft.com/en-us/windows/security/threat-protection/windows-defender-application-control/applocker/applocker-policies-deployment-guide

Remediation:

Configure an application allowlisting program to employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs.

Configuration of allowlisting applications will vary by the program. AppLocker is an allowlisting application built into Windows 11 Enterprise.

If AppLocker is used, it is configured through group policy in

```
Computer Configuration >> Windows Settings >> Security Settings >>
Application Control Policies >> AppLocker.
```

Implementation guidance for AppLocker is available in the NSA paper "Application allowlisting using Microsoft AppLocker" at the following link:

https://docs.microsoft.com/en-us/windows/security/threat-protection/windows-defender-application-control/applocker/applocker-policies-deployment-guide

Additional Information:

CCI-001774 Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system.

- NIST SP 800-53 Revision 4::CM-7 (5) (b)
- NIST SP 800-53 Revision 5::CM-7 (5) (b)

1.10 WN11-00-000040 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Windows 11 systems must be maintained at a supported servicing level.

```
GROUP ID: V-253263
RULE ID: SV-253263r1016364
```

Rationale:

Windows 11 is maintained by Microsoft at servicing levels for specific periods of time to support Windows as a Service. Systems at unsupported servicing levels or releases will not receive security updates for new vulnerabilities which leaves them subject to exploitation.

New versions with feature updates are planned to be released on a semi-annual basis with an estimated support timeframe of 18 to 30 months depending on the release. Support for previously released versions has been extended for Enterprise editions.

A separate servicing branch intended for special purpose systems is the Long-Term Servicing Channel (LTSC, formerly Branch - LTSB) which will receive security updates for 10 years but excludes feature updates.

Audit:

Run "winver.exe".

If the "About Windows" dialog box does not display "Microsoft Windows 11 Version 22H2 (OS Build 22621.380)" or greater, this is a finding.

Remediation:

Update systems on the Semi-Annual Channel to "Microsoft Windows 11 Version 22H2 (OS Build 22621.380)" or greater.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.11 WN11-00-000045 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The Windows 11 system must use an antivirus program.

```
GROUP ID: V-253264
RULE ID: SV-253264r991589
```

Rationale:

Malicious software can establish a base on individual desktops and servers. Employing an automated mechanism to detect this type of software will aid in elimination of the software from the operating system.

Audit:

Verify an antivirus solution is installed on the system and in use. The antivirus solution may be bundled with an approved Endpoint Security Solution.

Verify if Microsoft Defender Antivirus is in use or enabled:

Open "PowerShell".

Enter

```
"get-service | where {$_.DisplayName -Like "*Defender*"} | Select
Status,DisplayName"
```

Verify third-party antivirus is in use or enabled:

Open "PowerShell".

Enter

```
"get-service | where {$_.DisplayName -Like "*mcafee*"} | Select
Status,DisplayName"
```

Enter

```
"get-service | where {$_.DisplayName -Like "*symantec*"} | Select
Status,DisplayName"
```

If there is no antivirus solution installed on the system, this is a finding.

Remediation:

Install Microsoft Defender Antivirus or a third-party antivirus solution.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.12 WN11-00-000050 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Local volumes must be formatted using NTFS.

```
GROUP ID: V-253265
RULE ID: SV-253265r958472
```

Rationale:

The ability to set access permissions and auditing is critical to maintaining the security and proper access controls of a system. To support this, volumes must be formatted using the NTFS file system.

Audit:

Run "Computer Management".

Navigate to Storage >> Disk Management.

If the "File System" column does not indicate "NTFS" for each volume assigned a drive letter, this is a finding.

This does not apply to system partitions such the Recovery and EFI System Partition.

Remediation:

Format all local volumes to use NTFS.

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.13 WN11-00-000055 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Alternate operating systems must not be permitted on the same system.

```
GROUP ID: V-253266
RULE ID: SV-253266r991589
```

Rationale:

Allowing other operating systems to run on a secure system may allow security to be circumvented.

Audit:

Verify the system does not include other operating system installations.

Run "Advanced System Settings".

Select the "Advanced" tab.

Click the "Settings" button in the "Startup and Recovery" section.

If the drop-down list box "Default operating system:" shows any operating system other than Windows 11, this is a finding.

Remediation:

Ensure Windows 11 is the only operating system on a device. Remove alternate operating systems.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.14 WN11-00-000060 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Non-system-created file shares on a system must limit access to groups that require it.

```
GROUP ID: V-253267
RULE ID: SV-253267r958524
```

Rationale:

Shares which provide network access, must not exist on a workstation except for system-created administrative shares, and could potentially expose sensitive information. If a share is necessary, share permissions, as well as NTFS permissions, must be reconfigured to give the minimum access to those accounts that require it.

Audit:

Non-system-created shares must not exist on workstations.

If only system-created shares exist on the system, this is NA.

Run "Computer Management".

Navigate to System Tools >> Shared Folders >> Shares.

If the only shares listed are "ADMIN$", "C$" and "IPC$", this is NA.

(Selecting Properties for system-created shares will display a message that it has been shared for administrative purposes.)

Right-click any non-system-created shares.

Select "Properties".

Select the "Share Permissions" tab.

Verify the necessity of any shares found.

If the file shares have not been reconfigured to restrict permissions to the specific groups or accounts that require access, this is a finding.

Select the "Security" tab.

If the NTFS permissions have not been reconfigured to restrict permissions to the specific groups or accounts that require access, this is a finding.

Remediation:

If a non-system-created share is required on a system, configure the share and NTFS permissions to limit access to the specific groups or accounts that require it.

Remove any unnecessary non-system-created shares.

Additional Information:

CCI-001090 Prevent unauthorized and unintended information transfer via shared system resources.

- NIST SP 800-53::SC-4
- NIST SP 800-53 Revision 4::SC-4
- NIST SP 800-53 Revision 5::SC-4
- NIST SP 800-53A::SC-4.1

1.15 WN11-00-000065 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Unused accounts must be disabled or removed from the system after 35 days of inactivity.

```
GROUP ID: V-253268
RULE ID: SV-253268r1051039
```

Rationale:

Outdated or unused accounts provide penetration points that may go undetected. Inactive accounts must be deleted if no longer necessary or, if still required, disable until needed.

Satisfies: SRG-OS-000468-GPOS-00212, SRG-OS-000118-GPOS-00060

Audit:

Run "PowerShell".

Copy the lines below to the PowerShell window and enter.

"([ADSI]('WinNT://{0}' -f $env:COMPUTERNAME)).Children | Where { $.*SchemaClassName -eq 'user' } | ForEach {*

$user = *([ADSI]$*.Path)

$lastLogin = $user.Properties.LastLogin.Value

$enabled = ($user.Properties.UserFlags.Value -band 0x2) -ne 0x2

if ($lastLogin -eq $null) {

$lastLogin = 'Never'

}

Write-Host $user.Name $lastLogin $enabled

}"

This will return a list of local accounts with the account name, last logon, and if the account is enabled (True/False).

For example: User1 10/31/2015 5:49:56 AM True

Review the list to determine the finding validity for each account reported.

Exclude the following accounts:

Built-in administrator account (Disabled, SID ending in 500)

Built-in guest account (Disabled, SID ending in 501)

Built-in DefaultAccount (Disabled, SID ending in 503)

Local administrator account

If any enabled accounts have not been logged on to within the past 35 days, this is a finding.

Inactive accounts that have been reviewed and deemed to be required must be documented with the information system security officer (ISSO).

Remediation:

Review local accounts and verify their necessity. Disable or delete any active accounts that have not been used in the last 35 days.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

CCI-003627 Disable accounts when the accounts have expired.

- NIST SP 800-53 Revision 5::AC-2 (3) (a)

CCI-000795 The organization manages information system identifiers by disabling the identifier after an organization-defined time period of inactivity.

- NIST SP 800-53::IA-4 e
- NIST SP 800-53 Revision 4::IA-4 e
- NIST SP 800-53A::IA-4.1 (iii)

1.16 WN11-00-000070 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Only accounts responsible for the administration of a system must have Administrator rights on the system.

```
GROUP ID: V-253269
RULE ID: SV-253269r958702
```

Rationale:

An account that does not have Administrator duties must not have Administrator rights. Such rights would allow the account to bypass or modify required security restrictions on that machine and make it vulnerable to attack.

System administrators must log on to systems only using accounts with the minimum level of authority necessary.

For domain-joined workstations, the Domain Admins group must be replaced by a domain workstation administrator group (see V-36434 in the Active Directory Domain STIG). Restricting highly privileged accounts from the local Administrators group helps mitigate the risk of privilege escalation resulting from credential theft attacks.

Standard user accounts must not be members of the local administrators group.

Audit:

Run "Computer Management".

Navigate to System Tools >> Local Users and Groups >> Groups.

Review the members of the Administrators group.

Only the appropriate administrator groups or accounts responsible for administration of the system may be members of the group.

For domain-joined workstations, the Domain Admins group must be replaced by a domain workstation administrator group.

Standard user accounts must not be members of the local administrator group.

If prohibited accounts are members of the local administrators group, this is a finding.

The built-in Administrator account or other required administrative accounts would not be a finding.

Remediation:

Configure the system to include only administrator groups or accounts that are responsible for the system in the local Administrators group.

For domain-joined workstations, the Domain Admins group must be replaced by a domain workstation administrator group.

Remove any standard user accounts.

Additional Information:

CCI-002165 Enforce organization-defined discretionary access control policies over defined subjects and objects.

- NIST SP 800-53 Revision 4::AC-3 (4)
- NIST SP 800-53 Revision 5::AC-3 (4)

1.17 WN11-00-000075 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Only accounts responsible for the backup operations must be members of the Backup Operators group.

```
GROUP ID: V-253270
RULE ID: SV-253270r991589
```

Rationale:

Backup Operators are able to read and write to any file in the system, regardless of the rights assigned to it. Backup and restore rights permit users to circumvent the file access restrictions present on NTFS disk drives for backup and restore purposes. Members of the Backup Operators group must have separate logon accounts for performing backup duties.

Audit:

Run "Computer Management".

Navigate to System Tools >> Local Users and Groups >> Groups.

Review the members of the Backup Operators group.

If the group contains no accounts, this is not a finding.

If the group contains any accounts, the accounts must be specifically for backup functions.

If the group contains any standard user accounts used for performing normal user tasks, this is a finding.

Remediation:

Create separate accounts for backup operations for users with this privilege.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.18 WN11-00-000080 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Only authorized user accounts must be allowed to create or run virtual machines on Windows 11 systems.

```
GROUP ID: V-253271
RULE ID: SV-253271r958702
```

Rationale:

Allowing other operating systems to run on a secure system may allow users to circumvent security. For Hyper-V, preventing unauthorized users from being assigned to the Hyper-V Administrators group will prevent them from accessing or creating virtual machines on the system. The Hyper-V Hypervisor is used by virtualization-based Security features such as Credential Guard on Windows 11; however, it is not the full Hyper-V installation.

Audit:

If a hosted hypervisor (Hyper-V, VMware Workstation, etc.) is installed on the system, verify only authorized user accounts are allowed to run virtual machines.

For Hyper-V, run "Computer Management".

Navigate to System Tools >> Local Users and Groups >> Groups.

Double click on "Hyper-V Administrators".

If any unauthorized groups or user accounts are listed in "Members:", this is a finding.

For hosted hypervisors other than Hyper-V, verify only authorized user accounts have access to run the virtual machines. Restrictions may be enforced by access to the physical system, software restriction policies, or access restrictions built into the application.

If any unauthorized groups or user accounts have access to create or run virtual machines, this is a finding.

All users authorized to create or run virtual machines must be documented with the ISSM/ISSO. Accounts nested within group accounts must be documented as individual accounts and not the group accounts.

Remediation:

For Hyper-V, remove any unauthorized groups or user accounts from the "Hyper-V Administrators" group.

For hosted hypervisors other than Hyper-V, restrict access to create or run virtual machines to authorized user accounts only.

Additional Information:

CCI-002165 Enforce organization-defined discretionary access control policies over defined subjects and objects.

- NIST SP 800-53 Revision 4::AC-3 (4)
- NIST SP 800-53 Revision 5::AC-3 (4)

1.19 WN11-00-000085 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Standard local user accounts must not exist on a system in a domain.

```
GROUP ID: V-253272
RULE ID: SV-253272r991589
```

Rationale:

To minimize potential points of attack, local user accounts, other than built-in accounts and local administrator accounts, must not exist on a workstation in a domain. Users must log on to workstations in a domain with their domain accounts.

Audit:

Run "Computer Management".

Navigate to System Tools >> Local Users and Groups >> Users.

If local users other than the accounts listed below exist on a workstation in a domain, this is a finding.

For standalone or nondomain-joined systems, this is Not Applicable.

Built-in Administrator account (Disabled)

Built-in Guest account (Disabled)

Built-in DefaultAccount (Disabled)

Built-in defaultuser0 (Disabled)

Built-in WDAGUtilityAccount (Disabled)

Local administrator account(s)

All of the built-in accounts may not exist on a system, depending on the Windows 11 version.

Remediation:

Limit local user accounts on domain-joined systems. Remove any unauthorized local accounts.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.20 WN11-00-000090 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Accounts must be configured to require password expiration.

```
GROUP ID: V-253273
RULE ID: SV-253273r1051040
```

Rationale:

Passwords that do not expire increase exposure with a greater probability of being discovered or cracked.

Audit:

Run "Computer Management".

Navigate to System Tools >> Local Users and Groups >> Users.

Double-click each active account.

If "Password never expires" is selected for any account, this is a finding.

Remediation:

Configure all passwords to expire.

Run "Computer Management".

Navigate to System Tools >> Local Users and Groups >> Users.

Double-click each active account.

Ensure "Password never expires" is not checked on all active accounts.

Additional Information:

CCI-004066 For password-based authentication, enforce organization-defined composition and complexity rules.

- NIST SP 800-53 Revision 5::IA-5 (1) (h)

CCI-000199 The information system enforces maximum password lifetime restrictions.

- NIST SP 800-53::IA-5 (1) (d)
- NIST SP 800-53 Revision 4::IA-5 (1) (d)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.21 WN11-00-000095 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Permissions for system files and directories must conform to minimum requirements.

```
GROUP ID: V-253274
RULE ID: SV-253274r1016661
```

Rationale:

Changing the system's file and directory permissions allows the possibility of unauthorized and anonymous modification to the operating system and installed applications.

Audit:

The default file system permissions are adequate when the Security Option "Network access: Let Everyone permissions apply to anonymous users" is set to "Disabled" (WN11-SO-000160).

If the default file system permissions are maintained and the referenced option is set to "Disabled", this is not a finding.

Verify the default permissions for the sample directories below. Non-privileged groups such as Users or Authenticated Users must not have greater than read & execute permissions except where noted as defaults. (Individual accounts must not be used to assign permissions.)

Select the "Security" tab, and the "Advanced" button.

C:

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

Administrators - Full control - This folder, subfolders, and files

SYSTEM - Full control - This folder, subfolders, and files

Users - Read & execute - This folder, subfolders, and files

Authenticated Users - Modify - Subfolders and files only

Authenticated Users - Create folders / append data - This folder only

\Program Files

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

TrustedInstaller - Full control - This folder and subfolders

SYSTEM - Modify - This folder only

SYSTEM - Full control - Subfolders and files only

Administrators - Modify - This folder only

Administrators - Full control - Subfolders and files only

Users - Read & execute - This folder, subfolders, and files

CREATOR OWNER - Full control - Subfolders and files only

ALL APPLICATION PACKAGES - Read & execute - This folder, subfolders, and files

ALL RESTRICTED APPLICATION PACKAGES - Read & execute - This folder, subfolders, and files

\Windows

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

TrustedInstaller - Full control - This folder and subfolders

SYSTEM - Modify - This folder only

SYSTEM - Full control - Subfolders and files only

Administrators - Modify - This folder only

Administrators - Full control - Subfolders and files only

Users - Read & execute - This folder, subfolders, and files

CREATOR OWNER - Full control - Subfolders and files only

ALL APPLICATION PACKAGES - Read & execute - This folder, subfolders, and files

ALL RESTRICTED APPLICATION PACKAGES - Read & execute - This folder, subfolders, and files

Alternately use icacls.

Run "CMD" as administrator.

Enter

```
"icacls" followed by the directory.
```

icacls c:

icacls "c:\program files"

icacls c:\windows

The following results will be displayed as each is entered:

c:

S-1-15-3-65536-1888954469-739942743-1668119174-2468466756-4239452838-1296943325-355587736-700089176 (S,RD,X,RA)

BUILTIN\Administrators:(OI)(CI)(F)

NT AUTHORITY\SYSTEM:(OI)(CI)(F)

BUILTIN\Users:(OI)(CI)(RX)

NT AUTHORITY\Authenticated Users:(OI)(CI)(IO)(M)

NT AUTHORITY\Authenticated Users:(AD)

Mandatory Label\High Mandatory Level:(OI)(NP)(IO)(NW)

Successfully processed 1 files; Failed processing 0 files

c:\program files

NT SERVICE\TrustedInstaller:(F)

NT SERVICE\TrustedInstaller:(CI)(IO)(F)

NT AUTHORITY\SYSTEM:(M)

NT AUTHORITY\SYSTEM:(OI)(CI)(IO)(F)

BUILTIN\Administrators:(M)

BUILTIN\Administrators:(OI)(CI)(IO)(F)

BUILTIN\Users:(RX)

BUILTIN\Users:(OI)(CI)(IO)(GR,GE)

CREATOR OWNER:(OI)(CI)(IO)(F)

APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(RX)

APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(OI)(CI)(IO)(GR,GE)

APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(RX)

APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(OI)(CI)(IO)(GR,GE)

Successfully processed 1 files; Failed processing 0 files

c:\windows

NT SERVICE\TrustedInstaller:(F)

NT SERVICE\TrustedInstaller:(CI)(IO)(F)

NT AUTHORITY\SYSTEM:(M)

NT AUTHORITY\SYSTEM:(OI)(CI)(IO)(F)

BUILTIN\Administrators:(M)

BUILTIN\Administrators:(OI)(CI)(IO)(F)

BUILTIN\Users:(RX)

BUILTIN\Users:(OI)(CI)(IO)(GR,GE)

CREATOR OWNER:(OI)(CI)(IO)(F)

APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(RX)

APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(OI)(CI)(IO)(GR,GE)

APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(RX)

APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES:(OI)(CI)(IO)(GR,GE)

Successfully processed 1 files; Failed processing 0 files

Remediation:

Maintain the default file system permissions and configure the Security Option: "Network access: Let everyone permissions apply to anonymous users" to "Disabled" (WN11-SO-000160).

Additional Information:

CCI-002165 Enforce organization-defined discretionary access control policies over defined subjects and objects.

- NIST SP 800-53 Revision 4::AC-3 (4)
- NIST SP 800-53 Revision 5::AC-3 (4)

1.22 WN11-00-000100 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Internet Information System (IIS) or its subcomponents must not be installed on a workstation.

```
GROUP ID: V-253275
RULE ID: SV-253275r958478
```

Rationale:

IIS is not installed by default. Installation of Internet Information System (IIS) may allow unauthorized internet services to be hosted. Websites must only be hosted on servers that have been designed for that purpose and can be adequately secured.

Audit:

Verify it has not been installed on the system.

Run "Programs and Features".

Select "Turn Windows features on or off".

If the entries for "Internet Information Services" or "Internet Information Services Hostable Web Core" are selected, this is a finding.

If an application requires IIS or a subset to be installed to function, this needs be documented with the ISSO. In addition, any applicable requirements from the IIS STIG must be addressed.

Remediation:

Uninstall "Internet Information Services" or "Internet Information Services Hostable Web Core" from the system.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.23 WN11-00-000105 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Simple Network Management Protocol (SNMP) must not be installed on the system.

```
GROUP ID: V-253276
RULE ID: SV-253276r958480
```

Rationale:

"SNMP" is not installed by default. Some protocols and services do not support required security features, such as encrypting passwords or traffic.

Audit:

Verify SNMP has not been installed.

Navigate to the Windows\System32 directory.

If the "SNMP" application exists, this is a finding.

Remediation:

Uninstall "Simple Network Management Protocol (SNMP)" from the system.

Run "Programs and Features".

Select "Turn Windows Features on or off".

De-select "Simple Network Management Protocol (SNMP)".

Additional Information:

CCI-000382 Configure the system to prohibit or restrict the use of organization-defined prohibited or restricted functions, system ports, protocols, software, and/or services.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 b
- NIST SP 800-53 Revision 5::CM-7 b
- NIST SP 800-53A::CM-7.1 (iii)

1.24 WN11-00-000110 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Simple TCP/IP Services must not be installed on the system.

```
GROUP ID: V-253277
RULE ID: SV-253277r958478
```

Rationale:

"Simple TCP/IP Services" is not installed by default. Some protocols and services do not support required security features, such as encrypting passwords or traffic.

Audit:

Verify Simple TCP/IP Services has not been installed.

Run "Services.msc".

If "Simple TCP/IP Services" is listed, this is a finding.

Remediation:

Uninstall "Simple TCPIP Services (i.e. echo, daytime etc.)" from the system.

Run "Programs and Features".

Select "Turn Windows Features on or off".

De-select "Simple TCPIP Services (i.e. echo, daytime etc.)".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.25 WN11-00-000115 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Telnet Client must not be installed on the system.

```
GROUP ID: V-253278
RULE ID: SV-253278r958480
```

Rationale:

The "Telnet Client" is not installed by default. Some protocols and services do not support required security features, such as encrypting passwords or traffic.

Audit:

Verify Telnet Client has not been installed.

Navigate to the Windows\System32 directory.

If the "telnet" application exists, this is a finding.

Remediation:

Uninstall "Telnet Client" from the system.

Run "Programs and Features".

Select "Turn Windows Features on or off".

De-select "Telnet Client".

Additional Information:

CCI-000382 Configure the system to prohibit or restrict the use of organization-defined prohibited or restricted functions, system ports, protocols, software, and/or services.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 b
- NIST SP 800-53 Revision 5::CM-7 b
- NIST SP 800-53A::CM-7.1 (iii)

1.26 WN11-00-000120 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The TFTP Client must not be installed on the system.

```
GROUP ID: V-253279
RULE ID: SV-253279r958480
```

Rationale:

The "TFTP Client" is not installed by default. Some protocols and services do not support required security features, such as encrypting passwords or traffic.

Audit:

Verify TFTP Client has not been installed.

Navigate to the Windows\System32 directory.

If the "TFTP" application exists, this is a finding.

Remediation:

Uninstall "TFTP Client" from the system.

Run "Programs and Features".

Select "Turn Windows Features on or off".

De-select "TFTP Client".

Additional Information:

CCI-000382 Configure the system to prohibit or restrict the use of organization-defined prohibited or restricted functions, system ports, protocols, software, and/or services.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 b
- NIST SP 800-53 Revision 5::CM-7 b
- NIST SP 800-53A::CM-7.1 (iii)

1.27 WN11-00-000125 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Copilot in Windows must be disabled for Windows 11

```
GROUP ID: V-268317
RULE ID: SV-268317r1016371
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Turning off this capability will prevent potentially sensitive information from being sent outside the enterprise and uncontrolled updates to the system.

Audit:

If the following local computer policy is not configured as specified, this is a finding:

User Configuration >> Administrative Templates >> Windows Components >> Windows Copilot >> "Turn off Windows Copilot" to "Enabled”.

Remediation:

Configure the policy value for User Configuration >> Administrative Templates >> Windows Components >> Windows Copilot >> "Turn off Windows Copilot" to "Enabled".

Additional Information:

CCI-000382 Configure the system to prohibit or restrict the use of organization-defined prohibited or restricted functions, system ports, protocols, software, and/or services.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 b
- NIST SP 800-53 Revision 5::CM-7 b
- NIST SP 800-53A::CM-7.1 (iii)

1.28 WN11-00-000130 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Software certificate installation files must be removed from Windows 11.

```
GROUP ID: V-253280
RULE ID: SV-253280r991589
```

Rationale:

Use of software certificates and their accompanying installation files for end users to access resources is less secure than the use of hardware-based certificates.

Audit:

Search all drives for *.p12 and *.pfx files.

If any files with these extensions exist, this is a finding.

This does not apply to server-based applications that have a requirement for .p12 certificate files (e.g., Oracle Wallet Manager) or Adobe PreFlight certificate files. Some applications create files with extensions of .p12 that are not certificate installation files. Removal of non-certificate installation files from systems is not required. These must be documented with the ISSO.

Remediation:

Remove any certificate installation files (*.p12 and *.pfx) found on a system.

Note: This does not apply to server-based applications that have a requirement for .p12 certificate files (e.g., Oracle Wallet Manager) or Adobe PreFlight certificate files.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.29 WN11-00-000135 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

A host-based firewall must be installed and enabled on the system.

```
GROUP ID: V-253281
RULE ID: SV-253281r991589
```

Rationale:

A firewall provides a line of defense against attack, allowing or blocking inbound and outbound connections based on a set of rules.

Audit:

Determine if a host-based firewall is installed and enabled on the system. If a host-based firewall is not installed and enabled on the system, this is a finding.

The configuration requirements will be determined by the applicable firewall STIG.

Remediation:

Install and enable a host-based firewall on the system.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.30 WN11-00-000140 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Inbound exceptions to the firewall on Windows 11 domain workstations must only allow authorized remote management hosts.

```
GROUP ID: V-253282
RULE ID: SV-253282r991593
```

Rationale:

Allowing inbound access to domain workstations from other systems may allow lateral movement across systems if credentials are compromised. Limiting inbound connections only from authorized remote management systems will help limit this exposure.

Audit:

Verify firewall exceptions to inbound connections on domain workstations include only authorized remote management hosts.

If allowed inbound exceptions are not limited to authorized remote management hosts, this is a finding.

Review inbound firewall exceptions.

```
Computer Configuration >> Windows Settings >> Security Settings >> Windows
Defender Firewall with Advanced Security >> Windows Defender Firewall with
Advanced Security >> Inbound Rules (this link will be in the right pane)
```

For any inbound rules that allow connections view the Scope for Remote IP address. This may be defined as an IP address, subnet, or range. The rule must apply to all firewall profiles.

If a third-party firewall is used, ensure comparable settings are in place.

Remediation:

Configure firewall exceptions to inbound connections on domain workstations to include only authorized remote management hosts.

Configure only inbound connection exceptions for authorized remote management hosts.

```
Computer Configuration >> Windows Settings >> Security Settings >> Windows
Defender Firewall with Advanced Security >> Windows Defender Firewall with
Advanced Security >> Inbound Rules (this link will be in the right pane)
```

For any inbound rules that allow connections, configure the Scope for Remote IP address to those of authorized remote management hosts. This may be defined as an IP address, subnet or range. Apply the rule to all firewall profiles.

If a third-party firewall is used, configure inbound exceptions to only include authorized remote management hosts.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.31 WN11-00-000145 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Data Execution Prevention (DEP) must be configured to at least OptOut.

```
GROUP ID: V-253283
RULE ID: SV-253283r958928
```

Rationale:

Attackers are constantly looking for vulnerabilities in systems and applications. Data Execution Prevention (DEP) prevents harmful code from running in protected memory locations reserved for Windows and other programs.

Audit:

Verify the DEP configuration.

Open a command prompt (cmd.exe) or PowerShell with elevated privileges (Run as administrator).

Enter

```
"BCDEdit /enum {current}". (If using PowerShell "{current}" must be enclosed
in quotes.)
```

If the value for "nx" is not "OptOut", this is a finding.

(The more restrictive configuration of "AlwaysOn" would not be a finding.)

Remediation:

Configure DEP to at least OptOut.

Note: Suspend BitLocker before making changes to the DEP configuration.

Open a command prompt (cmd.exe) or PowerShell with elevated privileges (Run as administrator).

Enter

```
"BCDEDIT /set {current} nx OptOut". (If using PowerShell "{current}" must be
enclosed in quotes.)
```

"AlwaysOn", a more restrictive selection, is also valid but does not allow applications that do not function properly to be opted out of DEP.

Opted out exceptions can be configured in the "System Properties".

Open "System" in Control Panel.

Select "Advanced system settings".

Click "Settings" in the "Performance" section.

Select the "Data Execution Prevention" tab.

Applications that are opted out are configured in the window below the selection "Turn on DEP for all programs and services except those I select:".

Additional Information:

CCI-002824 Implement organization-defined controls to protect its memory from unauthorized code execution.

- NIST SP 800-53 Revision 4::SI-16
- NIST SP 800-53 Revision 5::SI-16

1.32 WN11-00-000150 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Structured Exception Handling Overwrite Protection (SEHOP) must be enabled.

```
GROUP ID: V-253284
RULE ID: SV-253284r958928
```

Rationale:

Attackers are constantly looking for vulnerabilities in systems and applications. Structured Exception Handling Overwrite Protection (SEHOP) blocks exploits that use the Structured Exception Handling overwrite technique, a common buffer overflow attack.

Audit:

Verify SEHOP is turned on.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Session Manager\kernel\

Value Name: DisableExceptionChainValidation

Value Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MS Security Guide >>
"Enable Structured Exception Handling Overwrite Protection (SEHOP)"
```

to "Enabled".

This policy setting requires the installation of the SecGuide custom templates included with the STIG package. "SecGuide.admx" and "SecGuide.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-002824 Implement organization-defined controls to protect its memory from unauthorized code execution.

- NIST SP 800-53 Revision 4::SI-16
- NIST SP 800-53 Revision 5::SI-16

1.33 WN11-00-000155 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows PowerShell 2.0 feature must be disabled on the system.

```
GROUP ID: V-253285
RULE ID: SV-253285r958478
```

Rationale:

Windows PowerShell 5.0 added advanced logging features which can provide additional detail when malware has been run on a system. Disabling the Windows PowerShell 2.0 mitigates against a downgrade attack that evades the Windows PowerShell 5.0 script block logging feature.

Audit:

Run "Windows PowerShell" with elevated privileges (run as administrator).

Enter the following:

Get-WindowsOptionalFeature -Online | Where FeatureName -like *PowerShellv2*

If either of the following have a "State" of "Enabled", this is a finding.

FeatureName : MicrosoftWindowsPowerShellV2

State : Enabled

FeatureName : MicrosoftWindowsPowerShellV2Root

State : Enabled

Alternately:

Search for "Features".

Select "Turn Windows features on or off".

If "Windows PowerShell 2.0" (whether the subcategory of "Windows PowerShell 2.0 Engine" is selected or not) is selected, this is a finding.

Remediation:

Disable "Windows PowerShell 2.0" on the system.

Run "Windows PowerShell" with elevated privileges (run as administrator).

Enter the following:

Disable-WindowsOptionalFeature -Online -FeatureName MicrosoftWindowsPowerShellV2Root

This command must disable both "MicrosoftWindowsPowerShellV2Root" and "MicrosoftWindowsPowerShellV2" which correspond to "Windows PowerShell 2.0" and "Windows PowerShell 2.0 Engine" respectively in "Turn Windows features on or off".

Alternately:

Search for "Features".

Select "Turn Windows features on or off".

De-select "Windows PowerShell 2.0".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.34 WN11-00-000160 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Server Message Block (SMB) v1 protocol must be disabled on the system.

```
GROUP ID: V-253286
RULE ID: SV-253286r958478
```

Rationale:

SMBv1 is a legacy protocol that uses the MD5 algorithm as part of SMB. MD5 is known to be vulnerable to a number of attacks such as collision and preimage attacks as well as not being FIPS compliant.

Disabling SMBv1 support may prevent access to file or print sharing resources with systems or devices that only support SMBv1. File shares and print services hosted on Windows Server 2003 are an example, however Windows Server 2003 is no longer a supported operating system. Some older Network Attached Storage (NAS) devices may only support SMBv1.

Audit:

Different methods are available to disable SMBv1 on Windows 11. This is the preferred method, however if WN11-00-000165 and WN11-00-000170 are configured, this is NA.

Run "Windows PowerShell" with elevated privileges (run as administrator).

Enter the following:

Get-WindowsOptionalFeature -Online | Where FeatureName -eq SMB1Protocol

If "State : Enabled" is returned, this is a finding.

Alternately:

Search for "Features".

Select "Turn Windows features on or off".

If "SMB 1.0/CIFS File Sharing Support" is selected, this is a finding.

Remediation:

Disable the SMBv1 protocol.

Run "Windows PowerShell" with elevated privileges (run as administrator).

Enter the following:

Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

Alternately:

Search for "Features".

Select "Turn Windows features on or off".

De-select "SMB 1.0/CIFS File Sharing Support".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.35 WN11-00-000165 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Server Message Block (SMB) v1 protocol must be disabled on the SMB server.

```
GROUP ID: V-253287
RULE ID: SV-253287r958478
```

Rationale:

SMBv1 is a legacy protocol that uses the MD5 algorithm as part of SMB. MD5 is known to be vulnerable to a number of attacks such as collision and preimage attacks as well as not being FIPS compliant.

Disabling SMBv1 support may prevent access to file or print sharing resources with systems or devices that only support SMBv1. File shares and print services hosted on Windows Server 2003 are an example, however Windows Server 2003 is no longer a supported operating system. Some older network attached devices may only support SMBv1.

Audit:

Different methods are available to disable SMBv1 on Windows 11, if WN11-00-000160 is configured, this is NA.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\

Value Name: SMB1

Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MS Security Guide >>
"Configure SMBv1 Server"
```

to "Disabled".

This policy setting requires the installation of the SecGuide custom templates included with the STIG package. "SecGuide.admx" and "SecGuide.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories, respectively.

The system must be restarted for the change to take effect.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.36 WN11-00-000170 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Server Message Block (SMB) v1 protocol must be disabled on the SMB client.

```
GROUP ID: V-253288
RULE ID: SV-253288r958478
```

Rationale:

SMBv1 is a legacy protocol that uses the MD5 algorithm as part of SMB. MD5 is known to be vulnerable to a number of attacks such as collision and preimage attacks as well as not being FIPS compliant.

Disabling SMBv1 support may prevent access to file or print sharing resources with systems or devices that only support SMBv1. File shares and print services hosted on Windows Server 2003 are an example, however Windows Server 2003 is no longer a supported operating system. Some older network attached devices may only support SMBv1.

Audit:

Different methods are available to disable SMBv1 on Windows 11, if WN11-00-000160is configured, this is NA.

If the following registry value is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\mrxsmb10\

Value Name: Start

Type: REG_DWORD
Value: 0x00000004 (4)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MS Security Guide >>
"Configure SMBv1 client driver"
```

to "Enabled" with "Disable driver (recommended)" selected for "Configure MrxSmb10 driver".

This policy setting requires the installation of the SecGuide custom templates included with the STIG package. "SecGuide.admx" and "SecGuide.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories, respectively.

The system must be restarted for the changes to take effect.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.37 WN11-00-000175 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Secondary Logon service must be disabled on Windows 11.

```
GROUP ID: V-253289
RULE ID: SV-253289r958478
```

Rationale:

The Secondary Logon service provides a means for entering alternate credentials, typically used to run commands with elevated privileges. Using privileged credentials in a standard user session can expose those credentials to theft.

Audit:

Run "Services.msc".

Locate the "Secondary Logon" service.

If the "Startup Type" is not "Disabled" or the "Status" is "Running", this is a finding.

Remediation:

Configure the "Secondary Logon" service "Startup Type" to "Disabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.38 WN11-00-000190 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Orphaned security identifiers (SIDs) must be removed from user rights on Windows 11.

```
GROUP ID: V-253290
RULE ID: SV-253290r991589
```

Rationale:

Accounts or groups given rights on a system may show up as unresolved SIDs for various reasons including deletion of the accounts or groups. If the account or group objects are reanimated, there is a potential they may still have rights no longer intended. Valid domain accounts or groups may also show up as unresolved SIDs if a connection to the domain cannot be established for some reason.

Audit:

Review the effective User Rights setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

Review each User Right listed for any unresolved SIDs to determine whether they are valid, such as due to being temporarily disconnected from the domain. (Unresolved SIDs have the format of "*S-1-..".)

If any unresolved SIDs exist and are not for currently valid accounts or groups, this is a finding.

Remediation:

Remove any unresolved SIDs found in User Rights assignments and determined to not be for currently valid accounts or groups by removing the accounts or groups from the appropriate group policy.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.39 WN11-00-000210 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Bluetooth must be turned off unless approved by the organization.

```
GROUP ID: V-253291
RULE ID: SV-253291r958478
```

Rationale:

If not configured properly, Bluetooth may allow rogue devices to communicate with a system. If a rogue device is paired with a system, there is potential for sensitive information to be compromised.

Audit:

This is NA if the system does not have Bluetooth.

Verify the Bluetooth radio is turned off unless approved by the organization. If it is not, this is a finding.

Approval must be documented with the ISSO.

Remediation:

Turn off Bluetooth radios not organizationally approved. Establish an organizational policy for the use of Bluetooth.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.40 WN11-00-000220 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Bluetooth must be turned off when not in use.

```
GROUP ID: V-253292
RULE ID: SV-253292r958478
```

Rationale:

If not configured properly, Bluetooth may allow rogue devices to communicate with a system. If a rogue device is paired with a system, there is potential for sensitive information to be compromised.

Audit:

This is NA if the system does not have Bluetooth.

Verify the organization has a policy to turn off Bluetooth when not in use and personnel are trained. If it does not, this is a finding.

Remediation:

Turn off Bluetooth radios when not in use. Establish an organizational policy for the use of Bluetooth to include training of personnel.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.41 WN11-00-000230 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must notify the user when a Bluetooth device attempts to connect.

```
GROUP ID: V-253293
RULE ID: SV-253293r991589
```

Rationale:

If not configured properly, Bluetooth may allow rogue devices to communicate with a system. If a rogue device is paired with a system, there is potential for sensitive information to be compromised.

Audit:

This is NA if the system does not have Bluetooth, or if Bluetooth is turned off per the organizations policy.

Search for "Bluetooth".

View Bluetooth Settings.

Select "More Bluetooth Options"

If "Alert me when a new Bluetooth device wants to connect" is not checked, this is a finding.

Remediation:

Configure Bluetooth to notify users if devices attempt to connect.

View Bluetooth Settings.

Ensure "Alert me when a new Bluetooth device wants to connect" is checked.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.42 WN11-00-000240 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Administrative accounts must not be used with applications that access the internet, such as web browsers, or with potential internet sources, such as email.

```
GROUP ID: V-253294
RULE ID: SV-253294r991589
```

Rationale:

Using applications that access the internet or have potential internet sources using administrative privileges exposes a system to compromise. If a flaw in an application is exploited while running as a privileged user, the entire system could be compromised. Web browsers and email are common attack vectors for introducing malicious code and must not be run with an administrative account.

Since administrative accounts may generally change or work around technical restrictions for running a web browser or other applications, it is essential that policy requires administrative accounts to not access the internet or use applications, such as email.

The policy must define specific exceptions for local service administration. These exceptions may include HTTP(S)-based tools that are used for the administration of the local system, services, or attached devices.

Technical means such as application allowlisting can be used to enforce the policy to ensure compliance.

Audit:

Determine whether administrative accounts are prevented from using applications that access the internet, such as web browsers, or with potential internet sources, such as email, except as necessary for local service administration.

The organization must have a policy that prohibits administrative accounts from using applications that access the internet, such as web browsers, or with potential internet sources, such as email, except as necessary for local service administration. The policy must define specific exceptions for local service administration. These exceptions may include HTTP(S)-based tools that are used for the administration of the local system, services, or attached devices.

Technical measures such as the removal of applications or application allowlisting must be used where feasible to prevent the use of applications that access the internet.

If accounts with administrative privileges are not prevented from using applications that access the internet or with potential internet sources, this is a finding.

Remediation:

Establish and enforce a policy that prohibits administrative accounts from using applications that access the internet, such as web browsers, or with potential internet sources, such as email. Define specific exceptions for local service administration. These exceptions may include HTTP(S)-based tools that are used for the administration of the local system, services, or attached devices.

Implement technical measures where feasible such as removal of applications or use of application allowlisting to restrict the use of applications that can access the internet.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.43 WN11-00-000250 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 nonpersistent VM sessions must not exceed 24 hours.

```
GROUP ID: V-253295
RULE ID: SV-253295r958552
```

Rationale:

For virtual desktop implementations (VDIs) where the virtual desktop instance is deleted or refreshed upon logoff, the organization must enforce that sessions be terminated within 24 hours. This would ensure any data stored on the VM that is not encrypted or covered by Credential Guard is deleted.

Audit:

Verify there is a documented policy or procedure in place that nonpersistent VM sessions do not exceed 24 hours.

If the system is NOT a nonpersistent VM, this is Not Applicable.

For Azure Virtual Desktop (AVD) implementations with no data at rest, this is Not Applicable.

If there is no such documented policy or procedure in place, this is a finding.

Remediation:

Set nonpersistent VM sessions to not exceed 24 hours.

Additional Information:

CCI-001199 Protects the confidentiality and/or integrity of organization-defined information at rest.

- NIST SP 800-53::SC-28
- NIST SP 800-53 Revision 4::SC-28
- NIST SP 800-53 Revision 5::SC-28
- NIST SP 800-53A::SC-28.1

1.44 WN11-00-000260 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The Windows 11 time service must synchronize with an appropriate DOD time source.

```
GROUP ID: V-253296
RULE ID: SV-253296r1051041
```

Rationale:

The Windows Time Service controls time synchronization settings. Time synchronization is essential for authentication and auditing purposes. If the Windows Time Service is used, it must synchronize with a secure, authorized time source. Domain-joined systems are automatically configured to synchronize with domain controllers. If an NTP server is configured, it must synchronize with a secure, authorized time source.

Audit:

Review the Windows time service configuration.

Open an elevated "Command Prompt" (run as administrator).

Enter

```
"W32tm /query /configuration".
```

Domain-joined systems (excluding the domain controller with the PDC emulator role):

If the value for "Type" under "NTP Client" is not "NT5DS", this is a finding.

Remediation:

Configure the system to synchronize time with an appropriate DOD time source.

Domain-joined systems use NT5DS to synchronize time from other systems in the domain by default.

If the system needs to be configured to an NTP server, configure the system to point to an authorized time server by setting the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Windows Time
Service >> Time Providers >> "Configure Windows NTP Client"
```

to "Enabled", and configure the "NtpServer" field to point to an appropriate DOD time server.

The US Naval Observatory operates stratum 1 time servers, identified at https://www.cnmoc.usff.navy.mil/Our-Commands/United-States-Naval-Observatory/Precise-Time-Department/Network-Time-Protocol-NTP/. Time synchronization will occur through a hierarchy of time servers down to the local level. Clients and lower-level servers will synchronize with an authorized time server in the hierarchy.

Additional Information:

CCI-004923 Compare the internal system clocks on an organization-defined frequency with organization-defined authoritative time source.

- NIST SP 800-53 Revision 5::SC-45 (1) (a)

CCI-001891 The information system compares internal information system clocks on an organization-defined frequency with an organization-defined authoritative time source.

- NIST SP 800-53 Revision 4::AU-8 (1) (a)

1.45 WN11-00-000395 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must not have portproxy enabled or in use.

```
GROUP ID: V-257592
RULE ID: SV-257592r991589
```

Rationale:

Having portproxy enabled or configured in Windows 10 could allow a man-in-the-middle attack.

Audit:

Check the registry key for existence of proxied ports:

HKLM\SYSTEM\CurrentControlSet\Services\PortProxy.

If the key contains v4tov4\tcp\ or is populated v4tov4\tcp, this is a finding.

Run "netsh interface portproxy show all".

If the command displays any results, this is a finding.

Remediation:

Contact the Administrator to run "netsh interface portproxy delete" with elevation. Remove any enabled portproxies that may be configured.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.46 WN11-AC-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 account lockout duration must be configured to 15 minutes or greater.

```
GROUP ID: V-253297
RULE ID: SV-253297r958736
```

Rationale:

The account lockout feature, when enabled, prevents brute-force password attacks on the system. This parameter specifies the amount of time that an account will remain locked after the specified number of failed logon attempts.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Account Lockout Policy.
```

If the "Account lockout duration" is less than "15" minutes (excluding "0"), this is a finding.

Configuring this to "0", requiring an administrator to unlock the account, is more restrictive and is not a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Account Lockout Policy >> "Account lockout duration"
```

to "15" minutes or greater.

A value of "0" is also acceptable, requiring an administrator to unlock the account.

Additional Information:

CCI-002238 Automatically lock the account or node for either an organization-defined time period, until the locked account or node is released by an administrator, or delays the next logon prompt according to the organization-defined delay algorithm when the maximum number of unsuccessful logon attempts is exceeded.

- NIST SP 800-53 Revision 4::AC-7 b
- NIST SP 800-53 Revision 5::AC-7 b

1.47 WN11-AC-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The number of allowed bad logon attempts must be configured to three or less.

```
GROUP ID: V-253298
RULE ID: SV-253298r958388
```

Rationale:

The account lockout feature, when enabled, prevents brute-force password attacks on the system. The higher this value is, the less effective the account lockout feature will be in protecting the local system. The number of bad logon attempts must be reasonably small to minimize the possibility of a successful password attack, while allowing for honest errors made during a normal user logon.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Account Lockout Policy.
```

If the "Account lockout threshold" is "0" or more than "3" attempts, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Account Lockout Policy >> "Account lockout threshold"
```

to "3" or less invalid logon attempts (excluding "0" which is unacceptable).

Additional Information:

CCI-000044 Enforce the organization-defined limit of consecutive invalid logon attempts by a user during the organization-defined time period.

- NIST SP 800-53::AC-7 a
- NIST SP 800-53 Revision 4::AC-7 a
- NIST SP 800-53 Revision 5::AC-7 a
- NIST SP 800-53A::AC-7.1 (ii)

1.48 WN11-AC-000015 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The period of time before the bad logon counter is reset must be configured to 15 minutes.

```
GROUP ID: V-253299
RULE ID: SV-253299r958388
```

Rationale:

The account lockout feature, when enabled, prevents brute-force password attacks on the system. This parameter specifies the period of time that must pass after failed logon attempts before the counter is reset to 0. The smaller this value is, the less effective the account lockout feature will be in protecting the local system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Account Lockout Policy.
```

If the "Reset account lockout counter after" value is less than "15" minutes, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Account Lockout Policy >> "Reset account lockout counter after"
```

to "15" minutes.

Additional Information:

CCI-000044 Enforce the organization-defined limit of consecutive invalid logon attempts by a user during the organization-defined time period.

- NIST SP 800-53::AC-7 a
- NIST SP 800-53 Revision 4::AC-7 a
- NIST SP 800-53 Revision 5::AC-7 a
- NIST SP 800-53A::AC-7.1 (ii)

1.49 WN11-AC-000020 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The password history must be configured to 24 passwords remembered.

```
GROUP ID: V-253300
RULE ID: SV-253300r1000103
```

Rationale:

A system is more vulnerable to unauthorized access when system users recycle the same password several times without being required to change a password to a unique password on a regularly scheduled basis. This enables users to effectively negate the purpose of mandating periodic password changes. The default value is 24 for Windows domain systems. DOD has decided this is the appropriate value for all Windows systems.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy.
```

If the value for "Enforce password history" is less than "24" passwords remembered, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy >> "Enforce password history"
```

to "24" passwords remembered.

Additional Information:

CCI-004061 For password-based authentication, verify when users create or update passwords, that the passwords are not found on the list of commonly-used, expected, or compromised passwords in IA-5 (1) (a).

- NIST SP 800-53 Revision 5::IA-5 (1) (b)

1.50 WN11-AC-000025 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The maximum password age must be configured to 60 days or less.

```
GROUP ID: V-253301
RULE ID: SV-253301r1051042
```

Rationale:

The longer a password is in use, the greater the opportunity for someone to gain unauthorized knowledge of the passwords. Scheduled changing of passwords hinders the ability of unauthorized system users to crack passwords and gain access to a system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy.
```

If the value for the "Maximum password age" is greater than "60" days, this is a finding. If the value is set to "0" (never expires), this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy >> "Maximum Password Age"
```

to "60" days or less (excluding "0" which is unacceptable).

Additional Information:

CCI-004066 For password-based authentication, enforce organization-defined composition and complexity rules.

- NIST SP 800-53 Revision 5::IA-5 (1) (h)

CCI-000199 The information system enforces maximum password lifetime restrictions.

- NIST SP 800-53::IA-5 (1) (d)
- NIST SP 800-53 Revision 4::IA-5 (1) (d)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.51 WN11-AC-000030 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The minimum password age must be configured to at least 1 day.

```
GROUP ID: V-253302
RULE ID: SV-253302r1051043
```

Rationale:

Permitting passwords to be changed in immediate succession within the same day allows users to cycle passwords through their history database. This enables users to effectively negate the purpose of mandating periodic password changes.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy.
```

If the value for the "Minimum password age" is less than "1" day, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy >> "Minimum Password Age"
```

to at least "1" day.

Additional Information:

CCI-004066 For password-based authentication, enforce organization-defined composition and complexity rules.

- NIST SP 800-53 Revision 5::IA-5 (1) (h)

CCI-000198 The information system enforces minimum password lifetime restrictions.

- NIST SP 800-53::IA-5 (1) (d)
- NIST SP 800-53 Revision 4::IA-5 (1) (d)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.52 WN11-AC-000035 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Passwords must, at a minimum, be 14 characters.

```
GROUP ID: V-253303
RULE ID: SV-253303r1051044
```

Rationale:

Information systems not protected with strong password schemes (including passwords of minimum length) provide the opportunity for anyone to crack the password, thus gaining access to the system and compromising the device, information, or the local network.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy.
```

If the value for the "Minimum password length," is less than "14" characters, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy >> "Minimum password length"
```

to "14" characters.

Additional Information:

CCI-004066 For password-based authentication, enforce organization-defined composition and complexity rules.

- NIST SP 800-53 Revision 5::IA-5 (1) (h)

CCI-000205 The information system enforces minimum password length.

- NIST SP 800-53::IA-5 (1) (a)
- NIST SP 800-53 Revision 4::IA-5 (1) (a)
- NIST SP 800-53A::IA-5 (1).1 (i)

1.53 WN11-AC-000040 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The built-in Microsoft password complexity filter must be enabled.

```
GROUP ID: V-253304
RULE ID: SV-253304r1051045
```

Rationale:

The use of complex passwords increases their strength against guessing and brute-force attacks. This setting configures the system to verify that newly created passwords conform to the Windows password complexity policy.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy.
```

If the value for "Password must meet complexity requirements" is not set to "Enabled", this is a finding.

If the site is using a password filter that requires this setting be set to "Disabled" for the filter to be used, this would not be considered a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy >> "Password must meet complexity requirements"
```

to "Enabled".

Additional Information:

CCI-004066 For password-based authentication, enforce organization-defined composition and complexity rules.

- NIST SP 800-53 Revision 5::IA-5 (1) (h)

CCI-000192 The information system enforces password complexity by the minimum number of upper case characters used.

- NIST SP 800-53::IA-5 (1) (a)
- NIST SP 800-53 Revision 4::IA-5 (1) (a)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.54 WN11-AC-000045 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Reversible password encryption must be disabled.

```
GROUP ID: V-253305
RULE ID: SV-253305r1051046
```

Rationale:

Storing passwords using reversible encryption is essentially the same as storing clear-text versions of the passwords. For this reason, this policy must never be enabled.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy.
```

If the value for "Store password using reversible encryption" is not set to "Disabled", this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Account
Policies >> Password Policy >> "Store passwords using reversible encryption"
```

to "Disabled".

Additional Information:

CCI-004062 For password-based authentication, store passwords using an approved salted key derivation function, preferably using a keyed hash.

- NIST SP 800-53 Revision 5::IA-5 (1) (d)

CCI-000196 The information system, for password-based authentication, stores only cryptographically-protected passwords.

- NIST SP 800-53::IA-5 (1) (c)
- NIST SP 800-53 Revision 4::IA-5 (1) (c)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.55 WN11-AU-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Account Logon - Credential Validation failures.

```
GROUP ID: V-253306
RULE ID: SV-253306r991570
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Credential validation records events related to validation tests on credentials for a user account logon.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Account Logon >> Credential Validation - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Account Logon >>
"Audit Credential Validation"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.56 WN11-AU-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Account Logon - Credential Validation successes.

```
GROUP ID: V-253307
RULE ID: SV-253307r991570
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Credential validation records events related to validation tests on credentials for a user account logon.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Account Logon >> Credential Validation - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Account Logon >>
"Audit Credential Validation"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.57 WN11-AU-000030 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Account Management - Security Group Management successes.

```
GROUP ID: V-253308
RULE ID: SV-253308r971541
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Security Group Management records events such as creating, deleting or changing of security groups, including changes in group members.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Account Management >> Security Group Management - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Account Management >>
"Audit Security Group Management"
```

with "Success" selected.

Additional Information:

CCI-001914 Provide the capability for organization-defined individuals or roles to change the logging to be performed on organization-defined system components based on organization-defined selectable event criteria within organization-defined time thresholds.

- NIST SP 800-53 Revision 4::AU-12 (3)
- NIST SP 800-53 Revision 5::AU-12 (3)

1.58 WN11-AU-000035 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Account Management - User Account Management failures.

```
GROUP ID: V-253309
RULE ID: SV-253309r958566
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

User Account Management records events such as creating, changing, deleting, renaming, disabling, or enabling user accounts.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Account Management >> User Account Management - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Account Management >>
"Audit User Account Management"
```

with "Failure" selected.

Additional Information:

CCI-001314 Reveal error messages only to organization-defined personnel or roles.

- NIST SP 800-53::SI-11 c
- NIST SP 800-53 Revision 4::SI-11 b
- NIST SP 800-53 Revision 5::SI-11 b
- NIST SP 800-53A::SI-11.1 (iv)

1.59 WN11-AU-000040 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Account Management - User Account Management successes.

```
GROUP ID: V-253310
RULE ID: SV-253310r991551
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

User Account Management records events such as creating, changing, deleting, renaming, disabling, or enabling user accounts.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Account Management >> User Account Management - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Account Management >>
"Audit User Account Management"
```

with "Success" selected.

Additional Information:

CCI-001403 Automatically audit account modification actions.

- NIST SP 800-53::AC-2 (4)
- NIST SP 800-53 Revision 4::AC-2 (4)
- NIST SP 800-53 Revision 5::AC-2 (4)
- NIST SP 800-53A::AC-2 (4).1 (i and ii)

1.60 WN11-AU-000045 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Detailed Tracking - PNP Activity successes.

```
GROUP ID: V-253311
RULE ID: SV-253311r1051047
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Plug and Play activity records events related to the successful connection of external devices.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Detailed Tracking >> Plug and Play Events - Success

Remediation:

```
Computer Configuration >> Windows Settings >> Advanced Audit Policy
Configuration >> System Audit Policies >> Detailed Tracking >> "Audit PNP
Activity"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

CCI-003938 Automatically generate audit records of the enforcement actions.

- NIST SP 800-53 Revision 5::CM-5 (1) (b)

CCI-001814 The Information system supports auditing of the enforcement actions.

- NIST SP 800-53 Revision 4::CM-5 (1)

1.61 WN11-AU-000050 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Detailed Tracking - Process Creation successes.

```
GROUP ID: V-253312
RULE ID: SV-253312r1051048
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Process creation records events related to the creation of a process and the source.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Detailed Tracking >> Process Creation - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Detailed Tracking >>
"Audit Process Creation"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

CCI-003938 Automatically generate audit records of the enforcement actions.

- NIST SP 800-53 Revision 5::CM-5 (1) (b)

CCI-001814 The Information system supports auditing of the enforcement actions.

- NIST SP 800-53 Revision 4::CM-5 (1)

1.62 WN11-AU-000054 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Logon/Logoff - Account Lockout failures.

```
GROUP ID: V-253313
RULE ID: SV-253313r991578
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Account Lockout events can be used to identify potentially malicious logon attempts.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Account Lockout - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Account Lockout"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.63 WN11-AU-000060 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Logon/Logoff - Group Membership successes.

```
GROUP ID: V-253314
RULE ID: SV-253314r991570
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Group Membership records information related to the group membership of a user's logon token.

Audit:

Security Option "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Group Membership - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Advanced Audit Policy
Configuration >> System Audit Policies >> Logon/Logoff >> "Audit Group
Membership"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.64 WN11-AU-000065 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Logon/Logoff - Logoff successes.

```
GROUP ID: V-253315
RULE ID: SV-253315r958406
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Logoff records user logoffs. If this is an interactive logoff, it is recorded on the local system. If it is to a network share, it is recorded on the system accessed.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Logoff - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Logoff"
```

with "Success" selected.

Additional Information:

CCI-000067 Employ automated mechanisms to monitor remote access methods.

- NIST SP 800-53::AC-17 (1)
- NIST SP 800-53 Revision 4::AC-17 (1)
- NIST SP 800-53 Revision 5::AC-17 (1)
- NIST SP 800-53A::AC-17 (1).1

1.65 WN11-AU-000070 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Logon/Logoff - Logon failures.

```
GROUP ID: V-253316
RULE ID: SV-253316r991581
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Logon records user logons. If this is an interactive logon, it is recorded on the local system. If it is to a network share, it is recorded on the system accessed.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Logon - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Logon"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.66 WN11-AU-000080 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Logon/Logoff - Special Logon successes.

```
GROUP ID: V-253318
RULE ID: SV-253318r991578
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Special Logon records special logons which have administrative privileges and can be used to elevate processes.

Audit:

Security Option "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Special Logon - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Special Logon"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.67 WN11-AU-000075 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Logon/Logoff - Logon successes.

```
GROUP ID: V-253317
RULE ID: SV-253317r991581
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Logon records user logons. If this is an interactive logon, it is recorded on the local system. If it is to a network share, it is recorded on the system accessed.

Audit:

Security Option "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Logon - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Logon"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.68 WN11-AU-000081 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Object Access - File Share failures.

```
GROUP ID: V-253319
RULE ID: SV-253319r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Auditing file shares records events related to connection to shares on a system including system shares such as C$.

Audit:

Security Option "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open PowerShell or a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following:

Object Access >> File Share - Failure

If the system does not audit the above, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >>
"Audit File Share"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.69 WN11-AU-000082 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Object Access - File Share successes.

```
GROUP ID: V-253320
RULE ID: SV-253320r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Auditing file shares records events related to connection to shares on a system including system shares such as C$.

Audit:

Security Option "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open PowerShell or a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following:

Object Access >> File Share - Success

If the system does not audit the above, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >>
"Audit File Share"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.70 WN11-AU-000083 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Object Access - Other Object Access Events successes.

```
GROUP ID: V-253321
RULE ID: SV-253321r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Auditing for other object access records events related to the management of task scheduler jobs and COM+ objects.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open PowerShell or a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following:

Object Access >> Other Object Access Events - Success

If the system does not audit the above, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >>
"Audit Other Object Access Events"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.71 WN11-AU-000084 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Object Access - Other Object Access Events failures.

```
GROUP ID: V-253322
RULE ID: SV-253322r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Auditing for other object access records events related to the management of task scheduler jobs and COM+ objects.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open PowerShell or a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following:

Object Access >> Other Object Access Events - Failure

If the system does not audit the above, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >>
"Audit Other Object Access Events"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.72 WN11-AU-000085 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Object Access - Removable Storage failures.

```
GROUP ID: V-253323
RULE ID: SV-253323r991583
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Auditing object access for removable media records events related to access attempts on file system objects on removable storage devices.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Object Access >> Removable Storage - Failure

Some virtual machines may generate excessive audit events for access to the virtual hard disk itself when this setting is enabled. This may be set to Not Configured in such cases and would not be a finding. This must be documented with the ISSO to include mitigations such as monitoring or restricting any actual removable storage connected to the VM.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >>
"Audit Removable Storage"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.73 WN11-AU-000090 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Object Access - Removable Storage successes.

```
GROUP ID: V-253324
RULE ID: SV-253324r991583
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Auditing object access for removable media records events related to access attempts on file system objects on removable storage devices.

Audit:

Security Option "Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Object Access >> Removable Storage - Success

Some virtual machines may generate excessive audit events for access to the virtual hard disk itself when this setting is enabled. This may be set to Not Configured in such cases and would not be a finding. This must be documented with the ISSO to include mitigations such as monitoring or restricting any actual removable storage connected to the VM.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >>
"Audit Removable Storage"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.74 WN11-AU-000100 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Policy Change - Audit Policy Change successes.

```
GROUP ID: V-253325
RULE ID: SV-253325r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Policy Change records events related to changes in audit policy.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Policy Change >> Audit Policy Change - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change >>
"Audit Policy Change"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.75 WN11-AU-000105 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Policy Change - Authentication Policy Change successes.

```
GROUP ID: V-253326
RULE ID: SV-253326r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Authentication Policy Change records events related to changes in authentication policy including Kerberos policy and Trust changes.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Policy Change >> Authentication Policy Change - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change >>
"Audit Authentication Policy Change"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.76 WN11-AU-000107 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Policy Change - Authorization Policy Change successes.

```
GROUP ID: V-253327
RULE ID: SV-253327r991572
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Authorization Policy Change records events related to changes in user rights, such as create a token object.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

-Open a Command Prompt with elevated privileges ("Run as Administrator").

-Enter "AuditPol /get /category:*".

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding.

Policy Change >> Authorization Policy Change - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change >>
"Audit Authorization Policy Change"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.77 WN11-AU-000110 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Privilege Use - Sensitive Privilege Use failures.

```
GROUP ID: V-253328
RULE ID: SV-253328r958732
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Sensitive Privilege Use records events related to use of sensitive privileges, such as "Act as part of the operating system" or "Debug programs".

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Privilege Use >> Sensitive Privilege Use - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Privilege Use >>
"Audit Sensitive Privilege Use"
```

with "Failure" selected.

Additional Information:

CCI-002234 Log the execution of privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (9)
- NIST SP 800-53 Revision 5::AC-6 (9)

1.78 WN11-AU-000115 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit Privilege Use - Sensitive Privilege Use successes.

```
GROUP ID: V-253329
RULE ID: SV-253329r991575
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Sensitive Privilege Use records events related to use of sensitive privileges, such as "Act as part of the operating system" or "Debug programs".

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Privilege Use >> Sensitive Privilege Use - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Privilege Use >>
"Audit Sensitive Privilege Use"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.79 WN11-AU-000120 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - IPsec Driver failures.

```
GROUP ID: V-253330
RULE ID: SV-253330r991586
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

IPsec Driver records events related to the IPsec Driver such as dropped packets.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> IPsec Driver - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit IPsec
Driver"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.80 WN11-AU-000130 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - Other System Events successes.

```
GROUP ID: V-253331
RULE ID: SV-253331r991579
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Other System Events records information related to cryptographic key operations and the Windows Firewall service.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> Other System Events - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit Other
System Events"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.81 WN11-AU-000135 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - Other System Events failures.

```
GROUP ID: V-253332
RULE ID: SV-253332r991579
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Other System Events records information related to cryptographic key operations and the Windows Firewall service.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*"
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> Other System Events - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit Other
System Events"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.82 WN11-AU-000140 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - Security State Change successes.

```
GROUP ID: V-253333
RULE ID: SV-253333r991575
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Security State Change records events related to changes in the security state, such as startup and shutdown of the system.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> Security State Change - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit
Security State Change"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.83 WN11-AU-000150 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - Security System Extension successes.

```
GROUP ID: V-253334
RULE ID: SV-253334r991575
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Security System Extension records events related to extension code being loaded by the security subsystem.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> Security System Extension - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit
Security System Extension"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.84 WN11-AU-000155 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - System Integrity failures.

```
GROUP ID: V-253335
RULE ID: SV-253335r991573
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

System Integrity records events related to violations of integrity to the security subsystem.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> System Integrity - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit
System Integrity"
```

with "Failure" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.85 WN11-AU-000160 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to audit System - System Integrity successes.

```
GROUP ID: V-253336
RULE ID: SV-253336r991573
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

System Integrity records events related to violations of integrity to the security subsystem.

Audit:

Security Option "Audit: Force audit policy subcategory settings to override audit policy category settings" must be set to "Enabled" (WN11-SO-000030) for the detailed auditing subcategories to be effective.

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

System >> System Integrity - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> System >> "Audit
System Integrity"
```

with "Success" selected.

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.86 WN11-AU-000500 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Application event log size must be configured to 32768 KB or greater.

```
GROUP ID: V-253337
RULE ID: SV-253337r958752
```

Rationale:

Inadequate log size will cause the log to fill up quickly. This may prevent audit events from being recorded properly and require frequent attention by administrative personnel.

Audit:

If the system is configured to send audit records directly to an audit server, this is NA. This must be documented with the ISSO.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\EventLog\Application\

Value Name: MaxSize

Value Type: REG_DWORD
Value: 0x00008000 (32768) (or greater)
```

Remediation:

If the system is configured to send audit records directly to an audit server, this is NA. This must be documented with the ISSO.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Event Log Service >> Application >> "Specify the maximum log file size (KB)"
```

to "Enabled" with a "Maximum Log Size (KB)" of "32768" or greater.

Additional Information:

CCI-001849 Allocate audit log storage capacity to accommodate organization-defined audit record retention requirements.

- NIST SP 800-53 Revision 4::AU-4
- NIST SP 800-53 Revision 5::AU-4

1.87 WN11-AU-000505 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Security event log size must be configured to 1024000 KB or greater.

```
GROUP ID: V-253338
RULE ID: SV-253338r958752
```

Rationale:

Inadequate log size will cause the log to fill up quickly. This may prevent audit events from being recorded properly and require frequent attention by administrative personnel.

Audit:

If the system is configured to send audit records directly to an audit server, this is NA. This must be documented with the ISSO.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\EventLog\Security\

Value Name: MaxSize

Value Type: REG_DWORD
Value: 0x000fa000 (1024000) (or greater)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Event Log Service >> Security >> "Specify the maximum log file size (KB)"
```

to "Enabled" with a "Maximum Log Size (KB)" of "1024000" or greater.

If the system is configured to send audit records directly to an audit server, this must be documented with the ISSO.

Additional Information:

CCI-001849 Allocate audit log storage capacity to accommodate organization-defined audit record retention requirements.

- NIST SP 800-53 Revision 4::AU-4
- NIST SP 800-53 Revision 5::AU-4

1.88 WN11-AU-000510 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The System event log size must be configured to 32768 KB or greater.

```
GROUP ID: V-253339
RULE ID: SV-253339r958752
```

Rationale:

Inadequate log size will cause the log to fill up quickly. This may prevent audit events from being recorded properly and require frequent attention by administrative personnel.

Audit:

If the system is configured to send audit records directly to an audit server, this is NA. This must be documented with the ISSO.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\EventLog\System\

Value Name: MaxSize

Value Type: REG_DWORD
Value: 0x00008000 (32768) (or greater)
```

Remediation:

If the system is configured to send audit records directly to an audit server, this is NA. This must be documented with the ISSO.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Event Log Service >> System >> "Specify the maximum log file size (KB)"
```

to "Enabled" with a "Maximum Log Size (KB)" of "32768" or greater.

Additional Information:

CCI-001849 Allocate audit log storage capacity to accommodate organization-defined audit record retention requirements.

- NIST SP 800-53 Revision 4::AU-4
- NIST SP 800-53 Revision 5::AU-4

1.89 WN11-AU-000515 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 permissions for the Application event log must prevent access by non-privileged accounts.

```
GROUP ID: V-253340
RULE ID: SV-253340r958434
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. The Application event log may be susceptible to tampering if proper permissions are not applied.

Audit:

Verify the permissions on the Application event log (Application.evtx). Standard user accounts or groups must not have access. The default permissions listed below satisfy this requirement.

Eventlog - Full Control

SYSTEM - Full Control

Administrators - Full Control

The default location is the "%SystemRoot%\SYSTEM32\WINEVT\LOGS" directory. They may have been moved to another folder.

If the permissions for these files are not as restrictive as the ACLs listed, this is a finding.

Note: If "APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES" has Special Permissions, this would not be a finding.

Remediation:

Ensure the permissions on the Application event log (Application.evtx) are configured to prevent standard user accounts or groups from having access. The default permissions listed below satisfy this requirement.

Eventlog - Full Control

SYSTEM - Full Control

Administrators - Full Control

The default location is the "%SystemRoot%\SYSTEM32\WINEVT\LOGS" directory.

If the location of the logs has been changed, when adding Eventlog to the permissions, it must be entered as "NT Service\Eventlog".

Additional Information:

CCI-000162 Protect audit information from unauthorized access.

- NIST SP 800-53::AU-9
- NIST SP 800-53 Revision 4::AU-9
- NIST SP 800-53 Revision 5::AU-9 a
- NIST SP 800-53A::AU-9.1

1.90 WN11-AU-000520 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 permissions for the Security event log must prevent access by non-privileged accounts.

```
GROUP ID: V-253341
RULE ID: SV-253341r958434
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. The Security event log may disclose sensitive information or be susceptible to tampering if proper permissions are not applied.

Audit:

Verify the permissions on the Security event log (Security.evtx). Standard user accounts or groups must not have access. The default permissions listed below satisfy this requirement.

Eventlog - Full Control

SYSTEM - Full Control

Administrators - Full Control

The default location is the "%SystemRoot%\SYSTEM32\WINEVT\LOGS" directory. They may have been moved to another folder.

If the permissions for these files are not as restrictive as the ACLs listed, this is a finding.

Note: If "APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES" has Special Permissions, this would not be a finding.

Remediation:

Ensure the permissions on the Security event log (Security.evtx) are configured to prevent standard user accounts or groups from having access. The default permissions listed below satisfy this requirement.

Eventlog - Full Control

SYSTEM - Full Control

Administrators - Full Control

The default location is the "%SystemRoot%\SYSTEM32\WINEVT\LOGS" directory.

If the location of the logs has been changed, when adding Eventlog to the permissions, it must be entered as "NT Service\Eventlog".

Additional Information:

CCI-000162 Protect audit information from unauthorized access.

- NIST SP 800-53::AU-9
- NIST SP 800-53 Revision 4::AU-9
- NIST SP 800-53 Revision 5::AU-9 a
- NIST SP 800-53A::AU-9.1

1.91 WN11-AU-000525 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 permissions for the System event log must prevent access by non-privileged accounts.

```
GROUP ID: V-253342
RULE ID: SV-253342r958434
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. The System event log may be susceptible to tampering if proper permissions are not applied.

Audit:

Verify the permissions on the System event log (System.evtx). Standard user accounts or groups must not have access. The default permissions listed below satisfy this requirement.

Eventlog - Full Control

SYSTEM - Full Control

Administrators - Full Control

The default location is the "%SystemRoot%\SYSTEM32\WINEVT\LOGS" directory. They may have been moved to another folder.

If the permissions for these files are not as restrictive as the ACLs listed, this is a finding.

Note: If "APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES" has Special Permissions, this would not be a finding.

Remediation:

Ensure the permissions on the System event log (System.evtx) are configured to prevent standard user accounts or groups from having access. The default permissions listed below satisfy this requirement.

Eventlog - Full Control

SYSTEM - Full Control

Administrators - Full Control

The default location is the "%SystemRoot%\SYSTEM32\WINEVT\LOGS" directory.

If the location of the logs has been changed, when adding Eventlog to the permissions, it must be entered as "NT Service\Eventlog".

Additional Information:

CCI-000162 Protect audit information from unauthorized access.

- NIST SP 800-53::AU-9
- NIST SP 800-53 Revision 4::AU-9
- NIST SP 800-53 Revision 5::AU-9 a
- NIST SP 800-53A::AU-9.1

1.92 WN11-AU-000550 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Other Policy Change Events Successes.

```
GROUP ID: V-253343
RULE ID: SV-253343r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Other Policy Change Events contains events about EFS Data Recovery Agent policy changes, changes in Windows Filtering Platform filter, status on Security policy settings updates for local Group Policy settings, Central Access Policy changes, and detailed troubleshooting events for Cryptographic Next Generation (CNG) operations.

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Policy Change >> Other Policy Change Events - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change>> "Audit
Other Policy Change Events"
```

with "Success" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.93 WN11-AU-000555 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Other Policy Change Events Failures.

```
GROUP ID: V-253344
RULE ID: SV-253344r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Other Policy Change Events contains events about EFS Data Recovery Agent policy changes, changes in Windows Filtering Platform filter, status on Security policy settings updates for local Group Policy settings, Central Access Policy changes, and detailed troubleshooting events for Cryptographic Next Generation (CNG) operations.

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Policy Change >> Other Policy Change Events - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change>> "Audit
Other Policy Change Events"
```

with "Failure" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.94 WN11-AU-000560 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit other Logon/Logoff Events Successes.

```
GROUP ID: V-253345
RULE ID: SV-253345r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Other Logon/Logoff Events determines whether Windows generates audit events for other logon or logoff events. Logon events are essential to understanding user activity and detecting potential attacks.

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Other Logon/Logoff Events - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Other Logon/Logoff Events"
```

with "Success" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.95 WN11-AU-000565 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit other Logon/Logoff Events Failures.

```
GROUP ID: V-253346
RULE ID: SV-253346r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Other Logon/Logoff Events determines whether Windows generates audit events for other logon or logoff events. Logon events are essential to understanding user activity and detecting potential attacks.

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Logon/Logoff >> Other Logon/Logoff Events - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Logon/Logoff >> "Audit
Other Logon/Logoff Events"
```

with "Failure" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.96 WN11-AU-000570 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit Detailed File Share Failures.

```
GROUP ID: V-253347
RULE ID: SV-253347r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit Detailed File Share allows the user to audit attempts to access files and folders on a shared folder. The Detailed File Share setting logs an event every time a file or folder is accessed, whereas the File Share setting only records one event for any connection established between a client and file share. Detailed File Share audit events include detailed information about the permissions or other criteria used to grant or deny access.

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Object Access >> Detailed File Share - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Object Access >> Audit
Detailed File Share" with "
```

Failure" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.97 WN11-AU-000575 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit MPSSVC Rule-Level Policy Change Successes.

```
GROUP ID: V-253348
RULE ID: SV-253348r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit MPSSVC Rule-Level Policy Change determines whether the operating system generates audit events when changes are made to policy rules for the Microsoft Protection Service (MPSSVC.exe).

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Policy Change >> MPSSVC Rule-Level Policy Change - Success

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change >> Audit
MPSSVC Rule-Level Policy Change" with "
```

Success" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.98 WN11-AU-000580 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to audit MPSSVC Rule-Level Policy Change Failures.

```
GROUP ID: V-253349
RULE ID: SV-253349r958412
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Audit MPSSVC Rule-Level Policy Change determines whether the operating system generates audit events when changes are made to policy rules for the Microsoft Protection Service (MPSSVC.exe).

Audit:

Use the AuditPol tool to review the current Audit Policy configuration:

Open a Command Prompt with elevated privileges ("Run as Administrator").

Enter

```
"AuditPol /get /category:*".
```

Compare the AuditPol settings with the following. If the system does not audit the following, this is a finding:

Policy Change >> MPSSVC Rule-Level Policy Change - Failure

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policies >> Policy Change >> Audit
MPSSVC Rule-Level Policy Change" with "
```

Failure" selected.

Additional Information:

CCI-000130 Ensure that audit records containing information that establishes what type of event occurred.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 a
- NIST SP 800-53A::AU-3.1

1.99 WN11-AU-000585 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must have command line process auditing events enabled for failures.

```
GROUP ID: V-257770
RULE ID: SV-257770r958412
```

Rationale:

When this policy setting is enabled, the operating system generates audit events when a process fails to start and the name of the program or user that created it.

These audit events can assist in understanding how a computer is being used and tracking user activity.

Audit:

Ensure Audit Process Creation auditing has been enabled:

```
Computer Configuration >> Windows Settings >> Security Settings >> Advanced
Audit Policy Configuration >> System Audit Policy >> Detailed Tracking >>
Audit Process Creation.
```

If "Audit Process Creation" is not set to "Failure", this is a finding.

Remediation:

Go to

```
Computer Configuration >> Windows Settings >>Security Settings>> Advanced
Audit Policy Configuration >> System Audit Policies >> Detailed Tracking >>
Set "Audit Process Creation"
```

to "Failure".

Additional Information:

CCI-002234 Log the execution of privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (9)
- NIST SP 800-53 Revision 5::AC-6 (9)

1.100 WN11-CC-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Camera access from the lock screen must be disabled.

```
GROUP ID: V-253350
RULE ID: SV-253350r958478
```

Rationale:

Enabling camera access from the lock screen could allow for unauthorized use. Requiring logon will ensure the device is only used by authorized personnel.

Audit:

If the device does not have a camera, this is NA.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Personalization\

Value Name: NoLockScreenCamera

Value Type: REG_DWORD
Value: 1
```

Remediation:

If the device does not have a camera, this is NA.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Control Panel >>
Personalization >> "Prevent enabling lock screen camera"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.101 WN11-CC-000007 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must cover or disable the built-in or attached camera when not in use.

```
GROUP ID: V-253351
RULE ID: SV-253351r958478
```

Rationale:

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Failing to disconnect from collaborative computing devices (i.e. cameras) can result in subsequent compromises of organizational information. Providing easy methods to physically disconnect from such devices after a collaborative computing session helps to ensure that participants actually carry out the disconnect activity without having to go through complex and tedious procedures.

Satisfies: SRG-OS-000095-GPOS-00049, SRG-OS-000370-GPOS-00155

Audit:

If the device or operating system does not have a camera installed, this requirement is not applicable.

This requirement is not applicable to mobile devices (smartphones and tablets), where the use of the camera is a local AO decision.

This requirement is not applicable to dedicated VTC suites located in approved VTC locations that are centrally managed.

For an external camera, if there is not a method for the operator to manually disconnect camera at the end of collaborative computing sessions, this is a finding.

For a built-in camera, the camera must be protected by a camera cover (e.g. laptop camera cover slide) when not in use. If the built-in camera is not protected with a camera cover, or if the built-in

camera is not disabled in the bios, this is a finding.

If the camera is not disconnected or covered, the following registry entry is required:

```
Registry Hive: HKEY_LOCAL_MACHINE
RegistryPath\SOFTWARE\Microsoft\Windows\CurrentVersion\CapabilityAccessManage
r\ConsentStore\webcam

Value Name: Deny
```

If "Value Name" is set to a value other than "Deny" and the collaborative computing device has not been authorized for use, this is a finding.

Remediation:

If the camera is not disconnected or covered, the following registry entry is required.

```
Registry Hive: HKEY_LOCAL_MACHINE
RegistryPath\SOFTWARE\Microsoft\Windows\CurrentVersion\CapabilityAccessManage
r\ConsentStore\webcam

Value Name: Deny
```

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.102 WN11-CC-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The display of slide shows on the lock screen must be disabled.

```
GROUP ID: V-253352
RULE ID: SV-253352r958478
```

Rationale:

Slide shows that are displayed on the lock screen could display sensitive information to unauthorized personnel. Turning off this feature will limit access to the information to a logged on user.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Personalization\

Value Name: NoLockScreenSlideshow

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Control Panel >>
Personalization >> "Prevent enabling lock screen slide show"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.103 WN11-CC-000020 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

IPv6 source routing must be configured to highest protection.

```
GROUP ID: V-253353
RULE ID: SV-253353r991589
```

Rationale:

Configuring the system to disable IPv6 source routing protects against spoofing.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Tcpip6\Parameters\

Value Name: DisableIpSourceRouting

Value Type: REG_DWORD
Value: 2
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MSS (Legacy) >> "MSS:
(DisableIPSourceRouting IPv6) IP source routing protection level (protects
against packet spoofing)"
```

to "Highest protection, source routing is completely disabled".

This policy setting requires the installation of the MSS-Legacy custom templates included with the STIG package. "MSS-Legacy.admx" and "MSS-Legacy.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.104 WN11-CC-000025 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to prevent IP source routing.

```
GROUP ID: V-253354
RULE ID: SV-253354r991589
```

Rationale:

Configuring the system to disable IP source routing protects against spoofing.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Tcpip\Parameters\

Value Name: DisableIPSourceRouting

Value Type: REG_DWORD
Value: 2
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MSS (Legacy) >> "MSS:
(DisableIPSourceRouting) IP source routing protection level (protects against
packet spoofing)"
```

to "Highest protection, source routing is completely disabled".

This policy setting requires the installation of the MSS-Legacy custom templates included with the STIG package. "MSS-Legacy.admx" and "MSS-Legacy.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.105 WN11-CC-000030 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The system must be configured to prevent Internet Control Message Protocol (ICMP) redirects from overriding Open Shortest Path First (OSPF) generated routes.

```
GROUP ID: V-253355
RULE ID: SV-253355r991589
```

Rationale:

Allowing ICMP redirect of routes can lead to traffic not being routed properly. When disabled, this forces ICMP to be routed via shortest path first.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Tcpip\Parameters\

Value Name: EnableICMPRedirect

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MSS (Legacy) >> "MSS:
(EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes"
```

to "Disabled".

This policy setting requires the installation of the MSS-Legacy custom templates included with the STIG package. "MSS-Legacy.admx" and "MSS-Legacy.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.106 WN11-CC-000035 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The system must be configured to ignore NetBIOS name release requests except from WINS servers.

```
GROUP ID: V-253356
RULE ID: SV-253356r958902
```

Rationale:

Configuring the system to ignore name release requests, except from WINS servers, prevents a denial of service (DoS) attack. The DoS consists of sending a NetBIOS name release request to the server for each entry in the server's cache, causing a response delay in the normal operation of the servers WINS resolution capability.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netbt\Parameters\

Value Name: NoNameReleaseOnDemand

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MSS (Legacy) >> "MSS:
(NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release
requests except from WINS servers"
```

to "Enabled".

This policy setting requires the installation of the MSS-Legacy custom templates included with the STIG package. "MSS-Legacy.admx" and "MSS-Legacy.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-002385 Protect against or limit the effects of organization-defined types of denial of service events.

- NIST SP 800-53 Revision 4::SC-5
- NIST SP 800-53 Revision 5::SC-5 a

1.107 WN11-CC-000037 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Local administrator accounts must have their privileged token filtered to prevent elevated privileges from being used over the network on domain systems.

```
GROUP ID: V-253357
RULE ID: SV-253357r958518
```

Rationale:

A compromised local administrator account can provide means for an attacker to move laterally between domain systems.

With User Account Control enabled, filtering the privileged token for built-in administrator accounts will prevent the elevated privileges of these accounts from being used over the network.

Audit:

If the system is not a member of a domain, this is NA.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: LocalAccountTokenFilterPolicy

Value Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MS Security Guide >>
"Apply UAC restrictions to local accounts on network logons"
```

to "Enabled".

This policy setting requires the installation of the SecGuide custom templates included with the STIG package. "SecGuide.admx" and "SecGuide.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-001084 Isolate security functions from nonsecurity functions.

- NIST SP 800-53::SC-3
- NIST SP 800-53 Revision 4::SC-3
- NIST SP 800-53 Revision 5::SC-3
- NIST SP 800-53A::SC-3.1 (ii)

1.108 WN11-CC-000038 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

WDigest Authentication must be disabled.

```
GROUP ID: V-253358
RULE ID: SV-253358r958478
```

Rationale:

When the WDigest Authentication protocol is enabled, plain text passwords are stored in the Local Security Authority Subsystem Service (LSASS) exposing them to theft. WDigest is disabled by default in Windows 11. This setting ensures this is enforced.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\SecurityProviders\Wdigest\

Value Name: UseLogonCredential

Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MS Security Guide >>
"WDigest Authentication (disabling may require KB2871997)"
```

to "Disabled".

The patch referenced in the policy title is not required for Windows 11.

This policy setting requires the installation of the SecGuide custom templates included with the STIG package. "SecGuide.admx" and "SecGuide.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.109 WN11-CC-000039 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Run as different user must be removed from context menus.

```
GROUP ID: V-253359
RULE ID: SV-253359r958478
```

Rationale:

The "Run as different user" selection from context menus allows the use of credentials other than the currently logged on user. Using privileged credentials in a standard user session can expose those credentials to theft. Removing this option from context menus helps prevent this from occurring.

Audit:

If the following registry values do not exist or are not configured as specified, this is a finding.

The policy configures the same Value Name, Type and Value under four different registry paths.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Paths:
\SOFTWARE\Classes\batfile\shell\runasuser\
\SOFTWARE\Classes\cmdfile\shell\runasuser\
\SOFTWARE\Classes\exefile\shell\runasuser\
\SOFTWARE\Classes\mscfile\shell\runasuser\

Value Name: SuppressionPolicy

Type: REG_DWORD
Value: 0x00001000 (4096)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> MS Security Guide >>
"Remove "
```

Run as Different User" from context menus" to "Enabled".

This policy setting requires the installation of the SecGuide custom templates included with the STIG package. "SecGuide.admx" and "SecGuide.adml" must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.110 WN11-CC-000040 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Insecure logons to an SMB server must be disabled.

```
GROUP ID: V-253360
RULE ID: SV-253360r991589
```

Rationale:

Insecure guest logons allow unauthenticated access to shared folders. Shared resources on a system must require authentication to establish proper access.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\LanmanWorkstation\

Value Name: AllowInsecureGuestAuth

Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> Lanman
Workstation >> "Enable insecure guest logons"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.111 WN11-CC-000044 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Internet connection sharing must be disabled.

```
GROUP ID: V-253361
RULE ID: SV-253361r958478
```

Rationale:

Internet connection sharing makes it possible for an existing internet connection, such as through wireless, to be shared and used by other systems essentially creating a mobile hotspot. This exposes the system sharing the connection to others with potentially malicious purpose.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Network Connections\

Value Name: NC_ShowSharedAccessUI

Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> Network
Connections >> "Prohibit use of Internet Connection Sharing on your DNS
domain network"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.112 WN11-CC-000050 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Hardened UNC Paths must be defined to require mutual authentication and integrity for at least the *SYSVOL and* \\NETLOGON shares.

```
GROUP ID: V-253362
RULE ID: SV-253362r991589
```

Rationale:

Additional security requirements are applied to Universal Naming Convention (UNC) paths specified in Hardened UNC paths before allowing access them. This aids in preventing tampering with or spoofing of connections to these paths.

Audit:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

If the following registry values do not exist or are not configured as specified, this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths\

Value Name: \\*\NETLOGON
Value Type: REG_SZ
Value: RequireMutualAuthentication=1, RequireIntegrity=1

Value Name: \\*\SYSVOL
Value Type: REG_SZ
Value: RequireMutualAuthentication=1, RequireIntegrity=1
```

Additional entries would not be a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> Network
Provider >> "Hardened UNC Paths"
```

to "Enabled" with at least the following configured in "Hardened UNC Paths:" (click the "Show" button to display).

Value Name: *\SYSVOL

Value: RequireMutualAuthentication=1, RequireIntegrity=1

Value Name: *\NETLOGON

Value: RequireMutualAuthentication=1, RequireIntegrity=1

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.113 WN11-CC-000052 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to prioritize ECC Curves with longer key lengths first.

```
GROUP ID: V-253363
RULE ID: SV-253363r971535
```

Rationale:

Use of weak or untested encryption algorithms undermines the purposes of utilizing encryption to protect data. By default Windows uses ECC curves with shorter key lengths first. Requiring ECC curves with longer key lengths to be prioritized first helps ensure more secure algorithms are used.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002\

Value Name: EccCurves

Value Type: REG_MULTI_SZ
Value: NistP384 NistP256
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> SSL
Configuration Settings >> "ECC Curve Order"
```

to "Enabled" with "ECC Curve Order:" including the following in the order listed:

NistP384

NistP256

Additional Information:

CCI-000803 Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance for such authentication.

- NIST SP 800-53::IA-7
- NIST SP 800-53 Revision 4::IA-7
- NIST SP 800-53 Revision 5::IA-7
- NIST SP 800-53A::IA-7.1

1.114 WN11-CC-000055 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Simultaneous connections to the internet or a Windows domain must be limited.

```
GROUP ID: V-253364
RULE ID: SV-253364r958358
```

Rationale:

Multiple network connections can provide additional attack vectors to a system and must be limited. The "Minimize the number of simultaneous connections to the Internet or a Windows Domain" setting prevents systems from automatically establishing multiple connections. When both wired and wireless connections are available, for example, the less preferred connection (typically wireless) will be disconnected.

Audit:

The default behavior for "Minimize the number of simultaneous connections to the Internet or a Windows Domain" is "Enabled".

If it exists and is configured with a value of "0", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WcmSvc\GroupPolicy\

Value Name: fMinimizeConnections

Value Type: REG_DWORD
Value: 3 (or if the Value Name does not exist)
```

Remediation:

The default behavior for "Minimize the number of simultaneous connections to the Internet or a Windows Domain" is "Enabled".

If this needs to be corrected, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> Windows
Connection Manager >> "Minimize the number of simultaneous connections to the
Internet or a Windows Domain"
```

to "Enabled". Under "Options", set "Minimize Policy Options" to "3 = Prevent Wi-Fi When on Ethernet".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

1.115 WN11-CC-000060 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Connections to non-domain networks when connected to a domain authenticated network must be blocked.

```
GROUP ID: V-253365
RULE ID: SV-253365r991589
```

Rationale:

Multiple network connections can provide additional attack vectors to a system and must be limited. When connected to a domain, communication must go through the domain connection.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WcmSvc\GroupPolicy\

Value Name: fBlockNonDomain

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> Windows
Connection Manager >> "Prohibit connection to non-domain networks when
connected to domain authenticated network"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.116 WN11-CC-000063 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 systems must use either Group Policy or an approved Mobile Device Management (MDM) product to enforce STIG compliance.

```
GROUP ID: V-268318
RULE ID: SV-268318r1081062
```

Rationale:

Without Windows 11 systems being managed, devices could be rogue and become targets of an attacker.

Audit:

Verify the Windows 11 system is receiving policy from either group Policy or an MDM with the following steps:

From a command line or PowerShell:

gpresult /R

OS Configuration: Member Workstation

If the system is not being managed by GPO, ask the administrator to indicate which MDM is managing the device.

If the Window 11 system is not receiving policy from either group Policy or an MDM, this is a finding.

This is NA for standalone, nondomain joined systems.

Remediation:

Configure the Windows 11 system to use either Group Policy or an approved MDM product to enforce STIG compliance.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.117 WN11-CC-000065 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Wi-Fi Sense must be disabled.

```
GROUP ID: V-253366
RULE ID: SV-253366r991589
```

Rationale:

Wi-Fi Sense automatically connects the system to known hotspots and networks that contacts have shared. It also allows the sharing of the system's known networks to contacts. Automatically connecting to hotspots and shared networks can expose a system to unsecured or potentially malicious systems.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\WcmSvc\wifinetworkmanager\config\

Value Name: AutoConnectAllowedOEM

Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Network >> WLAN Service
>> WLAN Settings>> "Allow Windows to automatically connect to suggested open
hotspots, to networks shared by contacts, and to hotspots offering paid
services"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.118 WN11-CC-000066 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Command line data must be included in process creation events.

```
GROUP ID: V-253367
RULE ID: SV-253367r958422
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Enabling "Include command line data for process creation events" will record the command line information with the process creation events in the log. This can provide additional detail when malware has run on a system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Audit\

Value Name: ProcessCreationIncludeCmdLine_Enabled

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Audit Process
Creation >> "Include command line in process creation events"
```

to "Enabled".

Additional Information:

CCI-000135 Generate audit records containing the organization-defined additional information that is to be included in the audit records.

- NIST SP 800-53::AU-3 (1)
- NIST SP 800-53 Revision 4::AU-3 (1)
- NIST SP 800-53 Revision 5::AU-3 (1)
- NIST SP 800-53A::AU-3 (1).1 (ii)

1.119 WN11-CC-000068 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to enable Remote host allows delegation of non-exportable credentials.

```
GROUP ID: V-253368
RULE ID: SV-253368r991589
```

Rationale:

An exportable version of credentials is provided to remote hosts when using credential delegation which exposes them to theft on the remote host. Restricted Admin mode or Remote Credential Guard allow delegation of non-exportable credentials providing additional protection of the credentials. Enabling this configures the host to support Restricted Admin mode or Remote Credential Guard.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\CredentialsDelegation\

Value Name: AllowProtectedCreds

Type: REG_DWORD
Value: 0x00000001 (1)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Credentials
Delegation >> "Remote host allows delegation of non-exportable credentials"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.120 WN11-CC-000070 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Virtualization-based Security must be enabled on Windows 11 with the platform security level configured to Secure Boot or Secure Boot with DMA Protection.

```
GROUP ID: V-253369
RULE ID: SV-253369r991589
```

Rationale:

Virtualization-based Security (VBS) provides the platform for the additional security features, Credential Guard and virtualization-based protection of code integrity. Secure Boot is the minimum security level with DMA protection providing additional memory protection. DMA Protection requires a CPU that supports input/output memory management unit (IOMMU).

Audit:

Confirm virtualization-based Security is enabled and running with Secure Boot or Secure Boot and DMA Protection.

For those devices that support virtualization-based security (VBS) features, including Credential Guard or protection of code integrity, this must be enabled. If the system meets the hardware and firmware dependencies for enabling VBS but it is not enabled, this is a CAT III finding.

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Run "PowerShell" with elevated privileges (run as administrator).

Enter the following:

```
"Get-CimInstance -ClassName Win32_DeviceGuard -Namespace
root\Microsoft\Windows\DeviceGuard"
```

If "RequiredSecurityProperties" does not include a value of "2" indicating "Secure Boot" (e.g., "{1, 2}"), this is a finding.

If "Secure Boot and DMA Protection" is configured, "3" will also be displayed in the results (e.g., "{1, 2, 3}").

If "VirtualizationBasedSecurityStatus" is not a value of "2" indicating "Running", this is a finding.

Alternately:

Run "System Information".

Under "System Summary", verify the following:

If "Device Guard virtualization-based security" does not display "Running", this is finding.

If "Device Guard Required Security Properties" does not display "Base Virtualization Support, Secure Boot", this is finding.

If "Secure Boot and DMA Protection" is configured, "DMA Protection" will also be displayed (e.g., "Base Virtualization Support, Secure Boot, DMA Protection").

The policy settings referenced in the Fix section will configure the following registry values. However due to hardware requirements, the registry values alone do not ensure proper function.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\DeviceGuard\

Value Name: EnableVirtualizationBasedSecurity
Value Type: REG_DWORD
Value: 1

Value Name: RequirePlatformSecurityFeatures
Value Type: REG_DWORD
Value: 1 (Secure Boot only) or 3 (Secure Boot and DMA Protection)
```

A Microsoft article on Credential Guard system requirement can be found at the following link:

https://technet.microsoft.com/en-us/itpro/windows/keep-secure/credential-guard-requirements

Remediation:

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Device Guard
>> "Turn On virtualization-based Security"
```

to "Enabled" with "Secure Boot" or "Secure Boot and DMA Protection" selected for "Select Platform Security Level:".

A Microsoft article on Credential Guard system requirement can be found at the following link.

https://technet.microsoft.com/en-us/itpro/windows/keep-secure/credential-guard-requirements

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.121 WN11-CC-000075 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Credential Guard must be running on Windows 11 domain-joined systems.

```
GROUP ID: V-253370
RULE ID: SV-253370r991589
```

Rationale:

Credential Guard uses virtualization-based security to protect information that could be used in credential theft attacks if compromised. This authentication information, which was stored in the Local Security Authority (LSA) in previous versions of Windows, is isolated from the rest of operating system and can only be accessed by privileged system software.

Audit:

Confirm Credential Guard is running on domain-joined systems.

For those devices that support Credential Guard, this feature must be enabled. Organizations need to take the appropriate action to acquire and implement compatible hardware with Credential Guard enabled.

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Run "PowerShell" with elevated privileges (run as administrator).

Enter the following:

```
"Get-CimInstance -ClassName Win32_DeviceGuard -Namespace
root\Microsoft\Windows\DeviceGuard"
```

If "SecurityServicesRunning" does not include a value of "1" (e.g., "{1, 2}"), this is a finding.

Alternately:

Run "System Information".

Under "System Summary", verify the following:

If "virtualization-based Services Running" does not list "Credential Guard", this is finding.

The policy settings referenced in the Fix section will configure the following registry value. However, due to hardware requirements, the registry value alone does not ensure proper function.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\DeviceGuard\

Value Name: LsaCfgFlags
Value Type: REG_DWORD
Value: 0x00000001 (1) (Enabled with UEFI lock)
```

Remediation:

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

For VDIs with persistent desktops, this may be downgraded to a CAT II only where administrators have specific tokens for the VDI. Administrator accounts on virtual desktops must only be used on systems in the VDI; they may not have administrative privileges on any other systems such as servers and physical workstations.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Device Guard
>> "Turn On virtualization-based Security"
```

to "Enabled" with "Enabled with UEFI lock" selected for "Credential Guard Configuration:".

A Microsoft TechNet article on Credential Guard, including system requirement details, can be found at the following link:

https://docs.microsoft.com/en-us/windows/access-protection/credential-guard/credential-guard

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.122 WN11-CC-000080 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Virtualization-based protection of code integrity must be enabled.

```
GROUP ID: V-253371
RULE ID: SV-253371r991589
```

Rationale:

Virtualization-based protection of code integrity enforces kernel mode memory protections as well as protecting Code Integrity validation paths. This isolates the processes from the rest of the operating system and can only be accessed by privileged system software.

Audit:

Confirm virtualization-based protection of code integrity.

For those devices that support the virtualization-based security (VBS) feature for protection of code integrity, this must be enabled. If the system meets the hardware, firmware and compatible device driver dependencies for enabling virtualization-based protection of code integrity but it is not enabled, this is a CAT II finding.

Virtualization-based security currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Run "PowerShell" with elevated privileges (run as administrator).

Enter the following:

```
"Get-CimInstance -ClassName Win32_DeviceGuard -Namespace
root\Microsoft\Windows\DeviceGuard"
```

If "SecurityServicesRunning" does not include a value of "2" (e.g., "{1, 2}"), this is a finding.

Alternately:

Run "System Information".

Under "System Summary", verify the following:

If "Virtualization-based Security Services Running" does not list "Hypervisor enforced Code Integrity", this is finding.

The policy settings referenced in the Fix section will configure the following registry value. However due to hardware requirements, the registry value alone does not ensure proper function.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\DeviceGuard\

Value Name: HypervisorEnforcedCodeIntegrity
Value Type: REG_DWORD
Value: 0x00000001 (1) (Enabled with UEFI lock), or 0x00000002 (2) (Enabled
without lock)
```

Remediation:

Virtualization-based security currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop.

For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Device Guard
>> "Turn On virtualization-based Security"
```

to "Enabled" with "Enabled with UEFI lock" or "Enabled without lock" selected for "virtualization-based Protection of Code Integrity:".

"Enabled with UEFI lock" is preferred as more secure, however it cannot be turned off remotely through a group policy change if there is an issue.

"Enabled without lock" will allow this to be turned off remotely while testing for issues.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.123 WN11-CC-000085 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Early Launch Antimalware, Boot-Start Driver Initialization Policy must prevent boot drivers.

```
GROUP ID: V-253372
RULE ID: SV-253372r991589
```

Rationale:

The default behavior is for Early Launch Antimalware - Boot-Start Driver Initialization policy is to enforce "Good, unknown and bad but critical" (preventing "bad"). By being launched first by the kernel, ELAM (Early Launch Antimalware) is ensured to be launched before any third-party software, and is therefore able to detect malware in the boot process and prevent it from initializing.

Audit:

The default behavior is for Early Launch Antimalware - Boot-Start Driver Initialization policy is to enforce "Good, unknown and bad but critical" (preventing "bad").

If the registry value name below does not exist, this is a finding.

If it exists and is configured with a value of "7", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Policies\EarlyLaunch\

Value Name: DriverLoadPolicy

Value Type: REG_DWORD
Value: 1, 3, or 8
```

Possible values for this setting are:

8 - Good only

1 - Good and unknown

3 - Good, unknown and bad but critical

7 - All (which includes "Bad" and would be a finding)

Remediation:

Ensure that Early Launch Antimalware - Boot-Start Driver Initialization policy is set to enforce "Good, unknown and bad but critical" (preventing "bad").

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Early Launch
Antimalware >> "Boot-Start Driver Initialization Policy"
```

to "Enabled with "Good, unknown and bad but critical" selected.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.124 WN11-CC-000090 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Group Policy objects must be reprocessed even if they have not changed.

```
GROUP ID: V-253373
RULE ID: SV-253373r991589
```

Rationale:

Enabling this setting and then selecting the "Process even if the Group Policy objects have not changed" option ensures that the policies will be reprocessed even if none have been changed. This way, any unauthorized changes are forced to match the domain-based group policy settings again.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Group Policy\{35378EAC-
683F-11D2-A89A-00C04FBBCFA2}

Value Name: NoGPOListChanges

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Group Policy
>> "Configure registry policy processing"
```

to "Enabled" and select the option "Process even if the Group Policy objects have not changed".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.125 WN11-CC-000100 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Downloading print driver packages over HTTP must be prevented.

```
GROUP ID: V-253374
RULE ID: SV-253374r958478
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Turning off this capability will prevent potentially sensitive information from being sent outside the enterprise and uncontrolled updates to the system. This setting prevents the computer from downloading print driver packages over HTTP.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Printers\

Value Name: DisableWebPnPDownload

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Internet
Communication Management >> Internet Communication settings >> "Turn off
downloading of print drivers over HTTP"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.126 WN11-CC-000105 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Web publishing and online ordering wizards must be prevented from downloading a list of providers.

```
GROUP ID: V-253375
RULE ID: SV-253375r958478
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Turning off this capability will prevent potentially sensitive information from being sent outside the enterprise and uncontrolled updates to the system. This setting prevents Windows from downloading a list of providers for the Web publishing and online ordering wizards.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\

Value Name: NoWebServices

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Internet
Communication Management >> Internet Communication settings >> "Turn off
Internet download for Web publishing and online ordering wizards"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.127 WN11-CC-000110 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Printing over HTTP must be prevented.

```
GROUP ID: V-253376
RULE ID: SV-253376r958478
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Turning off this capability will prevent potentially sensitive information from being sent outside the enterprise and uncontrolled updates to the system. This setting prevents the client computer from printing over HTTP, which allows the computer to print to printers on the intranet as well as the internet.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Printers\

Value Name: DisableHTTPPrinting

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Internet
Communication Management >> Internet Communication settings >> "Turn off
printing over HTTP"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.128 WN11-CC-000115 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Systems must at least attempt device authentication using certificates.

```
GROUP ID: V-253377
RULE ID: SV-253377r991589
```

Rationale:

Using certificates to authenticate devices to the domain provides increased security over passwords. By default systems will attempt to authenticate using certificates and fall back to passwords if the domain controller does not support certificates for devices. This may also be configured to always use certificates for device authentication.

Audit:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

The default behavior for "Support device authentication using certificate" is "Automatic".

If it exists and is configured with a value of "0", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Kerberos\Parameter
s\

Value Name: DevicePKInitEnabled
Value Type: REG_DWORD
Value: 1 (or if the Value Name does not exist)
```

Remediation:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

The default behavior for "Support device authentication using certificate" is "Automatic".

To correct this, configured the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Kerberos >>
"Support device authentication using certificate"
```

to "Not Configured or "Enabled" with either option selected in "Device authentication behavior using certificate:".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.129 WN11-CC-000120 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The network selection user interface (UI) must not be displayed on the logon screen.

```
GROUP ID: V-253378
RULE ID: SV-253378r958478
```

Rationale:

Enabling interaction with the network selection UI allows users to change connections to available networks without signing into Windows.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\System\

Value Name: DontDisplayNetworkSelectionUI

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Logon >> "Do
not display network selection UI"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.130 WN11-CC-000130 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Local users on domain-joined computers must not be enumerated.

```
GROUP ID: V-253379
RULE ID: SV-253379r958478
```

Rationale:

The username is one part of logon credentials that could be used to gain access to a system. Preventing the enumeration of users limits this information to authorized personnel.

Audit:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\System\

Value Name: EnumerateLocalUsers

Value Type: REG_DWORD
Value: 0
```

Remediation:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Logon >>
"Enumerate local users on domain-joined computers"
```

to "Disabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.131 WN11-CC-000145 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Users must be prompted for a password on resume from sleep (on battery).

```
GROUP ID: V-253380
RULE ID: SV-253380r1051049
```

Rationale:

Authentication must always be required when accessing a system. This setting ensures the user is prompted for a password on resume from sleep (on battery).

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Power\PowerSettings\0e796bdb-
100d-47d6-a2d5-f7d2daa51f51\

Value Name: DCSettingIndex

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Power
Management >> Sleep Settings >> "Require a password when a computer wakes (on
battery)"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.132 WN11-CC-000150 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The user must be prompted for a password on resume from sleep (plugged in).

```
GROUP ID: V-253381
RULE ID: SV-253381r1051050
```

Rationale:

Authentication must always be required when accessing a system. This setting ensures the user is prompted for a password on resume from sleep (plugged in).

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Power\PowerSettings\0e796bdb-
100d-47d6-a2d5-f7d2daa51f51\

Value Name: ACSettingIndex

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Power
Management >> Sleep Settings >> "Require a password when a computer wakes
(plugged in)"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.133 WN11-CC-000155 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Solicited Remote Assistance must not be allowed.

```
GROUP ID: V-253382
RULE ID: SV-253382r958524
```

Rationale:

Remote assistance allows another user to view or take control of the local session of a user. Solicited assistance is help that is specifically requested by the local user. This may allow unauthorized parties access to the resources on the computer.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\

Value Name: fAllowToGetHelp

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Remote
Assistance >> "Configure Solicited Remote Assistance"
```

to "Disabled".

Additional Information:

CCI-001090 Prevent unauthorized and unintended information transfer via shared system resources.

- NIST SP 800-53::SC-4
- NIST SP 800-53 Revision 4::SC-4
- NIST SP 800-53 Revision 5::SC-4
- NIST SP 800-53A::SC-4.1

1.134 WN11-CC-000165 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Unauthenticated RPC clients must be restricted from connecting to the RPC server.

```
GROUP ID: V-253383
RULE ID: SV-253383r971545
```

Rationale:

Configuring RPC to restrict unauthenticated RPC clients from connecting to the RPC server will prevent anonymous connections.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Rpc\

Value Name: RestrictRemoteClients

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Remote
Procedure Call >> "Restrict Unauthenticated RPC clients"
```

to "Enabled" and "Authenticated".

Additional Information:

CCI-001967 Authenticate organization-defined devices and/or types of devices before establishing a local, remote, and/or network connection using bidirectional authentication that is cryptographically based.

- NIST SP 800-53 Revision 4::IA-3 (1)
- NIST SP 800-53 Revision 5::IA-3 (1)

1.135 WN11-CC-000170 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The setting to allow Microsoft accounts to be optional for modern style apps must be enabled.

```
GROUP ID: V-253384
RULE ID: SV-253384r991589
```

Rationale:

Control of credentials and the system must be maintained within the enterprise. Enabling this setting allows enterprise credentials to be used with modern style apps that support this, instead of Microsoft accounts.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: MSAOptional

Value Type: REG_DWORD
Value: 0x00000001 (1)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
App Runtime >> "Allow Microsoft accounts to be optional"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.136 WN11-CC-000175 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The Application Compatibility Program Inventory must be prevented from collecting data and sending the information to Microsoft.

```
GROUP ID: V-253385
RULE ID: SV-253385r958478
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Turning off this capability will prevent potentially sensitive information from being sent outside the enterprise and uncontrolled updates to the system. This setting will prevent the Program Inventory from collecting data about a system and sending the information to Microsoft.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\AppCompat\

Value Name: DisableInventory

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Application Compatibility >> "Turn off Inventory Collector"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.137 WN11-CC-000180 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Autoplay must be turned off for non-volume devices.

```
GROUP ID: V-253386
RULE ID: SV-253386r958804
```

Rationale:

Allowing autoplay to execute may introduce malicious code to a system. Autoplay begins reading from a drive as soon as media is inserted in the drive. As a result, the setup file of programs or music on audio media may start. This setting will disable autoplay for non-volume devices (such as Media Transfer Protocol (MTP) devices).

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Explorer\

Value Name: NoAutoplayfornonVolume

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
AutoPlay Policies >> "Disallow Autoplay for non-volume devices"
```

to "Enabled".

Additional Information:

CCI-001764 Prevent program execution in accordance with organization-defined policies, rules of behavior, and/or access agreements regarding software program usage and restrictions; rules authorizing the terms and conditions of software program usage.

- NIST SP 800-53 Revision 4::CM-7 (2)
- NIST SP 800-53 Revision 5::CM-7 (2)

1.138 WN11-CC-000185 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The default autorun behavior must be configured to prevent autorun commands.

```
GROUP ID: V-253387
RULE ID: SV-253387r958804
```

Rationale:

Allowing autorun commands to execute may introduce malicious code to a system. Configuring this setting prevents autorun commands from executing.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\

Value Name: NoAutorun

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
AutoPlay Policies >> "Set the default behavior for AutoRun"
```

to "Enabled:Do not execute any autorun commands".

Additional Information:

CCI-001764 Prevent program execution in accordance with organization-defined policies, rules of behavior, and/or access agreements regarding software program usage and restrictions; rules authorizing the terms and conditions of software program usage.

- NIST SP 800-53 Revision 4::CM-7 (2)
- NIST SP 800-53 Revision 5::CM-7 (2)

1.139 WN11-CC-000190 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Autoplay must be disabled for all drives.

```
GROUP ID: V-253388
RULE ID: SV-253388r958804
```

Rationale:

Allowing autoplay to execute may introduce malicious code to a system. Autoplay begins reading from a drive as soon as media is inserted in the drive. As a result, the setup file of programs or music on audio media may start. By default, autoplay is disabled on removable drives, such as the floppy disk drive (but not the CD-ROM drive) and on network drives. If this policy is enabled, autoplay can be disabled on all drives.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\policies\Explorer\

Value Name: NoDriveTypeAutoRun

Value Type: REG_DWORD
Value: 0x000000ff (255)
```

Note: If the value for NoDriveTypeAutorun is entered manually, it must be entered as "ff" when Hexadecimal is selected, or "255" with Decimal selected. Using the policy value specified in the Fix section will enter it correctly.

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
AutoPlay Policies >> "Turn off AutoPlay"
```

to "Enabled:All Drives".

Additional Information:

CCI-001764 Prevent program execution in accordance with organization-defined policies, rules of behavior, and/or access agreements regarding software program usage and restrictions; rules authorizing the terms and conditions of software program usage.

- NIST SP 800-53 Revision 4::CM-7 (2)
- NIST SP 800-53 Revision 5::CM-7 (2)

1.140 WN11-CC-000195 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Enhanced anti-spoofing for facial recognition must be enabled on Windows 11.

```
GROUP ID: V-253389
RULE ID: SV-253389r991589
```

Rationale:

Enhanced anti-spoofing provides additional protections when using facial recognition with devices that support it.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Biometrics\FacialFeatures\

Value Name: EnhancedAntiSpoofing

Value Type: REG_DWORD
Value: 0x00000001 (1)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Biometrics >> Facial Features >> "Configure enhanced anti-spoofing"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.141 WN11-CC-000197 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Microsoft consumer experiences must be turned off.

```
GROUP ID: V-253390
RULE ID: SV-253390r958478
```

Rationale:

Microsoft consumer experiences provides suggestions and notifications to users, which may include the installation of Windows Store apps. Organizations may control the execution of applications through other means such as allowlisting. Turning off Microsoft consumer experiences will help prevent the unwanted installation of suggested applications.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\CloudContent\

Value Name: DisableWindowsConsumerFeatures

Type: REG_DWORD
Value: 0x00000001 (1)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Cloud Content >> "Turn off Microsoft consumer experiences"
```

to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.142 WN11-CC-000200 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Administrator accounts must not be enumerated during elevation.

```
GROUP ID: V-253391
RULE ID: SV-253391r958518
```

Rationale:

Enumeration of administrator accounts when elevating can provide part of the logon information to an unauthorized user. This setting configures the system to always require users to type in a username and password to elevate a running application.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\CredUI\

Value Name: EnumerateAdministrators

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Credential User Interface >> "Enumerate administrator accounts on elevation"
```

to "Disabled".

Additional Information:

CCI-001084 Isolate security functions from nonsecurity functions.

- NIST SP 800-53::SC-3
- NIST SP 800-53 Revision 4::SC-3
- NIST SP 800-53 Revision 5::SC-3
- NIST SP 800-53A::SC-3.1 (ii)

1.143 WN11-CC-000204 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Enhanced diagnostic data must be limited to the minimum required to support Windows Analytics.

```
GROUP ID: V-253392
RULE ID: SV-253392r991589
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Limiting this capability will prevent potentially sensitive information from being sent outside the enterprise. The "Enhanced" level for telemetry includes additional information beyond "Security" and "Basic" on how Windows and apps are used and advanced reliability data. Windows Analytics can use a "limited enhanced" level to provide information such as health data for devices.

Audit:

If "Enhanced" level is enabled for telemetry, this must be configured. If "Security" or "Basic" are configured, this is NA. (See WN11-CC-000205).

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\DataCollection\

Value Name: LimitEnhancedDiagnosticDataWindowsAnalytics

Type: REG_DWORD
Value: 0x00000001 (1)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Data Collection and Preview Builds >> "Limit optional diagnostic data for
Windows Analytics"
```

to "Enabled" with "Enable Desktop Analytics collection" selected in "Options:".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.144 WN11-CC-000205 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows Telemetry must not be configured to Full.

```
GROUP ID: V-253393
RULE ID: SV-253393r958564
```

Rationale:

Some features may communicate with the vendor, sending system information or downloading data or components for the feature. Limiting this capability will prevent potentially sensitive information from being sent outside the enterprise. The "Security" option for Telemetry configures the lowest amount of data, effectively none outside of the Malicious Software Removal Tool (MSRT), Defender and telemetry client settings. "Basic" sends basic diagnostic and usage data and may be required to support some Microsoft services. "Enhanced" includes additional information on how Windows and apps are used and advanced reliability data. Windows Analytics can use a "limited enhanced" level to provide information such as health data for devices.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\DataCollection\

Value Name: AllowTelemetry

Type: REG_DWORD
Value: 0x00000000 (0) (Security)
```

0x00000001 (1) (Basic)

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Data Collection and Preview Builds >> "Allow Diagnostic Data"
```

to "Enabled" with "Send required diagnostic data" selected in "Options:".

Additional Information:

CCI-001312 Generates error messages that provide information necessary for corrective actions without revealing information that could be exploited.

- NIST SP 800-53::SI-11 b
- NIST SP 800-53 Revision 4::SI-11 a
- NIST SP 800-53 Revision 5::SI-11 a
- NIST SP 800-53A::SI-11.1 (iii)

1.145 WN11-CC-000206 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Windows Update must not obtain updates from other PCs on the internet.

```
GROUP ID: V-253394
RULE ID: SV-253394r991589
```

Rationale:

Windows 11 allows Windows Update to obtain updates from additional sources instead of Microsoft. In addition to Microsoft, updates can be obtained from and sent to PCs on the local network as well as on the Internet. This is part of the Windows Update trusted process, however to minimize outside exposure, obtaining updates from or sending to systems on the internet must be prevented.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\Windows\DeliveryOptimization\



Value Name: DODownloadMode



Value Type: REG_DWORD

Value: 0x00000000 (0) - No peering (HTTP Only)

0x00000001 (1) - Peers on same NAT only (LAN)

0x00000002 (2) - Local Network / Private group peering (Group)

0x00000063 (99) - Simple download mode, no peering (Simple)

0x00000064 (100) - Bypass mode, Delivery Optimization not used (Bypass)



A value of 0x00000003 (3), Internet, is a finding.



Standalone systems (configured in Settings):

If the following registry value does not exist or is not configured as
specified, this is a finding:
```

Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\DeliveryOptimization\Config\

Value Name: DODownloadMode

Value Type: REG_DWORD

Value: 0x00000000 (0) - Off

0x00000001 (1) - LAN

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Delivery Optimization >> "Download Mode"
```

to "Enabled" with any option except "Internet" selected.

Acceptable selections include:

Bypass (100)

Group (2)

HTTP only (0)

LAN (1)

Simple (99)

.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.146 WN11-CC-000210 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Microsoft Defender SmartScreen for Explorer must be enabled.

```
GROUP ID: V-253395
RULE ID: SV-253395r958478
```

Rationale:

Microsoft Defender SmartScreen helps protect systems from programs downloaded from the internet that may be malicious. Enabling Microsoft Defender SmartScreen will warn or prevent users from running potentially malicious programs.

Audit:

This is applicable to unclassified systems, for other systems this is NA.

If the following registry values do not exist or are not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\Windows\System\



Value Name: EnableSmartScreen



Value Type: REG_DWORD

Value: 0x00000001 (1)



And
```

Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\Windows\System\

Value Name: ShellSmartScreenLevel

Value Type: REG_SZ

Value: Block

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
File Explorer >> "Configure Windows Defender SmartScreen"
```

to "Enabled" with "Warn and prevent bypass" selected.

Windows 11 includes duplicate policies for this setting. It can also be configured under

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Defender SmartScreen >> Explorer.
```

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.147 WN11-CC-000215 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Explorer Data Execution Prevention must be enabled.

```
GROUP ID: V-253396
RULE ID: SV-253396r958928
```

Rationale:

Data Execution Prevention (DEP) provides additional protection by performing checks on memory to help prevent malicious code from running. This setting will prevent Data Execution Prevention from being turned off for File Explorer.

Audit:

The default behavior is for data execution prevention to be turned on for file explorer.

If it exists and is configured with a value of "1", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Explorer\

Value Name: NoDataExecutionPrevention

Value Type: REG_DWORD
Value: 0 (or if the Value Name does not exist)
```

Remediation:

The default behavior is for data execution prevention to be turned on for file explorer.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
File Explorer >> "Turn off Data Execution Prevention for Explorer"
```

to "Not Configured" or "Disabled".

Additional Information:

CCI-002824 Implement organization-defined controls to protect its memory from unauthorized code execution.

- NIST SP 800-53 Revision 4::SI-16
- NIST SP 800-53 Revision 5::SI-16

1.148 WN11-CC-000220 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

File Explorer heap termination on corruption must be disabled.

```
GROUP ID: V-253397
RULE ID: SV-253397r958902
```

Rationale:

Legacy plug-in applications may continue to function when a File Explorer session has become corrupt. Disabling this feature will prevent this.

Audit:

The default behavior is for File Explorer heap termination on corruption to be enabled.

If it exists and is configured with a value of "1", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Explorer\

Value Name: NoHeapTerminationOnCorruption

Value Type: REG_DWORD
Value: 0x00000000 (0) (or if the Value Name does not exist)
```

Remediation:

The default behavior is for File Explorer heap termination on corruption to be enabled.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
File Explorer >> "Turn off heap termination on corruption"
```

to "Not Configured" or "Disabled".

Additional Information:

CCI-002385 Protect against or limit the effects of organization-defined types of denial of service events.

- NIST SP 800-53 Revision 4::SC-5
- NIST SP 800-53 Revision 5::SC-5 a

1.149 WN11-CC-000225 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

File Explorer shell protocol must run in protected mode.

```
GROUP ID: V-253398
RULE ID: SV-253398r991589
```

Rationale:

The shell protocol will limit the set of folders applications can open when run in protected mode. Restricting files an application can open, to a limited set of folders, increases the security of Windows.

Audit:

The default behavior is for shell protected mode to be turned on for file explorer.

If it exists and is configured with a value of "1", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer\

Value Name: PreXPSP2ShellProtocolBehavior

Value Type: REG_DWORD
Value: 0 (or if the Value Name does not exist)
```

Remediation:

The default behavior is for shell protected mode to be turned on for file explorer.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
File Explorer >> "Turn off shell protocol protected mode"
```

to "Not Configured" or "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.150 WN11-CC-000252 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to disable Windows Game Recording and Broadcasting.

```
GROUP ID: V-253399
RULE ID: SV-253399r958478
```

Rationale:

Windows Game Recording and Broadcasting is intended for use with games; however, it could potentially record screen shots of other applications and expose sensitive data. Disabling the feature will prevent this from occurring.

Audit:

This is NA for Windows 11 LTSC.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\GameDVR\

Value Name: AllowGameDVR

Type: REG_DWORD
Value: 0x00000000 (0)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Game Recording and Broadcasting >> "Enables or disables Windows Game
Recording and Broadcasting"
```

to "Disabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.151 WN11-CC-000255 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The use of a hardware security device with Windows Hello for Business must be enabled.

```
GROUP ID: V-253400
RULE ID: SV-253400r991589
```

Rationale:

The use of a Trusted Platform Module (TPM) to store keys for Windows Hello for Business provides additional security. Keys stored in the TPM may only be used on that system while keys stored using software are more susceptible to compromise and could be used on other systems.

Audit:

Virtual desktop implementations currently may not support the use of TPMs. For virtual desktop implementations where the virtual desktop instance is deleted or refreshed upon logoff, this is NA.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\PassportForWork\

Value Name: RequireSecurityDevice

Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Hello for Business >> "Use a hardware security device"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.152 WN11-CC-000260 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to require a minimum pin length of six characters or greater.

```
GROUP ID: V-253401
RULE ID: SV-253401r991589
```

Rationale:

Windows allows the use of PINs as well as biometrics for authentication without sending a password to a network or website where it could be compromised. Longer minimum PIN lengths increase the available combinations an attacker would have to attempt. Shorter minimum length significantly reduces the strength.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\PassportForWork\PINComplexity\

Value Name: MinimumPINLength

Type: REG_DWORD
Value: 6 (or greater)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> PIN
Complexity >> "Minimum PIN length"
```

to "6" or greater.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.153 WN11-CC-000270 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Passwords must not be saved in the Remote Desktop Client.

```
GROUP ID: V-253402
RULE ID: SV-253402r1051051
```

Rationale:

Saving passwords in the Remote Desktop Client could allow an unauthorized user to establish a remote desktop session to another system. The system must be configured to prevent users from saving passwords in the Remote Desktop Client.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\

Value Name: DisablePasswordSaving

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Remote Desktop Services >> Remote Desktop Connection Client >> "Do not allow
passwords to be saved"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.154 WN11-CC-000275 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Local drives must be prevented from sharing with Remote Desktop Session Hosts.

```
GROUP ID: V-253403
RULE ID: SV-253403r958524
```

Rationale:

Preventing users from sharing the local drives on their client computers to Remote Session Hosts that they access helps reduce possible exposure of sensitive data.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\

Value Name: fDisableCdm

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Remote Desktop Services >> Remote Desktop Session Host >> Device and Resource
Redirection >> "Do not allow drive redirection"
```

to "Enabled".

Additional Information:

CCI-001090 Prevent unauthorized and unintended information transfer via shared system resources.

- NIST SP 800-53::SC-4
- NIST SP 800-53 Revision 4::SC-4
- NIST SP 800-53 Revision 5::SC-4
- NIST SP 800-53A::SC-4.1

1.155 WN11-CC-000280 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Remote Desktop Services must always prompt a client for passwords upon connection.

```
GROUP ID: V-253404
RULE ID: SV-253404r1051052
```

Rationale:

This setting controls the ability of users to supply passwords automatically as part of their remote desktop connection. Disabling this setting would allow anyone to use the stored credentials in a connection item to connect to the terminal server.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\

Value Name: fPromptForPassword

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Remote Desktop Services >> Remote Desktop Session Host >> Security >> "Always
prompt for password upon connection"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.156 WN11-CC-000285 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Remote Desktop Session Host must require secure RPC communications.

```
GROUP ID: V-253405
RULE ID: SV-253405r991554
```

Rationale:

Allowing unsecure RPC communication exposes the system to man in the middle attacks and data disclosure attacks. A man in the middle attack occurs when an intruder captures packets between a client and server and modifies them before allowing the packets to be exchanged. Usually the attacker will modify the information in the packets in an attempt to cause either the client or server to reveal sensitive information.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\

Value Name: fEncryptRPCTraffic

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Remote Desktop Services >> Remote Desktop Session Host >> Security "Require
secure RPC communication"
```

to "Enabled".

Additional Information:

CCI-001453 Implement cryptographic mechanisms to protect the integrity of remote access sessions.

- NIST SP 800-53::AC-17 (2)
- NIST SP 800-53 Revision 4::AC-17 (2)
- NIST SP 800-53 Revision 5::AC-17 (2)
- NIST SP 800-53A::AC-17 (2).1

1.157 WN11-CC-000290 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Remote Desktop Services must be configured with the client connection encryption set to the required level.

```
GROUP ID: V-253406
RULE ID: SV-253406r958408
```

Rationale:

Remote connections must be encrypted to prevent interception of data or sensitive information. Selecting "High Level" will ensure encryption of Remote Desktop Services sessions in both directions.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\

Value Name: MinEncryptionLevel

Value Type: REG_DWORD
Value: 3
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Remote Desktop Services >> Remote Desktop Session Host >> Security >> "Set
client connection encryption level"
```

to "Enabled" and "High Level".

Additional Information:

CCI-000068 Implement cryptographic mechanisms to protect the confidentiality of remote access sessions.

- NIST SP 800-53::AC-17 (2)
- NIST SP 800-53 Revision 4::AC-17 (2)
- NIST SP 800-53 Revision 5::AC-17 (2)
- NIST SP 800-53A::AC-17 (2).1

1.158 WN11-CC-000295 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Attachments must be prevented from being downloaded from RSS feeds.

```
GROUP ID: V-253407
RULE ID: SV-253407r991589
```

Rationale:

Attachments from RSS feeds may not be secure. This setting will prevent attachments from being downloaded from RSS feeds.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Internet Explorer\Feeds\

Value Name: DisableEnclosureDownload

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
RSS Feeds >> "Prevent downloading of enclosures"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.159 WN11-CC-000300 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Basic authentication for RSS feeds over HTTP must not be used.

```
GROUP ID: V-253408
RULE ID: SV-253408r958478
```

Rationale:

Basic authentication uses plain text passwords that could be used to compromise a system.

Audit:

The default behavior is for the Windows RSS platform to not use Basic authentication over HTTP connections.

If it exists and is configured with a value of "1", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Internet Explorer\Feeds\

Value Name: AllowBasicAuthInClear

Value Type: REG_DWORD
Value: 0 (or if the Value Name does not exist)
```

Remediation:

The default behavior is for the Windows RSS platform to not use Basic authentication over HTTP connections.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
RSS Feeds >> "Turn on Basic feed authentication over HTTP"
```

to "Not Configured" or "Disabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.160 WN11-CC-000305 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Indexing of encrypted files must be turned off.

```
GROUP ID: V-253409
RULE ID: SV-253409r958478
```

Rationale:

Indexing of encrypted files may expose sensitive data. This setting prevents encrypted files from being indexed.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Windows Search\

Value Name: AllowIndexingEncryptedStoresOrItems

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Search >> "Allow indexing of encrypted files"
```

to "Disabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.161 WN11-CC-000310 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Users must be prevented from changing installation options.

```
GROUP ID: V-253410
RULE ID: SV-253410r1051053
```

Rationale:

Installation options for applications are typically controlled by administrators. This setting prevents users from changing installation options that may bypass security features.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Installer\

Value Name: EnableUserControl

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Installer >> "Allow user control over installs"
```

to "Disabled".

Additional Information:

CCI-003980 Allow user installation of software only with explicit privileged status.

- NIST SP 800-53 Revision 5::CM-11 (2)

CCI-001812 The information system prohibits user installation of software without explicit privileged status.

- NIST SP 800-53 Revision 4::CM-11 (2)

1.162 WN11-CC-000315 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The Windows Installer feature "Always install with elevated privileges" must be disabled.

```
GROUP ID: V-253411
RULE ID: SV-253411r1051054
```

Rationale:

Standard user accounts must not be granted elevated privileges. Enabling Windows Installer to elevate privileges when installing applications can allow malicious persons and applications to gain full control of a system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Installer\

Value Name: AlwaysInstallElevated

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Installer >> "Always install with elevated privileges"
```

to "Disabled".

Additional Information:

CCI-003980 Allow user installation of software only with explicit privileged status.

- NIST SP 800-53 Revision 5::CM-11 (2)

CCI-001812 The information system prohibits user installation of software without explicit privileged status.

- NIST SP 800-53 Revision 4::CM-11 (2)

1.163 WN11-CC-000320 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Users must be notified if a web-based program attempts to install software.

```
GROUP ID: V-253412
RULE ID: SV-253412r991589
```

Rationale:

Web-based programs may attempt to install malicious software on a system. Ensuring users are notified if a web-based program attempts to install software allows them to refuse the installation.

Audit:

The default behavior is for Internet Explorer to warn users and select whether to allow or refuse installation when a web-based program attempts to install software on the system.

If it exists and is configured with a value of "1", this is a finding.

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\Installer\

Value Name: SafeForScripting

Value Type: REG_DWORD
Value: 0 (or if the Value Name does not exist)
```

Remediation:

The default behavior is for Internet Explorer to warn users and select whether to allow or refuse installation when a web-based program attempts to install software on the system.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Installer >> "Prevent Internet Explorer security prompt for Windows
Installer scripts"
```

to "Not Configured" or "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.164 WN11-CC-000325 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Automatically signing in the last interactive user after a system-initiated restart must be disabled.

```
GROUP ID: V-253413
RULE ID: SV-253413r991591
```

Rationale:

Windows can be configured to automatically sign the user back in after a Windows Update restart. Some protections are in place to help ensure this is done in a secure fashion; however, disabling this will prevent the caching of credentials for this purpose and also ensure the user is aware of the restart.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: DisableAutomaticRestartSignOn

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Logon Options >> "Sign-in last interactive user automatically after a
system-initiated restart"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.165 WN11-CC-000326 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

PowerShell script block logging must be enabled on Windows 11.

```
GROUP ID: V-253414
RULE ID: SV-253414r958422
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Enabling PowerShell script block logging will record detailed information from the processing of PowerShell commands and scripts. This can provide additional detail when malware has run on a system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging\

Value Name: EnableScriptBlockLogging

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows PowerShell >> "Turn on PowerShell Script Block Logging"
```

to "Enabled".

Additional Information:

CCI-000135 Generate audit records containing the organization-defined additional information that is to be included in the audit records.

- NIST SP 800-53::AU-3 (1)
- NIST SP 800-53 Revision 4::AU-3 (1)
- NIST SP 800-53 Revision 5::AU-3 (1)
- NIST SP 800-53A::AU-3 (1).1 (ii)

1.166 WN11-CC-000327 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

PowerShell Transcription must be enabled on Windows 11.

```
GROUP ID: V-253415
RULE ID: SV-253415r958420
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior.

Enabling PowerShell Transcription will record detailed information from the processing of PowerShell commands and scripts. This can provide additional detail when malware has run on a system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription\

Value Name: EnableTranscripting

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows PowerShell >> "Turn on PowerShell Transcription"
```

to "Enabled".

Specify the Transcript output directory to point to a Central Log Server or another secure location to prevent user access.

Additional Information:

CCI-000134 Ensure that audit records containing information that establishes the outcome of the event.

- NIST SP 800-53::AU-3
- NIST SP 800-53 Revision 4::AU-3
- NIST SP 800-53 Revision 5::AU-3 e
- NIST SP 800-53A::AU-3.1

1.167 WN11-CC-000330 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The Windows Remote Management (WinRM) client must not use Basic authentication.

```
GROUP ID: V-253416
RULE ID: SV-253416r958510
```

Rationale:

Basic authentication uses plain text passwords that could be used to compromise a system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WinRM\Client\

Value Name: AllowBasic

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Remote Management (WinRM) >> WinRM Client >> "Allow Basic
authentication"
```

to "Disabled".

Additional Information:

CCI-000877 Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions.

- NIST SP 800-53::MA-4 c
- NIST SP 800-53 Revision 4::MA-4 c
- NIST SP 800-53 Revision 5::MA-4 c
- NIST SP 800-53A::MA-4.1 (iv)

1.168 WN11-CC-000335 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows Remote Management (WinRM) client must not allow unencrypted traffic.

```
GROUP ID: V-253417
RULE ID: SV-253417r958848
```

Rationale:

Unencrypted remote access to a system can allow sensitive information to be compromised. Windows remote management connections must be encrypted to prevent this.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WinRM\Client\

Value Name: AllowUnencryptedTraffic

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Remote Management (WinRM) >> WinRM Client >> "Allow unencrypted
traffic"
```

to "Disabled".

Additional Information:

CCI-002890 Implement organization-defined cryptographic mechanisms to protect the integrity of nonlocal maintenance and diagnostic communications.

- NIST SP 800-53 Revision 4::MA-4 (6)
- NIST SP 800-53 Revision 5::MA-4 (6)

1.169 WN11-CC-000345 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The Windows Remote Management (WinRM) service must not use Basic authentication.

```
GROUP ID: V-253418
RULE ID: SV-253418r958510
```

Rationale:

Basic authentication uses plain text passwords that could be used to compromise a system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WinRM\Service\

Value Name: AllowBasic

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Remote Management (WinRM) >> WinRM Service >> "Allow Basic
authentication"
```

to "Disabled".

Severity Override Guidance: The AO can allow the severity override if they have reviewed the overall protection. This would only be allowed temporarily for implementation as documented and approved.

....

Allowing Basic authentication to be used for the sole creation of Office 365 DoD tenants.

....

A documented mechanism and or script that can disable Basic authentication once administration completes.

....

Use of a Privileged Access Workstation (PAW) and adherence to the Clean Source principle for administration.

Additional Information:

CCI-000877 Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions.

- NIST SP 800-53::MA-4 c
- NIST SP 800-53 Revision 4::MA-4 c
- NIST SP 800-53 Revision 5::MA-4 c
- NIST SP 800-53A::MA-4.1 (iv)

1.170 WN11-CC-000350 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows Remote Management (WinRM) service must not allow unencrypted traffic.

```
GROUP ID: V-253419
RULE ID: SV-253419r958850
```

Rationale:

Unencrypted remote access to a system can allow sensitive information to be compromised. Windows remote management connections must be encrypted to prevent this.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WinRM\Service\

Value Name: AllowUnencryptedTraffic

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Remote Management (WinRM) >> WinRM Service >> "Allow unencrypted
traffic"
```

to "Disabled".

Additional Information:

CCI-003123 Implement organization-defined cryptographic mechanisms to protect the confidentiality of nonlocal maintenance and diagnostic communications.

- NIST SP 800-53 Revision 4::MA-4 (6)
- NIST SP 800-53 Revision 5::MA-4 (6)

1.171 WN11-CC-000355 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows Remote Management (WinRM) service must not store RunAs credentials.

```
GROUP ID: V-253420
RULE ID: SV-253420r1051055
```

Rationale:

Storage of administrative credentials could allow unauthorized access. Disallowing the storage of RunAs credentials for Windows Remote Management will prevent them from being used with plug-ins.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WinRM\Service\

Value Name: DisableRunAs

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Remote Management (WinRM) >> WinRM Service >> "Disallow WinRM from
storing RunAs credentials"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.172 WN11-CC-000360 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows Remote Management (WinRM) client must not use Digest authentication.

```
GROUP ID: V-253421
RULE ID: SV-253421r958510
```

Rationale:

Digest authentication is not as strong as other options and may be subject to man-in-the-middle attacks.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\WinRM\Client\

Value Name: AllowDigest

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Remote Management (WinRM) >> WinRM Client >> "Disallow Digest
authentication"
```

to "Enabled".

Additional Information:

CCI-000877 Employ strong authentication in the establishment of nonlocal maintenance and diagnostic sessions.

- NIST SP 800-53::MA-4 c
- NIST SP 800-53 Revision 4::MA-4 c
- NIST SP 800-53 Revision 5::MA-4 c
- NIST SP 800-53A::MA-4.1 (iv)

1.173 WN11-CC-000365 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must be configured to prevent Windows apps from being activated by voice while the system is locked.

```
GROUP ID: V-253422
RULE ID: SV-253422r958400
```

Rationale:

Allowing Windows apps to be activated by voice from the lock screen could allow for unauthorized use. Requiring logon will ensure the apps are only used by authorized personnel.

Audit:

The setting is NA when the "Allow voice activation" policy is configured to disallow applications to be activated with voice for all users.

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\Windows\AppPrivacy\



Value Name: LetAppsActivateWithVoiceAboveLock



Type: REG_DWORD

Value: 0x00000002 (2)



If the following registry value exists and is configured as specified,
requirement is NA:
```

Registry Hive: HKEY_LOCAL_MACHINE

Registry Path: \SOFTWARE\Policies\Microsoft\Windows\AppPrivacy\

Value Name: LetAppsActivateWithVoice

Type: REG_DWORD

Value: 0x00000002 (2)

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
App Privacy >> "Let Windows apps activate with voice while the system is
locked"
```

to "Enabled" with Default for all Apps: set to Force Deny.

The requirement is NA if the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
App Privacy >> "Let Windows apps activate with voice"
```

is configured to "Enabled" with Default for all Apps: set to Force Deny.

Additional Information:

CCI-000056 Retain the device lock until the user reestablishes access using established identification and authentication procedures.

- NIST SP 800-53::AC-11 b
- NIST SP 800-53 Revision 4::AC-11 b
- NIST SP 800-53 Revision 5::AC-11 b
- NIST SP 800-53A::AC-11.1 (iii)

1.174 WN11-CC-000370 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The convenience PIN for Windows 11 must be disabled.

```
GROUP ID: V-253423
RULE ID: SV-253423r958478
```

Rationale:

This policy controls whether a domain user can sign in using a convenience PIN to prevent enabling (Password Stuffer).

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \Software\Policies\Microsoft\Windows\System

Value Name: AllowDomainPINLogon
Value Type: REG_DWORD
Value data: 0
```

Remediation:

Disable the convenience PIN sign-in.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Logon >> Set
"Turn on convenience PIN sign-in"
```

to "Disabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.175 WN11-CC-000385 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows Ink Workspace must be configured to disallow access above the lock.

```
GROUP ID: V-253424
RULE ID: SV-253424r958404
```

Rationale:

This action secures Windows Ink, which contains applications and features oriented toward pen computing.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \Software\Policies\Microsoft\WindowsInkWorkspace

Value Name: AllowWindowsInkWorkspace
Value Type: REG_DWORD
Value data: 1
```

Remediation:

Disable the convenience PIN sign-in.

To correct this, configure the policy value for

```
Computer Configuration >> Administrative Templates >> Windows Components >>
Windows Ink Workspace >> Set "Allow Windows Ink Workspace"
```

to "Enabled and set Options "On, but disallow access above lock".

Additional Information:

CCI-000060 Conceal, via the device lock, information previously visible on the display with a publicly viewable image.

- NIST SP 800-53::AC-11 (1)
- NIST SP 800-53 Revision 4::AC-11 (1)
- NIST SP 800-53 Revision 5::AC-11 (1)
- NIST SP 800-53A::AC-11 (1).1

1.176 WN11-CC-000390 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Windows 11 must be configured to prevent users from receiving suggestions for third-party or additional applications.

```
GROUP ID: V-253425
RULE ID: SV-253425r958478
```

Rationale:

Windows spotlight features may suggest apps and content from third-party software publishers in addition to Microsoft apps and content.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_CURRENT_USER
Registry Path: \SOFTWARE\Policies\Microsoft\Windows\CloudContent\

Value Name: DisableThirdPartySuggestions

Type: REG_DWORD
Value: 0x00000001 (1)
```

Remediation:

Configure the policy value for User Configuration >> Administrative Templates. >> Windows Components >> Cloud Content >> "Do not suggest third-party content in Windows spotlight" to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.177 WN11-CC-000391 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Internet Explorer must be disabled for Windows 11.

```
GROUP ID: V-256893
RULE ID: SV-256893r958552
```

Rationale:

Internet Explorer 11 (IE11) is not supported on Windows 11 semi-annual channel.

Audit:

Determine if IE11 is installed or enabled on Windows 11 semi-annual channel.

If IE11 is installed or not disabled on Windows 11 semi-annual channel, this is a finding.

If IE11 is installed on an unsupported operating system and is enabled or installed, this is a finding.

For more information, visit: https://learn.microsoft.com/en-us/lifecycle/faq/internet-explorer-microsoft-edge#what-is-the-lifecycle-policy-for-internet-explorer-

Remediation:

For Windows 11 semi-annual channel, remove or disable the IE11 application.

To disable IE11 as a standalone browser:

Set the policy value for "Computer Configuration/Administrative Templates/Windows Components/Internet Explorer/Disable Internet Explorer 11 as a standalone browser" to "Enabled" with the option value set to "Never".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.178 WN11-EP-000310 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 Kernel (Direct Memory Access) DMA Protection must be enabled.

```
GROUP ID: V-253426
RULE ID: SV-253426r991580
```

Rationale:

Kernel DMA Protection to protect PCs against drive-by Direct Memory Access (DMA) attacks using PCI hot plug devices connected to Thunderbolt 3 ports. Drive-by DMA attacks can lead to disclosure of sensitive information residing on a PC, or even injection of malware that allows attackers to bypass the lock screen or control PCs remotely.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \Software\Policies\Microsoft\Windows\Kernel DMA Protection

Value Name: DeviceEnumerationPolicy
Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Administrative Templates >> System >> Kernel DMA
Protection >> "Enumeration policy for external devices incompatible with
Kernel DMA Protection"
```

to "Enabled" with "Enumeration Policy" set to "Block All".

Additional Information:

CCI-000172 Generate audit records for the event types defined in AU-2 c that include the audit record content defined in AU-3.

- NIST SP 800-53::AU-12 c
- NIST SP 800-53 Revision 4::AU-12 c
- NIST SP 800-53 Revision 5::AU-12 c
- NIST SP 800-53A::AU-12.1 (iv)

1.179 WN11-PK-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The DoD Root CA certificates must be installed in the Trusted Root Store.

```
GROUP ID: V-253427
RULE ID: SV-253427r958448
```

Rationale:

To ensure secure DoD websites and DoD-signed code are properly validated, the system must trust the DoD Root Certificate Authorities (CAs). The DoD root certificates will ensure that the trust chain is established for server certificates issued from the DoD CAs.

Audit:

Verify the DoD Root CA certificates are installed as Trusted Root Certification Authorities.

The certificates and thumbprints referenced below apply to unclassified systems; refer to PKE documentation for other networks.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\root | Where Subject -Like "*DoD*" | FL Subject, Thumbprint, NotAfter

If the following certificate "Subject" and "Thumbprint" information is not displayed, this is a finding.

Subject: CN=DoD Root CA 3, OU=PKI, OU=DoD, O=U.S. Government, C=US

Thumbprint: D73CA91102A2204A36459ED32213B467D7CE97FB

NotAfter: 12/30/2029

Subject: CN=DoD Root CA 4, OU=PKI, OU=DoD, O=U.S. Government, C=US

Thumbprint: B8269F25DBD937ECAFD4C35A9838571723F2D026

NotAfter: 7/25/2032

Subject: CN=DoD Root CA 5, OU=PKI, OU=DoD, O=U.S. Government, C=US

Thumbprint: 4ECB5CC3095670454DA1CBD410FC921F46B8564B

NotAfter: 6/14/2041

Subject: CN=DoD Root CA 6 OU=PKI, OU=DoD, O=U.S. Government, C=US

Thumbprint: D37ECF61C0B4ED88681EF3630C4E2FC787B37AEF

NotAfter: 1/24/2053

Alternately, use the Certificates MMC snap-in:

Run "MMC".

Select "File", "Add/Remove Snap-in".

Select "Certificates", click "Add".

Select "Computer account", click "Next".

Select "Local computer: (the computer this console is running on)", click "Finish".

Click "OK".

Expand "Certificates" and navigate to Trusted Root Certification Authorities >> Certificates.

For each of the DoD Root CA certificates noted below:

Right-click on the certificate and select "Open".

Select the "Details" tab.

Scroll to the bottom and select "Thumbprint".

If the DoD Root CA certificates below are not listed or the value for the "Thumbprint" field is not as noted, this is a finding.

DoD Root CA 3

Thumbprint: D73CA91102A2204A36459ED32213B467D7CE97FB

Valid to: Sunday, December 30, 2029

DoD Root CA 4

Thumbprint: B8269F25DBD937ECAFD4C35A9838571723F2D026

Valid to: Sunday, July 25, 2032

DoD Root CA 5

Thumbprint: 4ECB5CC3095670454DA1CBD410FC921F46B8564B

Valid to: Friday, June 14, 2041

DoD Root CA 6

Thumbprint : D37ECF61C0B4ED88681EF3630C4E2FC787B37AEF

Valid to: Friday, January 24, 2053

Remediation:

Install the DoD Root CA certificates.

DoD Root CA 3

DoD Root CA 4

DoD Root CA 5

DoD Root CA 6

The InstallRoot tool is available on Cyber Exchange at https://cyber.mil/pki-pke/tools-configuration-files. PKI can be found at https://crl.gds.disa.mil/.

Additional Information:

CCI-000185 For public key-based authentication, validate certificates by constructing and verifying a certification path to an accepted trust anchor including checking certificate status information.

- NIST SP 800-53::IA-5 (2)
- NIST SP 800-53 Revision 4::IA-5 (2) (a)
- NIST SP 800-53 Revision 5::IA-5 (2) (b) (1)
- NIST SP 800-53A::IA-5 (2).1

1.180 WN11-PK-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The External Root CA certificates must be installed in the Trusted Root Store on unclassified systems.

```
GROUP ID: V-253428
RULE ID: SV-253428r958448
```

Rationale:

To ensure secure websites protected with External Certificate Authority (ECA) server certificates are properly validated, the system must trust the ECA Root CAs. The ECA root certificates will ensure the trust chain is established for server certificates issued from the External CAs. This requirement only applies to unclassified systems.

Audit:

Verify the ECA Root CA certificates are installed on unclassified systems as Trusted Root Certification Authorities.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\root | Where Subject -Like "*ECA*" | FL Subject, Thumbprint, NotAfter

If the following certificate "Subject" and "Thumbprint" information is not displayed, this is a finding.

Subject: CN=ECA Root CA 4, OU=ECA, O=U.S. Government, C=US

Thumbprint: 73E8BB08E337D6A5A6AEF90CFFDD97D9176CB582

NotAfter: 12/30/2029

Alternately use the Certificates MMC snap-in:

Run "MMC".

Select "File", "Add/Remove Snap-in".

Select "Certificates", click "Add".

Select "Computer account", click "Next".

Select "Local computer: (the computer this console is running on)", click "Finish".

Click "OK".

Expand "Certificates" and navigate to Trusted Root Certification Authorities >> Certificates.

For each of the ECA Root CA certificates noted below:

Right-click on the certificate and select "Open".

Select the "Details" tab.

Scroll to the bottom and select "Thumbprint".

If the ECA Root CA certificates below are not listed or the value for the "Thumbprint" field is not as noted, this is a finding.

ECA Root CA 4

Thumbprint: 73E8BB08E337D6A5A6AEF90CFFDD97D9176CB582

Valid to: Sunday, December 30, 2029

Remediation:

Install the ECA Root CA certificates on unclassified systems.

ECA Root CA 4

The InstallRoot tool is available on Cyber Exchange at https://cyber.mil/pki-pke/tools-configuration-files. PKI can be found at https://crl.gds.disa.mil/.

Additional Information:

CCI-000185 For public key-based authentication, validate certificates by constructing and verifying a certification path to an accepted trust anchor including checking certificate status information.

- NIST SP 800-53::IA-5 (2)
- NIST SP 800-53 Revision 4::IA-5 (2) (a)
- NIST SP 800-53 Revision 5::IA-5 (2) (b) (1)
- NIST SP 800-53A::IA-5 (2).1

1.181 WN11-PK-000015 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The DoD Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unclassified systems.

```
GROUP ID: V-253429
RULE ID: SV-253429r958448
```

Rationale:

To ensure users do not experience denial of service when performing certificate-based authentication to DoD websites due to the system chaining to a root other than DoD Root CAs, the DoD Interoperability Root CA cross-certificates must be installed in the Untrusted Certificate Store. This requirement only applies to unclassified systems.

Audit:

Verify the DoD Interoperability cross-certificates are installed on unclassified systems as Untrusted Certificates.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\disallowed | Where {$*.Issuer -Like "DoD Interoperability" -and $*.Subject -Like "*DoD*"} | FL Subject, Issuer, Thumbprint, NotAfter

If the following certificate "Subject", "Issuer", and "Thumbprint" information is not displayed, this is a finding.

Subject: CN=DoD Root CA 3, OU=PKI, OU=DoD, O=U.S. Government, C=US

Issuer: CN=DoD Interoperability Root CA 2, OU=PKI, OU=DoD, O=U.S. Government, C=US

Thumbprint: 49CBE933151872E17C8EAE7F0ABA97FB610F6477

NotAfter: 11/16/2024

Subject: CN=DoD Root CA 3, OU=PKI, OU=DoD, O=U.S. Government, C=US

Issuer: CN=DoD Interoperability Root CA 2, OU=PKI, OU=DoD, O=U.S. Government, C=US

Thumbprint: AC06108CA348CC03B53795C64BF84403C1DBD341

NotAfter: 1/22/2022

Alternately, use the Certificates MMC snap-in:

Run "MMC".

Select "File", "Add/Remove Snap-in".

Select "Certificates", click "Add".

Select "Computer account", click "Next".

Select "Local computer: (the computer this console is running on)", click "Finish".

Click "OK".

Expand "Certificates" and navigate to Untrusted Certificates >> Certificates.

For each certificate with "DoD Root CA...." under "Issued To" and "DoD Interoperability Root CA...." under "Issued By":

Right-click on the certificate and select "Open".

Select the "Details" tab.

Scroll to the bottom and select "Thumbprint".

If the certificates below are not listed or the value for the "Thumbprint" field is not as noted, this is a finding.

Issued To: DoD Root CA 3

Issued By: Interoperability Root CA 2

Thumbprint : 49CBE933151872E17C8EAE7F0ABA97FB610F6477

Valid to: Saturday, November 16, 2024

Remediation:

Install the DoD Interoperability Root CA cross-certificates on unclassified systems.

Issued To - Issued By - Thumbprint

DoD Root CA 3 - DoD Interoperability Root CA 2 - 49CBE933151872E17C8EAE7F0ABA97FB610F6477

The certificates can be installed using the InstallRoot tool. The tool and user guide are available on Cyber Exchange at https://cyber.mil/pki-pke/tools-configuration-files. Certificate bundles published by the PKI can be found at https://crl.gds.disa.mil/.

Additional Information:

CCI-002470 Only allow the use of organization-defined certificate authorities for verification of the establishment of protected sessions.

- NIST SP 800-53 Revision 4::SC-23 (5)
- NIST SP 800-53 Revision 5::SC-23 (5)

1.182 WN11-PK-000020 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unclassified systems.

```
GROUP ID: V-253430
RULE ID: SV-253430r1081058
```

Rationale:

To ensure users do not experience denial of service when performing certificate-based authentication to DOD websites due to the system chaining to a root other than DOD Root CAs, the US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificate Store. This requirement only applies to unclassified systems.

Audit:

Verify the US DOD CCEB Interoperability Root CA cross-certificate is installed on unclassified systems as an Untrusted Certificate.

Run "PowerShell" as an administrator.

Execute the following command:

Get-ChildItem -Path Cert:Localmachine\disallowed | Where Issuer -Like "*CCEB Interoperability*" | FL Subject, Issuer, Thumbprint, NotAfter

If the following certificate "Subject", "Issuer", and "Thumbprint" information is not displayed, this is a finding.

Subject: CN=DOD Root CA 3, OU=PKI, OU=DOD, O=U.S. Government, C=US

Issuer: CN=US DOD CCEB Interoperability Root CA 2, OU=PKI, OU=DOD, O=U.S. Government, C=US

Thumbprint: 9B74964506C7ED9138070D08D5F8B969866560C8

NotAfter: 7/18/2025 9:56:22 A

Alternately, use the Certificates MMC snap-in:

Run "MMC".

Select "File", then click "Add/Remove Snap-in".

Select "Certificates", then click "Add".

Select "Computer account", then click "Next".

Select "Local computer: (the computer this console is running on)", then click "Finish".

Click "OK".

Expand "Certificates" and navigate to Untrusted Certificates >> Certificates.

For each certificate with "US DOD CCEB Interoperability Root CA..." under "Issued By":

Right-click on the certificate and select "Open".

Select the "Details" tab.

Scroll to the bottom and select "Thumbprint".

If the certificate below is not listed or the value for the "Thumbprint" field is not as noted, this is a finding.

Subject: CN=DOD Root CA 3, OU=PKI, OU=DOD, O=U.S. Government, C=US

Issuer: CN=US DOD CCEB Interoperability Root CA 2, OU=PKI, OU=DOD, O=U.S. Government, C=US

Thumbprint: Thumbprint: 9B74964506C7ED9138070D08D5F8B969866560C8

NotAfter: 7/18/2025 9:56:22 AM

Subject: CN=DOD Root CA 6, OU=PKI, OU=DOD, O=U.S. Government, C=US

Issuer: CN=US DOD CCEB Interoperability Root CA 2, OU=PKI, OU=DOD, O=U.S. Government, C=US

Thumbprint: D471CA32F7A692CE6CBB6196BD3377FE4DBCD106

NotAfter: 7/18/2026 9:56:22 AM

Remediation:

Install the US DOD CCEB Interoperability Root CA cross-certificate on unclassified systems.

Issued To - Issued By - Thumbprint

9B74964506C7ED9138070D08D5F8B969866560C8

NotAfter: 7/18/2025 9:56:22 AM

Issued To: DOD Root CA 6

Issued By: US DOD CCEB Interoperability Root CA 2

Thumbprint: D471CA32F7A692CE6CBB6196BD3377FE4DBCD106

NotAfter: 7/18/2026

The certificates can be installed using the InstallRoot tool. The tool and user guide are available on Cyber Exchange at https://cyber.mil/pki-pke/tools-configuration-files. Certificate bundles published by the PKI can be found at https://crl.gds.disa.mil/.

Additional Information:

CCI-002470 Only allow the use of organization-defined certificate authorities for verification of the establishment of protected sessions.

- NIST SP 800-53 Revision 4::SC-23 (5)
- NIST SP 800-53 Revision 5::SC-23 (5)

1.183 WN11-RG-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Default permissions for the HKEY_LOCAL_MACHINE registry hive must be maintained.

```
GROUP ID: V-253431
RULE ID: SV-253431r958726
```

Rationale:

The registry is integral to the function, security, and stability of the Windows system. Changing the system's registry permissions allows the possibility of unauthorized and anonymous modification to the operating system.

Audit:

Verify the default registry permissions for the keys note below of the HKEY_LOCAL_MACHINE hive.

If any non-privileged groups such as Everyone, Users or Authenticated Users have greater than Read permission, this is a finding.

Run "Regedit".

Right click on the registry areas noted below.

Select "Permissions..." and the "Advanced" button.

HKEY_LOCAL_MACHINE\SECURITY

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

SYSTEM - Full Control - This key and subkeys

Administrators - Special - This key and subkeys

HKEY_LOCAL_MACHINE\SOFTWARE

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

Users - Read - This key and subkeys

Administrators - Full Control - This key and subkeys

SYSTEM - Full Control - This key and subkeys

CREATOR OWNER - Full Control - This key and subkeys

ALL APPLICATION PACKAGES - Read - This key and subkeys

HKEY_LOCAL_MACHINE\SYSTEM

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

Users - Read - This key and subkeys

Administrators - Full Control - This key and subkeys

SYSTEM - Full Control - This key and subkeys

CREATOR OWNER - Full Control - This key and subkeys

ALL APPLICATION PACKAGES - Read - This key and subkeys

Other subkeys under the noted keys may also be sampled. There may be some instances where non-privileged groups have greater than read permission.

Microsoft has given Read permission to the SOFTWARE and SYSTEM registry keys in later versions of Windows 11 to the following SID, this is currently not a finding.

S-1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681

If the defaults have not been changed, these are not a finding.

Remediation:

Maintain the default permissions for the HKEY_LOCAL_MACHINE registry hive.

The default permissions of the higher level keys are noted below.

HKEY_LOCAL_MACHINE\SECURITY

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

SYSTEM - Full Control - This key and subkeys

Administrators - Special - This key and subkeys

HKEY_LOCAL_MACHINE\SOFTWARE

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

Users - Read - This key and subkeys

Administrators - Full Control - This key and subkeys

SYSTEM - Full Control - This key and subkeys

CREATOR OWNER - Full Control - This key and subkeys

ALL APPLICATION PACKAGES - Read - This key and subkeys

HKEY_LOCAL_MACHINE\SYSTEM

Type - "Allow" for all

Inherited from - "None" for all

Principal - Access - Applies to

Users - Read - This key and subkeys

Administrators - Full Control - This key and subkeys

SYSTEM - Full Control - This key and subkeys

CREATOR OWNER - Full Control - This key and subkeys

ALL APPLICATION PACKAGES - Read - This key and subkeys

Microsoft has also given read permission to the SOFTWARE and SYSTEM registry keys in later versions of Windows 11 to the following SID.

S-1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.184 WN11-SO-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The built-in administrator account must be disabled.

```
GROUP ID: V-253432
RULE ID: SV-253432r958482
```

Rationale:

The built-in administrator account is a well-known account subject to attack. It also provides no accountability to individual administrators on a system. It must be disabled to prevent its use.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options.
```

If the value for "Accounts: Administrator account status" is not set to "Disabled", this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Accounts: Administrator account status"
```

to "Disabled".

Additional Information:

CCI-000764 Uniquely identify and authenticate organizational users and associate that unique identification with processes acting on behalf of those users.

- NIST SP 800-53::IA-2
- NIST SP 800-53 Revision 4::IA-2
- NIST SP 800-53 Revision 5::IA-2
- NIST SP 800-53A::IA-2.1

1.185 WN11-SO-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The built-in guest account must be disabled.

```
GROUP ID: V-253433
RULE ID: SV-253433r958504
```

Rationale:

A system faces an increased vulnerability threat if the built-in guest account is not disabled. This account is a known account that exists on all Windows systems and cannot be deleted. This account is initialized during the installation of the operating system with no password assigned.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options.
```

If the value for "Accounts: Guest account status" is not set to "Disabled", this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Accounts: Guest account status"
```

to "Disabled".

Additional Information:

CCI-000804 Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users.

- NIST SP 800-53::IA-8
- NIST SP 800-53 Revision 4::IA-8
- NIST SP 800-53 Revision 5::IA-8
- NIST SP 800-53A::IA-8.1

1.186 WN11-SO-000015 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Local accounts with blank passwords must be restricted to prevent access from the network.

```
GROUP ID: V-253434
RULE ID: SV-253434r991589
```

Rationale:

An account without a password can allow unauthorized access to a system as only the username would be required. Password policies must prevent accounts with blank passwords from existing on a system. However, if a local account with a blank password did exist, enabling this setting will prevent network access, limiting the account to local console logon only.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: LimitBlankPasswordUse

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Accounts: Limit local account use of blank
passwords to console logon only"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.187 WN11-SO-000020 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The built-in administrator account must be renamed.

```
GROUP ID: V-253435
RULE ID: SV-253435r991589
```

Rationale:

The built-in administrator account is a well-known account subject to attack. Renaming this account to an unidentified name improves the protection of this account and the system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options.
```

If the value for "Accounts: Rename administrator account" is set to "Administrator", this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Accounts: Rename administrator account"
```

to a name other than "Administrator".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.188 WN11-SO-000025 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The built-in guest account must be renamed.

```
GROUP ID: V-253436
RULE ID: SV-253436r991589
```

Rationale:

The built-in guest account is a well-known user account on all Windows systems and, as initially installed, does not require a password. This can allow access to system resources by unauthorized users. Renaming this account to an unidentified name improves the protection of this account and the system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options.
```

If the value for "Accounts: Rename guest account" is set to "Guest", this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Accounts: Rename guest account"
```

to a name other than "Guest".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.189 WN11-SO-000030 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Audit policy using subcategories must be enabled.

```
GROUP ID: V-253437
RULE ID: SV-253437r958442
```

Rationale:

Maintaining an audit trail of system activity logs can help identify configuration errors, troubleshoot service disruptions, and analyze compromises that have occurred, as well as detect attacks. Audit logs are necessary to provide a trail of evidence in case the system or network is compromised. Collecting this data is essential for analyzing the security of information assets and detecting signs of suspicious and unexpected behavior. This setting allows administrators to enable more precise auditing capabilities.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: SCENoApplyLegacyAuditPolicy

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Audit: Force audit policy subcategory
settings (Windows Vista or later) to override audit policy category settings"
```

to "Enabled".

Additional Information:

CCI-000169 Provide audit record generation capability for the event types the system is capable of auditing as defined in AU-2 a. on organization-defined information system components.

- NIST SP 800-53::AU-12 a
- NIST SP 800-53 Revision 4::AU-12 a
- NIST SP 800-53 Revision 5::AU-12 a
- NIST SP 800-53A::AU-12.1 (ii)

1.190 WN11-SO-000035 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Outgoing secure channel traffic must be encrypted or signed.

```
GROUP ID: V-253438
RULE ID: SV-253438r958908
```

Rationale:

Requests sent on the secure channel are authenticated, and sensitive information (such as passwords) is encrypted, but not all information is encrypted. If this policy is enabled, outgoing secure channel traffic will be encrypted and signed.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netlogon\Parameters\

Value Name: RequireSignOrSeal

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Domain member: Digitally encrypt or sign
secure channel data (always)"
```

to "Enabled".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

CCI-002421 Implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission.

- NIST SP 800-53 Revision 4::SC-8 (1)
- NIST SP 800-53 Revision 5::SC-8 (1)

1.191 WN11-SO-000040 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Outgoing secure channel traffic must be encrypted.

```
GROUP ID: V-253439
RULE ID: SV-253439r958908
```

Rationale:

Requests sent on the secure channel are authenticated, and sensitive information (such as passwords) is encrypted, but not all information is encrypted. If this policy is enabled, outgoing secure channel traffic will be encrypted.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netlogon\Parameters\

Value Name: SealSecureChannel

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Domain member: Digitally encrypt secure
channel data (when possible)"
```

to "Enabled".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

CCI-002421 Implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission.

- NIST SP 800-53 Revision 4::SC-8 (1)
- NIST SP 800-53 Revision 5::SC-8 (1)

1.192 WN11-SO-000045 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Outgoing secure channel traffic must be signed.

```
GROUP ID: V-253440
RULE ID: SV-253440r958908
```

Rationale:

Requests sent on the secure channel are authenticated, and sensitive information (such as passwords) is encrypted, but the channel is not integrity checked. If this policy is enabled, outgoing secure channel traffic will be signed.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netlogon\Parameters\

Value Name: SignSecureChannel

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Domain member: Digitally sign secure channel
data (when possible)"
```

to "Enabled".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

CCI-002421 Implement cryptographic mechanisms to prevent unauthorized disclosure of information and/or detect changes to information during transmission.

- NIST SP 800-53 Revision 4::SC-8 (1)
- NIST SP 800-53 Revision 5::SC-8 (1)

1.193 WN11-SO-000050 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The computer account password must not be prevented from being reset.

```
GROUP ID: V-253441
RULE ID: SV-253441r991589
```

Rationale:

Computer account passwords are changed automatically on a regular basis. Disabling automatic password changes can make the system more vulnerable to malicious access. Frequent password changes can be a significant safeguard for the system. A new password for the computer account will be generated every 30 days.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netlogon\Parameters\

Value Name: DisablePasswordChange

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Domain member: Disable machine account
password changes"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.194 WN11-SO-000055 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The maximum age for machine account passwords must be configured to 30 days or less.

```
GROUP ID: V-253442
RULE ID: SV-253442r991589
```

Rationale:

Computer account passwords are changed automatically on a regular basis. This setting controls the maximum password age that a machine account may have. This setting must be set to no more than 30 days, ensuring the machine changes its password monthly.

Audit:

(remove)This is the default configuration for this setting (30 days).

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netlogon\Parameters\

Value Name: MaximumPasswordAge

Value Type: REG_DWORD
Value: 0x0000001e (30) (or less, excluding 0)
```

Remediation:

This is the default configuration for this setting (30 days).

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Domain member: Maximum machine account
password age"
```

to "30" or less (excluding 0 which is unacceptable).

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.195 WN11-SO-000060 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to require a strong session key.

```
GROUP ID: V-253443
RULE ID: SV-253443r958908
```

Rationale:

A computer connecting to a domain controller will establish a secure channel. Requiring strong session keys enforces 128-bit encryption between systems.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\Netlogon\Parameters\

Value Name: RequireStrongKey

Value Type: REG_DWORD
Value: 1
```

Warning: This setting may prevent a system from being joined to a domain if not configured consistently between systems.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Domain member: Require strong (Windows 2000
or Later) session key"
```

to "Enabled".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

1.196 WN11-SO-000070 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The machine inactivity limit must be set to 15 minutes, locking the system with the screensaver.

```
GROUP ID: V-253444
RULE ID: SV-253444r958636
```

Rationale:

Unattended systems are susceptible to unauthorized use and must be locked when unattended. The screen saver must be set at a maximum of 15 minutes and be password protected. This protects critical and sensitive data from exposure to unauthorized personnel with physical access to the computer.

Satisfies: SRG-OS-000279-GPOS-00109, SRG-OS-000163-GPOS-00072

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: InactivityTimeoutSecs

Value Type: REG_DWORD
Value: 0x00000384 (900) (or less, excluding "0" which is effectively
disabled)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Interactive logon: Machine inactivity limit"
```

to "900" seconds" or less, excluding "0" which is effectively disabled.

Additional Information:

CCI-001133 Terminate the network connection associated with a communications session at the end of the session or after an organization-defined time period of inactivity.

- NIST SP 800-53::SC-10
- NIST SP 800-53 Revision 4::SC-10
- NIST SP 800-53 Revision 5::SC-10
- NIST SP 800-53A::SC-10.1 (ii)

CCI-002361 Automatically terminate a user session after organization-defined conditions or trigger events requiring session disconnect.

- NIST SP 800-53 Revision 4::AC-12
- NIST SP 800-53 Revision 5::AC-12

1.197 WN11-SO-000075 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The required legal notice must be configured to display before console logon.

```
GROUP ID: V-253445
RULE ID: SV-253445r958392
```

Rationale:

Failure to display the logon banner prior to a logon attempt will negate legal proceedings resulting from unauthorized access to system resources.

Satisfies: SRG-OS-000024-GPOS-00007, SRG-OS-000228-GPOS-00088, SRG-OS-000024-GPOS-00007

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: LegalNoticeText

Value Type: REG_SZ
Value:
```

You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only.

By using this IS (which includes any device attached to this IS), you consent to the following conditions:

-The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

-At any time, the USG may inspect and seize data stored on this IS.

-Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

-This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Interactive logon: Message text for users
attempting to log on"
```

to the following.

You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only.

By using this IS (which includes any device attached to this IS), you consent to the following conditions:

-The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

-At any time, the USG may inspect and seize data stored on this IS.

-Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

-This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

-Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details.

Additional Information:

CCI-000044 Enforce the organization-defined limit of consecutive invalid logon attempts by a user during the organization-defined time period.

- NIST SP 800-53::AC-7 a
- NIST SP 800-53 Revision 4::AC-7 a
- NIST SP 800-53 Revision 5::AC-7 a
- NIST SP 800-53A::AC-7.1 (ii)

CCI-000048 Display an organization-defined system use notification message or banner to users before granting access to the system that provides privacy and security notices consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidelines.

- NIST SP 800-53::AC-8 a
- NIST SP 800-53 Revision 4::AC-8 a
- NIST SP 800-53 Revision 5::AC-8 a
- NIST SP 800-53A::AC-8.1 (ii)

CCI-000050 Retain the notification message or banner on the screen until users acknowledge the usage conditions and take explicit actions to log on to or further access the system.

- NIST SP 800-53::AC-8 b
- NIST SP 800-53 Revision 4::AC-8 b
- NIST SP 800-53 Revision 5::AC-8 b
- NIST SP 800-53A::AC-8.1 (iii)

1.198 WN11-SO-000080 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The Windows message title for the legal notice must be configured.

```
GROUP ID: V-253446
RULE ID: SV-253446r958586
```

Rationale:

Failure to display the logon banner prior to a logon attempt will negate legal proceedings resulting from unauthorized access to system resources.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: LegalNoticeCaption

Value Type: REG_SZ
Value: See message title above
```

"DoD Notice and Consent Banner", "US Department of Defense Warning Statement" or a site-defined equivalent, this is a finding.

If a site-defined title is used, it can in no case contravene or modify the language of the banner text required in WN11-SO-000075.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Interactive logon: Message title for users
attempting to log on"
```

to "DoD Notice and Consent Banner", "US Department of Defense Warning Statement", or a site-defined equivalent.

If a site-defined title is used, it can in no case contravene or modify the language of the banner text required in WN11-SO-000075.

Additional Information:

CCI-000048 Display an organization-defined system use notification message or banner to users before granting access to the system that provides privacy and security notices consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidelines.

- NIST SP 800-53::AC-8 a
- NIST SP 800-53 Revision 4::AC-8 a
- NIST SP 800-53 Revision 5::AC-8 a
- NIST SP 800-53A::AC-8.1 (ii)

CCI-001384 For publicly accessible systems, display system use information with organization-defined conditions before granting further access to the publicly accessible system.

- NIST SP 800-53::AC-8 c
- NIST SP 800-53 Revision 4::AC-8 c 1
- NIST SP 800-53 Revision 5::AC-8 c 1
- NIST SP 800-53A::AC-8.2 (i)

CCI-001385 For publicly accessible systems, displays references, if any, to monitoring that are consistent with privacy accommodations for such systems that generally prohibit those activities.

- NIST SP 800-53::AC-8 c
- NIST SP 800-53 Revision 4::AC-8 c 2
- NIST SP 800-53 Revision 5::AC-8 c 2
- NIST SP 800-53A::AC-8.2 (ii)

CCI-001386 For publicly accessible systems, displays references, if any, to recording that are consistent with privacy accommodations for such systems that generally prohibit those activities.

- NIST SP 800-53::AC-8 c
- NIST SP 800-53 Revision 4::AC-8 c 2
- NIST SP 800-53 Revision 5::AC-8 c 2
- NIST SP 800-53A::AC-8.2 (ii)

CCI-001387 For publicly accessible systems, displays references, if any, to auditing that are consistent with privacy accommodations for such systems that generally prohibit those activities.

- NIST SP 800-53::AC-8 c
- NIST SP 800-53 Revision 4::AC-8 c 2
- NIST SP 800-53 Revision 5::AC-8 c 2
- NIST SP 800-53A::AC-8.2 (ii)

CCI-001388 For publicly accessible systems, includes a description of the authorized uses of the system.

- NIST SP 800-53::AC-8 c
- NIST SP 800-53 Revision 4::AC-8 c 3
- NIST SP 800-53 Revision 5::AC-8 c 3
- NIST SP 800-53A::AC-8.2 (iii)

1.199 WN11-SO-000085 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Caching of logon credentials must be limited.

```
GROUP ID: V-253447
RULE ID: SV-253447r991589
```

Rationale:

The default Windows configuration caches the last logon credentials for users who log on interactively to a system. This feature is provided for system availability reasons, such as the user's machine being disconnected from the network or domain controllers being unavailable. Even though the credential cache is well-protected, if a system is attacked, an unauthorized individual may isolate the password to a domain user account using a password-cracking program and gain access to the domain.

Audit:

This is the default configuration for this setting (10 logons to cache).

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\

Value Name: CachedLogonsCount

Value Type: REG_SZ
Value: 10 (or less)
```

This setting only applies to domain-joined systems, however, it is configured by default on all systems.

Remediation:

This is the default configuration for this setting (10 logons to cache).

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Interactive logon: Number of previous logons
to cache (in case domain controller is not available)"
```

to "10" logons or less.

This setting only applies to domain-joined systems, however, it is configured by default on all systems.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.200 WN11-SO-000095 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Smart Card removal option must be configured to Force Logoff or Lock Workstation.

```
GROUP ID: V-253448
RULE ID: SV-253448r991589
```

Rationale:

Unattended systems are susceptible to unauthorized use and must be locked. Configuring a system to lock when a smart card is removed will ensure the system is inaccessible when unattended.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\

Value Name: SCRemoveOption

Value Type: REG_SZ
Value: 1 (Lock Workstation) or 2 (Force Logoff)
```

This can be left not configured or set to "No action" on workstations with the following conditions. This must be documented with the ISSO.

-The setting cannot be configured due to mission needs, or because it interferes with applications.

-Policy must be in place that users manually lock workstations when leaving them unattended.

-The screen saver is properly configured to lock as required.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Interactive logon: Smart card removal
behavior"
```

to "Lock Workstation" or "Force Logoff".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.201 WN11-SO-000100 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows SMB client must be configured to always perform SMB packet signing.

```
GROUP ID: V-253449
RULE ID: SV-253449r958908
```

Rationale:

The server message block (SMB) protocol provides the basis for many network operations. Digitally signed SMB packets aid in preventing man-in-the-middle attacks. If this policy is enabled, the SMB client will only communicate with an SMB server that performs SMB packet signing.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters\

Value Name: RequireSecuritySignature

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Microsoft network client: Digitally sign
communications (always)"
```

to "Enabled".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

1.202 WN11-SO-000110 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Unencrypted passwords must not be sent to third-party SMB Servers.

```
GROUP ID: V-253450
RULE ID: SV-253450r987796
```

Rationale:

Some non-Microsoft SMB servers only support unencrypted (plain text) password authentication. Sending plain text passwords across the network, when authenticating to an SMB server, reduces the overall security of the environment. Check with the vendor of the SMB server to see if there is a way to support encrypted password authentication.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters\

Value Name: EnablePlainTextPassword

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Microsoft network client: Send unencrypted
password to third-party SMB servers"
```

to "Disabled".

Additional Information:

CCI-000197 For password-based authentication, transmit passwords only cryptographically-protected channels.

- NIST SP 800-53::IA-5 (1) (c)
- NIST SP 800-53 Revision 4::IA-5 (1) (c)
- NIST SP 800-53 Revision 5::IA-5 (1) (c)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.203 WN11-SO-000120 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The Windows SMB server must be configured to always perform SMB packet signing.

```
GROUP ID: V-253451
RULE ID: SV-253451r958908
```

Rationale:

The server message block (SMB) protocol provides the basis for many network operations. Digitally signed SMB packets aid in preventing man-in-the-middle attacks. If this policy is enabled, the SMB server will only communicate with an SMB client that performs SMB packet signing.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\LanManServer\Parameters\

Value Name: RequireSecuritySignature

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Microsoft network server: Digitally sign
communications (always)"
```

to "Enabled".

Additional Information:

CCI-002418 Protect the confidentiality and/or integrity of transmitted information.

- NIST SP 800-53 Revision 4::SC-8
- NIST SP 800-53 Revision 5::SC-8

1.204 WN11-SO-000140 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Anonymous SID/Name translation must not be allowed.

```
GROUP ID: V-253452
RULE ID: SV-253452r991589
```

Rationale:

Allowing anonymous SID/Name translation can provide sensitive information for accessing a system. Only authorized users must be able to perform such translations.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options.
```

If the value for "Network access: Allow anonymous SID/Name translation" is not set to "Disabled", this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network access: Allow anonymous SID/Name
translation"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.205 WN11-SO-000145 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Anonymous enumeration of SAM accounts must not be allowed.

```
GROUP ID: V-253453
RULE ID: SV-253453r991589
```

Rationale:

Anonymous enumeration of SAM accounts allows anonymous log on users (null session connections) to list all accounts names, thus providing a list of potential points to attack the system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: RestrictAnonymousSAM

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network access: Do not allow anonymous
enumeration of SAM accounts"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.206 WN11-SO-000150 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Anonymous enumeration of shares must be restricted.

```
GROUP ID: V-253454
RULE ID: SV-253454r958524
```

Rationale:

Allowing anonymous logon users (null session connections) to list all account names and enumerate all shared resources can provide a map of potential points to attack the system.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: RestrictAnonymous

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network access: Do not allow anonymous
enumeration of SAM accounts and shares"
```

to "Enabled".

Additional Information:

CCI-001090 Prevent unauthorized and unintended information transfer via shared system resources.

- NIST SP 800-53::SC-4
- NIST SP 800-53 Revision 4::SC-4
- NIST SP 800-53 Revision 5::SC-4
- NIST SP 800-53A::SC-4.1

1.207 WN11-SO-000160 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to prevent anonymous users from having the same rights as the Everyone group.

```
GROUP ID: V-253455
RULE ID: SV-253455r991589
```

Rationale:

Access by anonymous users must be restricted. If this setting is enabled, then anonymous users have the same rights and permissions as the built-in Everyone group. Anonymous users must not have these permissions or rights.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: EveryoneIncludesAnonymous

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network access: Let Everyone permissions
apply to anonymous users"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.208 WN11-SO-000165 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

Anonymous access to Named Pipes and Shares must be restricted.

```
GROUP ID: V-253456
RULE ID: SV-253456r958524
```

Rationale:

Allowing anonymous access to named pipes or shares provides the potential for unauthorized system access. This setting restricts access to those defined in "Network access: Named Pipes that can be accessed anonymously" and "Network access: Shares that can be accessed anonymously", both of which must be blank under other requirements.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\LanManServer\Parameters\

Value Name: RestrictNullSessAccess

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network access: Restrict anonymous access to
Named Pipes and Shares"
```

to "Enabled".

Additional Information:

CCI-001090 Prevent unauthorized and unintended information transfer via shared system resources.

- NIST SP 800-53::SC-4
- NIST SP 800-53 Revision 4::SC-4
- NIST SP 800-53 Revision 5::SC-4
- NIST SP 800-53A::SC-4.1

1.209 WN11-SO-000167 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Remote calls to the Security Account Manager (SAM) must be restricted to Administrators.

```
GROUP ID: V-253457
RULE ID: SV-253457r1081060
```

Rationale:

The Windows SAM stores users' passwords. Restricting remote rpc connections to the SAM to Administrators helps protect those credentials.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: RestrictRemoteSAM

Value Type: REG_SZ
Value: O:BAG:BAD:(A;;RC;;;BA)
```

If a domain application account such as for a management tool requires this user right, this would not be a finding.

Vendor documentation must support the requirement for having the user right.

The requirement must be documented with the ISSO.

Remediation:

Navigate to the policy

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network access: Restrict clients allowed to
make remote calls to SAM"
```

.

Select "Edit Security" to configure the "Security descriptor:".

Add "Administrators" in "Group or user names:" if it is not already listed (this is the default).

Select "Administrators" in "Group or user names:".

Select "Allow" for "Remote Access" in "Permissions for "Administrators".

Click "OK".

The "Security descriptor:" must be populated with "O:BAG:BAD:(A;;RC;;;BA) for the policy to be enforced.

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.210 WN11-SO-000180 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

NTLM must be prevented from falling back to a Null session.

```
GROUP ID: V-253458
RULE ID: SV-253458r991589
```

Rationale:

NTLM sessions that are allowed to fall back to Null (unauthenticated) sessions may gain unauthorized access.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\LSA\MSV1_0\

Value Name: allownullsessionfallback

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: Allow LocalSystem NULL
session fallback"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.211 WN11-SO-000185 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

PKU2U authentication using online identities must be prevented.

```
GROUP ID: V-253459
RULE ID: SV-253459r991589
```

Rationale:

PKU2U is a peer-to-peer authentication protocol. This setting prevents online identities from authenticating to domain-joined systems. Authentication will be centrally managed with Windows user accounts.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\LSA\pku2u\

Value Name: AllowOnlineID

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: Allow PKU2U authentication
requests to this computer to use online identities"
```

to "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.212 WN11-SO-000190 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Kerberos encryption types must be configured to prevent the use of DES and RC4 encryption suites.

```
GROUP ID: V-253460
RULE ID: SV-253460r971535
```

Rationale:

Certain encryption types are no longer considered secure. This setting configures a minimum encryption type for Kerberos, preventing the use of the DES and RC4 encryption suites.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path:
\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Kerberos\Parameter
s\

Value Name: SupportedEncryptionTypes

Value Type: REG_DWORD
Value: 0x7ffffff8 (2147483640)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: Configure encryption types
allowed for Kerberos"
```

to "Enabled" with only the following selected:

AES128_HMAC_SHA1

AES256_HMAC_SHA1

Future encryption types

Additional Information:

CCI-000803 Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, Executive Orders, directives, policies, regulations, standards, and guidance for such authentication.

- NIST SP 800-53::IA-7
- NIST SP 800-53 Revision 4::IA-7
- NIST SP 800-53 Revision 5::IA-7
- NIST SP 800-53A::IA-7.1

1.213 WN11-SO-000195 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The system must be configured to prevent the storage of the LAN Manager hash of passwords.

```
GROUP ID: V-253461
RULE ID: SV-253461r1051056
```

Rationale:

The LAN Manager hash uses a weak encryption algorithm and there are several tools available that use this hash to retrieve account passwords. This setting controls whether or not a LAN Manager hash of the password is stored in the SAM the next time the password is changed.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: NoLMHash

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: Do not store LAN Manager
hash value on next password change"
```

to "Enabled".

Additional Information:

CCI-004062 For password-based authentication, store passwords using an approved salted key derivation function, preferably using a keyed hash.

- NIST SP 800-53 Revision 5::IA-5 (1) (d)

CCI-000196 The information system, for password-based authentication, stores only cryptographically-protected passwords.

- NIST SP 800-53::IA-5 (1) (c)
- NIST SP 800-53 Revision 4::IA-5 (1) (c)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.214 WN11-SO-000205 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The LanMan authentication level must be set to send NTLMv2 response only, and to refuse LM and NTLM.

```
GROUP ID: V-253462
RULE ID: SV-253462r991589
```

Rationale:

The Kerberos v5 authentication protocol is the default for authentication of users who are logging on to domain accounts. NTLM, which is less secure, is retained in later Windows versions for compatibility with clients and servers that are running earlier versions of Windows or applications that still use it. It is also used to authenticate logons to stand-alone computers that are running later versions.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\

Value Name: LmCompatibilityLevel

Value Type: REG_DWORD
Value: 5
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: LAN Manager authentication
level"
```

to "Send NTLMv2 response only. Refuse LM & NTLM".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.215 WN11-SO-000210 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to the required LDAP client signing level.

```
GROUP ID: V-253463
RULE ID: SV-253463r991589
```

Rationale:

This setting controls the signing requirements for LDAP clients. This setting must be set to Negotiate signing or Require signing, depending on the environment and type of LDAP server in use.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Services\LDAP\

Value Name: LDAPClientIntegrity

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: LDAP client signing
requirements"
```

to "Negotiate signing" at a minimum.

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.216 WN11-SO-000215 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to meet the minimum session security requirement for NTLM SSP based clients.

```
GROUP ID: V-253464
RULE ID: SV-253464r991589
```

Rationale:

Microsoft has implemented a variety of security support providers for use with RPC sessions. All of the options must be enabled to ensure the maximum security level.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0\

Value Name: NTLMMinClientSec

Value Type: REG_DWORD
Value: 0x20080000 (537395200)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: Minimum session security
for NTLM SSP based (including secure RPC) clients"
```

to "Require NTLMv2 session security" and "Require 128-bit encryption" (all options selected).

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.217 WN11-SO-000220 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to meet the minimum session security requirement for NTLM SSP based servers.

```
GROUP ID: V-253465
RULE ID: SV-253465r991589
```

Rationale:

Microsoft has implemented a variety of security support providers for use with RPC sessions. All of the options must be enabled to ensure the maximum security level.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0\

Value Name: NTLMMinServerSec

Value Type: REG_DWORD
Value: 0x20080000 (537395200)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "Network security: Minimum session security
for NTLM SSP based (including secure RPC) servers"
```

to "Require NTLMv2 session security" and "Require 128-bit encryption" (all options selected).

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.218 WN11-SO-000230 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The system must be configured to use FIPS-compliant algorithms for encryption, hashing, and signing.

```
GROUP ID: V-253466
RULE ID: SV-253466r959006
```

Rationale:

This setting ensures that the system uses algorithms that are FIPS-compliant for encryption, hashing, and signing. FIPS-compliant algorithms meet specific standards established by the U.S. Government and must be the algorithms used for all OS encryption functions.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Lsa\FIPSAlgorithmPolicy\

Value Name: Enabled

Value Type: REG_DWORD
Value: 1
```

Warning: Clients with this setting enabled will not be able to communicate via digitally encrypted or signed protocols with servers that do not support these algorithms.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "System cryptography: Use FIPS compliant
algorithms for encryption, hashing, and signing"
```

to "Enabled".

Additional Information:

CCI-002450 Implement organization-defined types of cryptography for each specified cryptography use.

- NIST SP 800-53 Revision 4::SC-13
- NIST SP 800-53 Revision 5::SC-13 b

1.219 WN11-SO-000240 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

The default permissions of global system objects must be increased.

```
GROUP ID: V-253467
RULE ID: SV-253467r991589
```

Rationale:

Windows systems maintain a global list of shared system resources such as DOS device names, mutexes, and semaphores. Each type of object is created with a default DACL that specifies who can access the objects with what permissions. If this policy is enabled, the default DACL is stronger, allowing non-admin users to read shared objects, but not modify shared objects that they did not create.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SYSTEM\CurrentControlSet\Control\Session Manager\

Value Name: ProtectionMode

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "System objects: Strengthen default
permissions of internal system objects (e.g. Symbolic links)"
```

to "Enabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.220 WN11-SO-000245 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control approval mode for the built-in Administrator must be enabled.

```
GROUP ID: V-253468
RULE ID: SV-253468r1051057
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. This setting configures the built-in Administrator account so that it runs in Admin Approval Mode.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: FilterAdministratorToken

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Admin Approval Mode
for the Built-in Administrator account"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.221 WN11-SO-000250 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control must prompt administrators for consent on the secure desktop.

```
GROUP ID: V-253469
RULE ID: SV-253469r958518
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. This setting configures the elevation requirements for logged on administrators to complete a task that requires raised privileges.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: ConsentPromptBehaviorAdmin

Value Type: REG_DWORD
Value: 2 (Prompt for consent on the secure desktop)
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Behavior of the
elevation prompt for administrators in Admin Approval Mode"
```

to "Prompt for consent on the secure desktop".

Additional Information:

CCI-001084 Isolate security functions from nonsecurity functions.

- NIST SP 800-53::SC-3
- NIST SP 800-53 Revision 4::SC-3
- NIST SP 800-53 Revision 5::SC-3
- NIST SP 800-53A::SC-3.1 (ii)

1.222 WN11-SO-000251 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Windows 11 must use multifactor authentication for local and network access to privileged and nonprivileged accounts.

```
GROUP ID: V-253470
RULE ID: SV-253470r958484
```

Rationale:

Without the use of multifactor authentication, the ease of access to privileged and nonprivileged functions is greatly increased.

All domain accounts must be enabled for multifactor authentication with the exception of local emergency accounts.

Multifactor authentication requires using two or more factors to achieve authentication.

Factors include:

1. Something a user knows (e.g., password/PIN);
2. Something a user has (e.g., cryptographic identification device, token); and
3. Something a user is (e.g., biometric).

A privileged account is defined as an information system account with authorizations of a privileged user.

Network access is defined as access to an information system by a user (or a process acting on behalf of a user) communicating through a network (e.g., local area network, wide area network, or the internet).

Local access is defined as access to an organizational information system by a user (or process acting on behalf of a user) communicating through a direct connection without the use of a network.

The DoD CAC with DoD-approved PKI is an example of multifactor authentication.

Satisfies: SRG-OS-000106-GPOS-00053, SRG-OS-000107-GPOS-00054, SRG-OS-000108-GPOS-00055

Audit:

If the system is not a member of a domain, this is Not Applicable.

If one of the following settings does not exist and is not populated, this is a finding:

\HKLM\SOFTWARE\Microsoft\Cryptography\Calais\Readers

\HKLM\SOFTWARE\Microsoft\Cryptography\Calais\SmartCards

Remediation:

For nondomain joined systems, configuring Windows Hello for sign-on options would be suggested based on the organization's needs and capabilities.

Additional Information:

CCI-000765 Implement multifactor authentication for network access to privileged accounts.

- NIST SP 800-53::IA-2 (1)
- NIST SP 800-53 Revision 4::IA-2 (1)
- NIST SP 800-53 Revision 5::IA-2 (1)
- NIST SP 800-53A::IA-2 (1).1

1.223 WN11-SO-000255 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control must automatically deny elevation requests for standard users.

```
GROUP ID: V-253471
RULE ID: SV-253471r1051058
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. Denying elevation requests from standard user accounts requires tasks that need elevation to be initiated by accounts with administrative privileges. This ensures correct accounts are used on the system for privileged tasks to help mitigate credential theft.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: ConsentPromptBehaviorUser

Value Type: REG_DWORD
Value: 0
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Behavior of the
elevation prompt for standard users"
```

to "Automatically deny elevation requests".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.224 WN11-SO-000260 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control must be configured to detect application installations and prompt for elevation.

```
GROUP ID: V-253472
RULE ID: SV-253472r958518
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. This setting requires Windows to respond to application installation requests by prompting for credentials.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: EnableInstallerDetection

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Detect application
installations and prompt for elevation"
```

to "Enabled".

Additional Information:

CCI-001084 Isolate security functions from nonsecurity functions.

- NIST SP 800-53::SC-3
- NIST SP 800-53 Revision 4::SC-3
- NIST SP 800-53 Revision 5::SC-3
- NIST SP 800-53A::SC-3.1 (ii)

1.225 WN11-SO-000265 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control must only elevate UIAccess applications that are installed in secure locations.

```
GROUP ID: V-253473
RULE ID: SV-253473r958518
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. This setting configures Windows to only allow applications installed in a secure location on the file system, such as the Program Files or the Windows\System32 folders, to run with elevated privileges.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: EnableSecureUIAPaths

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Only elevate UIAccess
applications that are installed in secure locations"
```

to "Enabled".

Additional Information:

CCI-001084 Isolate security functions from nonsecurity functions.

- NIST SP 800-53::SC-3
- NIST SP 800-53 Revision 4::SC-3
- NIST SP 800-53 Revision 5::SC-3
- NIST SP 800-53A::SC-3.1 (ii)

1.226 WN11-SO-000270 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control must run all administrators in Admin Approval Mode, enabling UAC.

```
GROUP ID: V-253474
RULE ID: SV-253474r1051059
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. This setting enables UAC.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: EnableLUA

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Run all administrators
in Admin Approval Mode"
```

to "Enabled".

Additional Information:

CCI-002038 The organization requires users to reauthenticate upon organization-defined circumstances or situations requiring reauthentication.

- NIST SP 800-53 Revision 4::IA-11

1.227 WN11-SO-000275 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

User Account Control must virtualize file and registry write failures to per-user locations.

```
GROUP ID: V-253475
RULE ID: SV-253475r958518
```

Rationale:

User Account Control (UAC) is a security mechanism for limiting the elevation of privileges, including administrative accounts, unless authorized. This setting configures non-UAC compliant applications to run in virtualized file and registry entries in per-user locations, allowing them to run.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_LOCAL_MACHINE
Registry Path: \SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\

Value Name: EnableVirtualization

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> Security Options >> "User Account Control: Virtualize file and
registry write failures to per-user locations"
```

to "Enabled".

Additional Information:

CCI-001084 Isolate security functions from nonsecurity functions.

- NIST SP 800-53::SC-3
- NIST SP 800-53 Revision 4::SC-3
- NIST SP 800-53 Revision 5::SC-3
- NIST SP 800-53A::SC-3.1 (ii)

1.228 WN11-SO-000280 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Passwords for enabled local Administrator accounts must be changed at least every 60 days.

```
GROUP ID: V-253476
RULE ID: SV-253476r1051060
```

Rationale:

The longer a password is in use, the greater the opportunity for someone to gain unauthorized knowledge of the password. A local Administrator account is not generally used and its password may not be changed as frequently as necessary. Changing the password for enabled Administrator accounts on a regular basis will limit its exposure.

Windows LAPS must be used to change the built-in Administrator account password.

Audit:

If there are no enabled local Administrator accounts, this is Not Applicable.

Review the password last set date for the enabled local Administrator account.

On the standalone or domain-joined workstation:

Open "PowerShell".

Enter

```
"Get-LocalUser -Name * | Select-Object *".
```

If the "PasswordLastSet" date is greater than "60" days old for the local Administrator account for administering the computer/domain, this is a finding.

Verify LAPS is configured and operational.

Navigate to Local Computer Policy >>

```
Computer Configuration >> Administrative Templates >> System >> LAPS >>
Password Settings >> Set to enabled. Password Complexity, large letters +
small letters + numbers + special, Password Length 14, Password Age 60. If
not configured as shown, this is a finding.
```

Verify LAPS Operational logs >> Event Viewer >> Applications and Services Logs >> Microsoft >> Windows >> LAPS >> Operational. Verify LAPS policy process is completing. If it is not, this is a finding.

Remediation:

Change the enabled local Administrator account password at least every 60 days.

Windows LAPS must be used to change the built-in Administrator account password. Domain-joined and nondomain-joined systems can configure this to occur more frequently. LAPS will change the password every 30 days by default.

More information is available at:

https://techcommunity.microsoft.com/t5/windows-it-pro-blog/by-popular-demand-windows-laps-available-now/ba-p/3788747

https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-overview#windows-laps-supported-platforms-and-azure-ad-laps-preview-status

Additional Information:

CCI-004066 For password-based authentication, enforce organization-defined composition and complexity rules.

- NIST SP 800-53 Revision 5::IA-5 (1) (h)

CCI-000199 The information system enforces maximum password lifetime restrictions.

- NIST SP 800-53::IA-5 (1) (d)
- NIST SP 800-53 Revision 4::IA-5 (1) (d)
- NIST SP 800-53A::IA-5 (1).1 (v)

1.229 WN11-UC-000015 (Manual)

Profile Applicability:

- SEVERITY: CAT III

Description:

Toast notifications to the lock screen must be turned off.

```
GROUP ID: V-253477
RULE ID: SV-253477r958478
```

Rationale:

Toast notifications that are displayed on the lock screen could display sensitive information to unauthorized personnel. Turning off this feature will limit access to the information to a logged on user.

Audit:

If the following registry value does not exist or is not configured as specified, this is a finding:

```
Registry Hive: HKEY_CURRENT_USER
Registry Path:
\SOFTWARE\Policies\Microsoft\Windows\CurrentVersion\PushNotifications\

Value Name: NoToastApplicationNotificationOnLockScreen

Value Type: REG_DWORD
Value: 1
```

Remediation:

Configure the policy value for User Configuration >> Administrative Templates >> Start Menu and Taskbar >> Notifications >> "Turn off toast notifications on the lock screen" to "Enabled".

Additional Information:

CCI-000381 Configure the system to provide only organization-defined mission essential capabilities.

- NIST SP 800-53::CM-7
- NIST SP 800-53 Revision 4::CM-7 a
- NIST SP 800-53 Revision 5::CM-7 a
- NIST SP 800-53A::CM-7.1 (ii)

1.230 WN11-UR-000005 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Access Credential Manager as a trusted caller" user right must not be assigned to any groups or accounts.

```
GROUP ID: V-253479
RULE ID: SV-253479r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Access Credential Manager as a trusted caller" user right may be able to retrieve the credentials of other accounts from Credential Manager.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts are granted the "Access Credential Manager as a trusted caller" user right, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Access Credential Manager as a trusted
caller"
```

to be defined but containing no entries (blank).

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.231 WN11-UC-000020 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

Zone information must be preserved when saving attachments.

```
GROUP ID: V-253478
RULE ID: SV-253478r991589
```

Rationale:

Preserving zone of origin (internet, intranet, local, restricted) information on file attachments allows Windows to determine risk.

Audit:

The default behavior is for Windows to mark file attachments with their zone information.

If it exists and is configured with a value of "1", this is a finding.

```
Registry Hive: HKEY_CURRENT_USER
Registry Path:
\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Attachments\

Value Name: SaveZoneInformation

Value Type: REG_DWORD
Value: 0x00000002 (2) (or if the Value Name does not exist)
```

Remediation:

The default behavior is for Windows to mark file attachments with their zone information.

To correct this, configure the policy value for User Configuration >> Administrative Templates >> Windows Components >> Attachment Manager >> "Do not preserve zone information in file attachments" to "Not Configured" or "Disabled".

Additional Information:

CCI-000366 Implement the security configuration settings.

- NIST SP 800-53::CM-6 b
- NIST SP 800-53 Revision 4::CM-6 b
- NIST SP 800-53 Revision 5::CM-6 b
- NIST SP 800-53A::CM-6.1 (iv)

1.232 WN11-UR-000010 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Access this computer from the network" user right must only be assigned to the Administrators and Remote Desktop Users groups.

```
GROUP ID: V-253480
RULE ID: SV-253480r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Access this computer from the network" user right may access resources on the system, and must be limited to those that require it.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Access this computer from the network" user right, this is a finding:

Administrators

Remote Desktop Users

If a domain application account such as for a management tool requires this user right, this would not be a finding.

Vendor documentation must support the requirement for having the user right.

The requirement must be documented with the ISSO.

The application account, managed at the domain level, must meet requirements for application account passwords, such as length and frequency of changes as defined in the Windows Server STIGs.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Access this computer from the network"
```

to only include the following groups or accounts:

Administrators

Remote Desktop Users

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.233 WN11-UR-000015 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The "Act as part of the operating system" user right must not be assigned to any groups or accounts.

```
GROUP ID: V-253481
RULE ID: SV-253481r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Act as part of the operating system" user right can assume the identity of any user and gain access to resources that user is authorized to access. Any accounts with this right can take complete control of a system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts (to include administrators), are granted the "Act as part of the operating system" user right, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Act as part of the operating system"
```

to be defined but containing no entries (blank).

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.234 WN11-UR-000025 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Allow log on locally" user right must only be assigned to the Administrators and Users groups.

```
GROUP ID: V-253482
RULE ID: SV-253482r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Allow log on locally" user right can log on interactively to a system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Allow log on locally" user right, this is a finding:

Administrators

Users

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Allow log on locally"
```

to only include the following groups or accounts:

Administrators

Users

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.235 WN11-UR-000030 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Back up files and directories" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253483
RULE ID: SV-253483r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Back up files and directories" user right can circumvent file and directory permissions and could allow access to sensitive data."

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Back up files and directories" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Back up files and directories"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.236 WN11-UR-000035 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Change the system time" user right must only be assigned to Administrators and Local Service.

```
GROUP ID: V-253484
RULE ID: SV-253484r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Change the system time" user right can change the system time, which can impact authentication, as well as affect time stamps on event log entries.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Change the system time" user right, this is a finding:

Administrators

LOCAL SERVICE

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Change the system time"
```

to only include the following groups or accounts:

Administrators

LOCAL SERVICE

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.237 WN11-UR-000040 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Create a pagefile" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253485
RULE ID: SV-253485r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Create a pagefile" user right can change the size of a pagefile, which could affect system performance.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Create a pagefile" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Create a pagefile"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.238 WN11-UR-000045 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The "Create a token object" user right must not be assigned to any groups or accounts.

```
GROUP ID: V-253486
RULE ID: SV-253486r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Create a token object" user right allows a process to create an access token. This could be used to provide elevated rights and compromise a system.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts are granted the "Create a token object" user right, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Create a token object"
```

to be defined but containing no entries (blank).

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.239 WN11-UR-000050 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Create global objects" user right must only be assigned to Administrators, Service, Local Service, and Network Service.

```
GROUP ID: V-253487
RULE ID: SV-253487r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Create global objects" user right can create objects that are available to all sessions, which could affect processes in other users' sessions.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Create global objects" user right, this is a finding:

Administrators

LOCAL SERVICE

NETWORK SERVICE

SERVICE

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Create global objects"
```

to only include the following groups or accounts:

Administrators

LOCAL SERVICE

NETWORK SERVICE

SERVICE

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.240 WN11-UR-000055 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Create permanent shared objects" user right must not be assigned to any groups or accounts.

```
GROUP ID: V-253488
RULE ID: SV-253488r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Create permanent shared objects" user right could expose sensitive data by creating shared objects.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts are granted the "Create permanent shared objects" user right, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Create permanent shared objects"
```

to be defined but containing no entries (blank).

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.241 WN11-UR-000060 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Create symbolic links" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253489
RULE ID: SV-253489r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Create symbolic links" user right can create pointers to other objects, which could potentially expose the system to attack.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Create symbolic links" user right, this is a finding:

Administrators

If the workstation has an approved use of Hyper-V, such as being used as a dedicated admin workstation using Hyper-V to separate administration and standard user functions, "NT VIRTUAL MACHINES\VIRTUAL MACHINE" may be assigned this user right and is not a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Create symbolic links"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.242 WN11-UR-000065 (Manual)

Profile Applicability:

- SEVERITY: CAT I

Description:

The "Debug programs" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253490
RULE ID: SV-253490r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Debug Programs" user right can attach a debugger to any process or to the kernel, providing complete access to sensitive and critical operating system components. This right is given to Administrators in the default configuration.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Debug Programs" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Debug programs"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.243 WN11-UR-000070 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Deny access to this computer from the network" user right on workstations must be configured to prevent access from highly privileged domain accounts and local accounts on domain systems and unauthenticated access on all systems.

```
GROUP ID: V-253491
RULE ID: SV-253491r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Deny access to this computer from the network" right defines the accounts that are prevented from logging on from the network.

In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks, which could lead to the compromise of an entire domain.

Local accounts on domain-joined systems must also be assigned this right to decrease the risk of lateral movement resulting from credential theft attacks.

The Guests group must be assigned this right to prevent unauthenticated access.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If the following groups or accounts are not defined for the "Deny access to this computer from the network" right, this is a finding:

Domain Systems Only:

Enterprise Admins group

Domain Admins group

Local account (see Note below)

All Systems:

Guests group

Privileged Access Workstations (PAWs) dedicated to the management of Active Directory are exempt from denying the Enterprise Admins and Domain Admins groups. (See the Windows Privileged Access Workstation STIG for PAW requirements.)

Note: "Local account" is a built-in security group used to assign user rights and permissions to all local accounts.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Deny access to this computer from the
network"
```

to include the following:

Domain Systems Only:

Enterprise Admins group

Domain Admins group

Local account (see Note below)

All Systems:

Guests group

Privileged Access Workstations (PAWs) dedicated to the management of Active Directory are exempt from denying the Enterprise Admins and Domain Admins groups. (See the Windows Privileged Access Workstation STIG for PAW requirements.)

Note: "Local account" is a built-in security group used to assign user rights and permissions to all local accounts.

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.244 WN11-UR-000075 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Deny log on as a batch job" user right on domain-joined workstations must be configured to prevent access from highly privileged domain accounts.

```
GROUP ID: V-253492
RULE ID: SV-253492r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Deny log on as a batch job" right defines accounts that are prevented from logging on to the system as a batch job, such as Task Scheduler.

In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks which could lead to the compromise of an entire domain.

Audit:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If the following groups or accounts are not defined for the "Deny log on as a batch job" right, this is a finding:

Domain Systems Only:

Enterprise Admin Group

Domain Admin Group

Remediation:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Deny log on as a batch job"
```

to include the following:

Domain Systems Only:

Enterprise Admin Group

Domain Admin Group

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.245 WN11-UR-000080 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Deny log on as a service" user right on Windows 11 domain-joined workstations must be configured to prevent access from highly privileged domain accounts.

```
GROUP ID: V-253493
RULE ID: SV-253493r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Deny log on as a service" right defines accounts that are denied log on as a service.

In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks which could lead to the compromise of an entire domain.

Incorrect configurations could prevent services from starting and result in a DoS.

Audit:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If the following groups or accounts are not defined for the "Deny log on as a service" right , this is a finding:

Domain Systems Only:

Enterprise Admins Group

Domain Admins Group

Remediation:

This requirement is applicable to domain-joined systems, for standalone systems this is NA.

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Deny log on as a service"
```

to include the following:

Domain Systems Only:

Enterprise Admins Group

Domain Admins Group

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.246 WN11-UR-000085 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Deny log on locally" user right on workstations must be configured to prevent access from highly privileged domain accounts on domain systems and unauthenticated access on all systems.

```
GROUP ID: V-253494
RULE ID: SV-253494r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Deny log on locally" right defines accounts that are prevented from logging on interactively.

In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks, which could lead to the compromise of an entire domain.

The Guests group must be assigned this right to prevent unauthenticated access.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If the following groups or accounts are not defined for the "Deny log on locally" right, this is a finding.

Domain Systems Only:

Enterprise Admins Group

Domain Admins Group

Privileged Access Workstations (PAWs) dedicated to the management of Active Directory are exempt from denying the Enterprise Admins and Domain Admins groups. (See the Windows Privileged Access Workstation STIG for PAW requirements.)

All Systems:

Guests Group

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Deny log on locally"
```

to include the following:

Domain Systems Only:

Enterprise Admins Group

Domain Admins Group

Privileged Access Workstations (PAWs) dedicated to the management of Active Directory are exempt from denying the Enterprise Admins and Domain Admins groups. (See the Windows Privileged Access Workstation STIG for PAW requirements.)

All Systems:

Guests Group

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

1.247 WN11-UR-000090 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Deny log on through Remote Desktop Services" user right on Windows 11 workstations must be configured to prevent access from highly privileged domain accounts and local accounts on domain systems and unauthenticated access on all systems.

```
GROUP ID: V-253495
RULE ID: SV-253495r958472
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Deny log on through Remote Desktop Services" right defines the accounts that are prevented from logging on using Remote Desktop Services.

If Remote Desktop Services is not used by the organization, the Everyone group must be assigned this right to prevent all access.

In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks, which could lead to the compromise of an entire domain.

Local accounts on domain-joined systems must also be assigned this right to decrease the risk of lateral movement resulting from credential theft attacks.

The Guests group must be assigned this right to prevent unauthenticated access.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If the following groups or accounts are not defined for the "Deny log on through Remote Desktop Services" right, this is a finding:

If Remote Desktop Services is not used by the organization, the "Everyone" group can replace all of the groups listed below.

Domain Systems Only:

Enterprise Admins group

Domain Admins group

Local account (see Note below)

All Systems:

Guests group

Privileged Access Workstations (PAWs) dedicated to the management of Active Directory are exempt from denying the Enterprise Admins and Domain Admins groups. (See the Windows Privileged Access Workstation STIG for PAW requirements.)

Note: "Local account" is a built-in security group used to assign user rights and permissions to all local accounts.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Deny log on through Remote Desktop
Services"
```

to include the following:

If Remote Desktop Services is not used by the organization, assign the Everyone group this right to prevent all access.

Domain Systems Only:

Enterprise Admins group

Domain Admins group

Local account (see Note below)

All Systems:

Guests group

Privileged Access Workstations (PAWs) dedicated to the management of Active Directory are exempt from denying the Enterprise Admins and Domain Admins groups. (See the Windows Privileged Access Workstation STIG for PAW requirements.)

Note: "Local account" is a built-in security group used to assign user rights and permissions to all local accounts.

Additional Information:

CCI-000213 Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

- NIST SP 800-53::AC-3
- NIST SP 800-53 Revision 4::AC-3
- NIST SP 800-53 Revision 5::AC-3
- NIST SP 800-53A::AC-3.1

CCI-002314 Employ automated mechanisms to control remote access methods.

- NIST SP 800-53 Revision 4::AC-17 (1)
- NIST SP 800-53 Revision 5::AC-17 (1)

1.248 WN11-UR-000095 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Enable computer and user accounts to be trusted for delegation" user right must not be assigned to any groups or accounts.

```
GROUP ID: V-253496
RULE ID: SV-253496r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Enable computer and user accounts to be trusted for delegation" user right allows the "Trusted for Delegation" setting to be changed. This could potentially allow unauthorized users to impersonate other users.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts are granted the "Enable computer and user accounts to be trusted for delegation" user right, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Enable computer and user accounts to
be trusted for delegation"
```

to be defined but containing no entries (blank).

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.249 WN11-UR-000100 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Force shutdown from a remote system" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253497
RULE ID: SV-253497r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Force shutdown from a remote system" user right can remotely shut down a system which could result in a DoS.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Force shutdown from a remote system" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Force shutdown from a remote system"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.250 WN11-UR-000110 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Impersonate a client after authentication" user right must only be assigned to Administrators, Service, Local Service, and Network Service.

```
GROUP ID: V-253498
RULE ID: SV-253498r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Impersonate a client after authentication" user right allows a program to impersonate another user or account to run on their behalf. An attacker could potentially use this to elevate privileges.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Impersonate a client after authentication" user right, this is a finding:

Administrators

LOCAL SERVICE

NETWORK SERVICE

SERVICE

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Impersonate a client after
authentication"
```

to only include the following groups or accounts:

Administrators

LOCAL SERVICE

NETWORK SERVICE

SERVICE

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.251 WN11-UR-000120 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Load and unload device drivers" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253499
RULE ID: SV-253499r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Load and unload device drivers" user right allows device drivers to dynamically be loaded on a system by a user. This could potentially be used to install malicious code by an attacker.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Load and unload device drivers" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Load and unload device drivers"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.252 WN11-UR-000125 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Lock pages in memory" user right must not be assigned to any groups or accounts.

```
GROUP ID: V-253500
RULE ID: SV-253500r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

The "Lock pages in memory" user right allows physical memory to be assigned to processes, which could cause performance issues or a DoS.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts are granted the "Lock pages in memory" user right, this is a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Lock pages in memory"
```

to be defined but containing no entries (blank).

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.253 WN11-UR-000130 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Manage auditing and security log" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253501
RULE ID: SV-253501r958434
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Manage auditing and security log" user right can manage the security log and change auditing configurations. This could be used to clear evidence of tampering.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000063-GPOS-00032

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Manage auditing and security log" user right, this is a finding:

Administrators

If the organization has an "Auditors" group the assignment of this group to the user right would not be a finding.

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Manage auditing and security log"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-000162 Protect audit information from unauthorized access.

- NIST SP 800-53::AU-9
- NIST SP 800-53 Revision 4::AU-9
- NIST SP 800-53 Revision 5::AU-9 a
- NIST SP 800-53A::AU-9.1

CCI-000171 Allow organization-defined personnel or roles to select the event types that are to be logged by specific components of the system.

- NIST SP 800-53::AU-12 b
- NIST SP 800-53 Revision 4::AU-12 b
- NIST SP 800-53 Revision 5::AU-12 b
- NIST SP 800-53A::AU-12.1 (iii)

1.254 WN11-UR-000140 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Modify firmware environment values" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253502
RULE ID: SV-253502r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Modify firmware environment values" user right can change hardware configuration environment variables. This could result in hardware failures or a DoS.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Modify firmware environment values" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Modify firmware environment values"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.255 WN11-UR-000145 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Perform volume maintenance tasks" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253503
RULE ID: SV-253503r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Perform volume maintenance tasks" user right can manage volume and disk configurations. They could potentially delete volumes, resulting in data loss or a DoS.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Perform volume maintenance tasks" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Perform volume maintenance tasks"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.256 WN11-UR-000150 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Profile single process" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253504
RULE ID: SV-253504r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Profile single process" user right can monitor non-system processes performance. An attacker could potentially use this to identify processes to attack.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Profile single process" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Profile single process"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.257 WN11-UR-000160 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Restore files and directories" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253505
RULE ID: SV-253505r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Restore files and directories" user right can circumvent file and directory permissions and could allow access to sensitive data. It could also be used to over-write more current data.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Restore files and directories" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Restore files and directories"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

1.258 WN11-UR-000165 (Manual)

Profile Applicability:

- SEVERITY: CAT II

Description:

The "Take ownership of files or other objects" user right must only be assigned to the Administrators group.

```
GROUP ID: V-253506
RULE ID: SV-253506r958726
```

Rationale:

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities.

Accounts with the "Take ownership of files or other objects" user right can take ownership of objects and make changes.

Audit:

Verify the effective setting in Local Group Policy Editor.

Run "gpedit.msc".

Navigate to Local Computer Policy >>

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment.
```

If any groups or accounts other than the following are granted the "Take ownership of files or other objects" user right, this is a finding:

Administrators

Remediation:

Configure the policy value for

```
Computer Configuration >> Windows Settings >> Security Settings >> Local
Policies >> User Rights Assignment >> "Take ownership of files or other
objects"
```

to only include the following groups or accounts:

Administrators

Additional Information:

CCI-002235 Prevent non-privileged users from executing privileged functions.

- NIST SP 800-53 Revision 4::AC-6 (10)
- NIST SP 800-53 Revision 5::AC-6 (10)

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**STIG RULES**		
1.1	WN11-00-000005 (Manual)	☐	☐
1.2	WN11-00-000010 (Manual)	☐	☐
1.3	WN11-00-000015 (Manual)	☐	☐
1.4	WN11-00-000020 (Manual)	☐	☐
1.5	WN11-00-000025 (Manual)	☐	☐
1.6	WN11-00-000030 (Manual)	☐	☐
1.7	WN11-00-000031 (Manual)	☐	☐
1.8	WN11-00-000032 (Manual)	☐	☐
1.9	WN11-00-000035 (Manual)	☐	☐
1.10	WN11-00-000040 (Manual)	☐	☐
1.11	WN11-00-000045 (Manual)	☐	☐
1.12	WN11-00-000050 (Manual)	☐	☐
1.13	WN11-00-000055 (Manual)	☐	☐
1.14	WN11-00-000060 (Manual)	☐	☐
1.15	WN11-00-000065 (Manual)	☐	☐
1.16	WN11-00-000070 (Manual)	☐	☐
1.17	WN11-00-000075 (Manual)	☐	☐
1.18	WN11-00-000080 (Manual)	☐	☐
1.19	WN11-00-000085 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.20	WN11-00-000090 (Manual)	☐	☐
1.21	WN11-00-000095 (Manual)	☐	☐
1.22	WN11-00-000100 (Manual)	☐	☐
1.23	WN11-00-000105 (Manual)	☐	☐
1.24	WN11-00-000110 (Manual)	☐	☐
1.25	WN11-00-000115 (Manual)	☐	☐
1.26	WN11-00-000120 (Manual)	☐	☐
1.27	WN11-00-000125 (Manual)	☐	☐
1.28	WN11-00-000130 (Manual)	☐	☐
1.29	WN11-00-000135 (Manual)	☐	☐
1.30	WN11-00-000140 (Manual)	☐	☐
1.31	WN11-00-000145 (Manual)	☐	☐
1.32	WN11-00-000150 (Manual)	☐	☐
1.33	WN11-00-000155 (Manual)	☐	☐
1.34	WN11-00-000160 (Manual)	☐	☐
1.35	WN11-00-000165 (Manual)	☐	☐
1.36	WN11-00-000170 (Manual)	☐	☐
1.37	WN11-00-000175 (Manual)	☐	☐
1.38	WN11-00-000190 (Manual)	☐	☐
1.39	WN11-00-000210 (Manual)	☐	☐
1.40	WN11-00-000220 (Manual)	☐	☐
1.41	WN11-00-000230 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.42	WN11-00-000240 (Manual)	☐	☐
1.43	WN11-00-000250 (Manual)	☐	☐
1.44	WN11-00-000260 (Manual)	☐	☐
1.45	WN11-00-000395 (Manual)	☐	☐
1.46	WN11-AC-000005 (Manual)	☐	☐
1.47	WN11-AC-000010 (Manual)	☐	☐
1.48	WN11-AC-000015 (Manual)	☐	☐
1.49	WN11-AC-000020 (Manual)	☐	☐
1.50	WN11-AC-000025 (Manual)	☐	☐
1.51	WN11-AC-000030 (Manual)	☐	☐
1.52	WN11-AC-000035 (Manual)	☐	☐
1.53	WN11-AC-000040 (Manual)	☐	☐
1.54	WN11-AC-000045 (Manual)	☐	☐
1.55	WN11-AU-000005 (Manual)	☐	☐
1.56	WN11-AU-000010 (Manual)	☐	☐
1.57	WN11-AU-000030 (Manual)	☐	☐
1.58	WN11-AU-000035 (Manual)	☐	☐
1.59	WN11-AU-000040 (Manual)	☐	☐
1.60	WN11-AU-000045 (Manual)	☐	☐
1.61	WN11-AU-000050 (Manual)	☐	☐
1.62	WN11-AU-000054 (Manual)	☐	☐
1.63	WN11-AU-000060 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.64	WN11-AU-000065 (Manual)	☐	☐
1.65	WN11-AU-000070 (Manual)	☐	☐
1.66	WN11-AU-000080 (Manual)	☐	☐
1.67	WN11-AU-000075 (Manual)	☐	☐
1.68	WN11-AU-000081 (Manual)	☐	☐
1.69	WN11-AU-000082 (Manual)	☐	☐
1.70	WN11-AU-000083 (Manual)	☐	☐
1.71	WN11-AU-000084 (Manual)	☐	☐
1.72	WN11-AU-000085 (Manual)	☐	☐
1.73	WN11-AU-000090 (Manual)	☐	☐
1.74	WN11-AU-000100 (Manual)	☐	☐
1.75	WN11-AU-000105 (Manual)	☐	☐
1.76	WN11-AU-000107 (Manual)	☐	☐
1.77	WN11-AU-000110 (Manual)	☐	☐
1.78	WN11-AU-000115 (Manual)	☐	☐
1.79	WN11-AU-000120 (Manual)	☐	☐
1.80	WN11-AU-000130 (Manual)	☐	☐
1.81	WN11-AU-000135 (Manual)	☐	☐
1.82	WN11-AU-000140 (Manual)	☐	☐
1.83	WN11-AU-000150 (Manual)	☐	☐
1.84	WN11-AU-000155 (Manual)	☐	☐
1.85	WN11-AU-000160 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.86	WN11-AU-000500 (Manual)	☐	☐
1.87	WN11-AU-000505 (Manual)	☐	☐
1.88	WN11-AU-000510 (Manual)	☐	☐
1.89	WN11-AU-000515 (Manual)	☐	☐
1.90	WN11-AU-000520 (Manual)	☐	☐
1.91	WN11-AU-000525 (Manual)	☐	☐
1.92	WN11-AU-000550 (Manual)	☐	☐
1.93	WN11-AU-000555 (Manual)	☐	☐
1.94	WN11-AU-000560 (Manual)	☐	☐
1.95	WN11-AU-000565 (Manual)	☐	☐
1.96	WN11-AU-000570 (Manual)	☐	☐
1.97	WN11-AU-000575 (Manual)	☐	☐
1.98	WN11-AU-000580 (Manual)	☐	☐
1.99	WN11-AU-000585 (Manual)	☐	☐
1.100	WN11-CC-000005 (Manual)	☐	☐
1.101	WN11-CC-000007 (Manual)	☐	☐
1.102	WN11-CC-000010 (Manual)	☐	☐
1.103	WN11-CC-000020 (Manual)	☐	☐
1.104	WN11-CC-000025 (Manual)	☐	☐
1.105	WN11-CC-000030 (Manual)	☐	☐
1.106	WN11-CC-000035 (Manual)	☐	☐
1.107	WN11-CC-000037 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.108	WN11-CC-000038 (Manual)	☐	☐
1.109	WN11-CC-000039 (Manual)	☐	☐
1.110	WN11-CC-000040 (Manual)	☐	☐
1.111	WN11-CC-000044 (Manual)	☐	☐
1.112	WN11-CC-000050 (Manual)	☐	☐
1.113	WN11-CC-000052 (Manual)	☐	☐
1.114	WN11-CC-000055 (Manual)	☐	☐
1.115	WN11-CC-000060 (Manual)	☐	☐
1.116	WN11-CC-000063 (Manual)	☐	☐
1.117	WN11-CC-000065 (Manual)	☐	☐
1.118	WN11-CC-000066 (Manual)	☐	☐
1.119	WN11-CC-000068 (Manual)	☐	☐
1.120	WN11-CC-000070 (Manual)	☐	☐
1.121	WN11-CC-000075 (Manual)	☐	☐
1.122	WN11-CC-000080 (Manual)	☐	☐
1.123	WN11-CC-000085 (Manual)	☐	☐
1.124	WN11-CC-000090 (Manual)	☐	☐
1.125	WN11-CC-000100 (Manual)	☐	☐
1.126	WN11-CC-000105 (Manual)	☐	☐
1.127	WN11-CC-000110 (Manual)	☐	☐
1.128	WN11-CC-000115 (Manual)	☐	☐
1.129	WN11-CC-000120 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.130	WN11-CC-000130 (Manual)	☐	☐
1.131	WN11-CC-000145 (Manual)	☐	☐
1.132	WN11-CC-000150 (Manual)	☐	☐
1.133	WN11-CC-000155 (Manual)	☐	☐
1.134	WN11-CC-000165 (Manual)	☐	☐
1.135	WN11-CC-000170 (Manual)	☐	☐
1.136	WN11-CC-000175 (Manual)	☐	☐
1.137	WN11-CC-000180 (Manual)	☐	☐
1.138	WN11-CC-000185 (Manual)	☐	☐
1.139	WN11-CC-000190 (Manual)	☐	☐
1.140	WN11-CC-000195 (Manual)	☐	☐
1.141	WN11-CC-000197 (Manual)	☐	☐
1.142	WN11-CC-000200 (Manual)	☐	☐
1.143	WN11-CC-000204 (Manual)	☐	☐
1.144	WN11-CC-000205 (Manual)	☐	☐
1.145	WN11-CC-000206 (Manual)	☐	☐
1.146	WN11-CC-000210 (Manual)	☐	☐
1.147	WN11-CC-000215 (Manual)	☐	☐
1.148	WN11-CC-000220 (Manual)	☐	☐
1.149	WN11-CC-000225 (Manual)	☐	☐
1.150	WN11-CC-000252 (Manual)	☐	☐
1.151	WN11-CC-000255 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.152	WN11-CC-000260 (Manual)	☐	☐
1.153	WN11-CC-000270 (Manual)	☐	☐
1.154	WN11-CC-000275 (Manual)	☐	☐
1.155	WN11-CC-000280 (Manual)	☐	☐
1.156	WN11-CC-000285 (Manual)	☐	☐
1.157	WN11-CC-000290 (Manual)	☐	☐
1.158	WN11-CC-000295 (Manual)	☐	☐
1.159	WN11-CC-000300 (Manual)	☐	☐
1.160	WN11-CC-000305 (Manual)	☐	☐
1.161	WN11-CC-000310 (Manual)	☐	☐
1.162	WN11-CC-000315 (Manual)	☐	☐
1.163	WN11-CC-000320 (Manual)	☐	☐
1.164	WN11-CC-000325 (Manual)	☐	☐
1.165	WN11-CC-000326 (Manual)	☐	☐
1.166	WN11-CC-000327 (Manual)	☐	☐
1.167	WN11-CC-000330 (Manual)	☐	☐
1.168	WN11-CC-000335 (Manual)	☐	☐
1.169	WN11-CC-000345 (Manual)	☐	☐
1.170	WN11-CC-000350 (Manual)	☐	☐
1.171	WN11-CC-000355 (Manual)	☐	☐
1.172	WN11-CC-000360 (Manual)	☐	☐
1.173	WN11-CC-000365 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.174	WN11-CC-000370 (Manual)	☐	☐
1.175	WN11-CC-000385 (Manual)	☐	☐
1.176	WN11-CC-000390 (Manual)	☐	☐
1.177	WN11-CC-000391 (Manual)	☐	☐
1.178	WN11-EP-000310 (Manual)	☐	☐
1.179	WN11-PK-000005 (Manual)	☐	☐
1.180	WN11-PK-000010 (Manual)	☐	☐
1.181	WN11-PK-000015 (Manual)	☐	☐
1.182	WN11-PK-000020 (Manual)	☐	☐
1.183	WN11-RG-000005 (Manual)	☐	☐
1.184	WN11-SO-000005 (Manual)	☐	☐
1.185	WN11-SO-000010 (Manual)	☐	☐
1.186	WN11-SO-000015 (Manual)	☐	☐
1.187	WN11-SO-000020 (Manual)	☐	☐
1.188	WN11-SO-000025 (Manual)	☐	☐
1.189	WN11-SO-000030 (Manual)	☐	☐
1.190	WN11-SO-000035 (Manual)	☐	☐
1.191	WN11-SO-000040 (Manual)	☐	☐
1.192	WN11-SO-000045 (Manual)	☐	☐
1.193	WN11-SO-000050 (Manual)	☐	☐
1.194	WN11-SO-000055 (Manual)	☐	☐
1.195	WN11-SO-000060 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.196	WN11-SO-000070 (Manual)	☐	☐
1.197	WN11-SO-000075 (Manual)	☐	☐
1.198	WN11-SO-000080 (Manual)	☐	☐
1.199	WN11-SO-000085 (Manual)	☐	☐
1.200	WN11-SO-000095 (Manual)	☐	☐
1.201	WN11-SO-000100 (Manual)	☐	☐
1.202	WN11-SO-000110 (Manual)	☐	☐
1.203	WN11-SO-000120 (Manual)	☐	☐
1.204	WN11-SO-000140 (Manual)	☐	☐
1.205	WN11-SO-000145 (Manual)	☐	☐
1.206	WN11-SO-000150 (Manual)	☐	☐
1.207	WN11-SO-000160 (Manual)	☐	☐
1.208	WN11-SO-000165 (Manual)	☐	☐
1.209	WN11-SO-000167 (Manual)	☐	☐
1.210	WN11-SO-000180 (Manual)	☐	☐
1.211	WN11-SO-000185 (Manual)	☐	☐
1.212	WN11-SO-000190 (Manual)	☐	☐
1.213	WN11-SO-000195 (Manual)	☐	☐
1.214	WN11-SO-000205 (Manual)	☐	☐
1.215	WN11-SO-000210 (Manual)	☐	☐
1.216	WN11-SO-000215 (Manual)	☐	☐
1.217	WN11-SO-000220 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.218	WN11-SO-000230 (Manual)	☐	☐
1.219	WN11-SO-000240 (Manual)	☐	☐
1.220	WN11-SO-000245 (Manual)	☐	☐
1.221	WN11-SO-000250 (Manual)	☐	☐
1.222	WN11-SO-000251 (Manual)	☐	☐
1.223	WN11-SO-000255 (Manual)	☐	☐
1.224	WN11-SO-000260 (Manual)	☐	☐
1.225	WN11-SO-000265 (Manual)	☐	☐
1.226	WN11-SO-000270 (Manual)	☐	☐
1.227	WN11-SO-000275 (Manual)	☐	☐
1.228	WN11-SO-000280 (Manual)	☐	☐
1.229	WN11-UC-000015 (Manual)	☐	☐
1.230	WN11-UR-000005 (Manual)	☐	☐
1.231	WN11-UC-000020 (Manual)	☐	☐
1.232	WN11-UR-000010 (Manual)	☐	☐
1.233	WN11-UR-000015 (Manual)	☐	☐
1.234	WN11-UR-000025 (Manual)	☐	☐
1.235	WN11-UR-000030 (Manual)	☐	☐
1.236	WN11-UR-000035 (Manual)	☐	☐
1.237	WN11-UR-000040 (Manual)	☐	☐
1.238	WN11-UR-000045 (Manual)	☐	☐
1.239	WN11-UR-000050 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.240	WN11-UR-000055 (Manual)	☐	☐
1.241	WN11-UR-000060 (Manual)	☐	☐
1.242	WN11-UR-000065 (Manual)	☐	☐
1.243	WN11-UR-000070 (Manual)	☐	☐
1.244	WN11-UR-000075 (Manual)	☐	☐
1.245	WN11-UR-000080 (Manual)	☐	☐
1.246	WN11-UR-000085 (Manual)	☐	☐
1.247	WN11-UR-000090 (Manual)	☐	☐
1.248	WN11-UR-000095 (Manual)	☐	☐
1.249	WN11-UR-000100 (Manual)	☐	☐
1.250	WN11-UR-000110 (Manual)	☐	☐
1.251	WN11-UR-000120 (Manual)	☐	☐
1.252	WN11-UR-000125 (Manual)	☐	☐
1.253	WN11-UR-000130 (Manual)	☐	☐
1.254	WN11-UR-000140 (Manual)	☐	☐
1.255	WN11-UR-000145 (Manual)	☐	☐
1.256	WN11-UR-000150 (Manual)	☐	☐
1.257	WN11-UR-000160 (Manual)	☐	☐
1.258	WN11-UR-000165 (Manual)	☐	☐

Appendix: Change History

Date	Version	Changes for this version
08/12/2025	v1.0.0	Initial CIS Release